DevSecOps pipeline: final report

Oussama Koudhai · 4NIDS6, Esprit
Spring Boot student-management API
Project repository
Report built 2026-11-11 from revision `1abd571`.

First GitHub-hosted run on master

The pipeline passed on 11 November 2026 after PR #28 merged. SonarQube, Nexus, the image registry, the Compose stack and monitoring all ran on the disposable GitHub-hosted runner. Nmap acceptance passed, both Prometheus targets were UP, and all 30 sample API requests succeeded. The seven UI screenshots below come from this run. GitHub Actions run 43076300738 · Combined report artifact

The 5 November Azure run 42108525318 remains the historical evidence for delivery to an Azure VM. The Azure workflow is now manually triggered. The hosted workflow runs on pushes to `master` and pull requests targeting it.

How the lab maps to the course

Development runs the early security checks. Acceptance builds the artifact, starts a disposable Compose test environment and checks TCP exposure with Nmap. Production smoke testing then verifies the scanned digest and database-backed API on that same stack. Operations uses Prometheus and Grafana while the lab is running. The job demonstrates these practices without a separate production promotion or an always-on service.

Appendix B contains the hosted tool reports and the original evidence ZIP.

Appendix C contains the earlier standalone assessment PDFs.

Pipeline at a glance

#	Stage	Technique	Tool	Blocks the pipeline when	Report	Status
A. Development						
1	Threat modelling	STRIDE threat model, reviewed by a human before coding	documentation/THREAT-MODEL.md	The document must exist; CI preserves it with the run's reports	`precommit/THREAT-MODEL.md`	**Verified in a real run**
2	Pre-commit hooks	Local hooks replayed in CI: YAML/XML validity, merge markers, private-key headers, staged-secret scan	pre-commit, Gitleaks (staged snapshot)	Any hook failure stops the pipeline	`precommit/report.html`	**Verified in a real run**
3	Static application security testing	SAST with project rules for command execution, concatenated SQL and disabled TLS verification	Semgrep	Any finding fails (--error --strict)	`sast/report.html`	**Verified in a real run**
4	Secret scanning	Full Git history scan with redacted output	Gitleaks	Any new finding fails; one exact historical fingerprint is documented in SECURITY.md	`secrets/report.html`	**Verified in a real run**
5	Dependency analysis and SBOM	Software composition analysis of the source POM with a CycloneDX inventory	Trivy	HIGH/CRITICAL fails; empty or unversioned inventory is rejected	`dependencies/report.html`	**Verified in a real run**

#	Stage	Technique	Tool	Blocks the pipeline when	Report	Status
6	Infrastructure-as-code policy	Terraform fmt/validate, policy scan, custom SSH-to-internet rule, workflow lint, Caddy config validation	Terraform, Checkov, actionlint	Any unexcepted failure; ten exclusions are documented in SECURITY.md	`iac/report.html`	**Verified in a real run**
7	Collect pre-build reports	Aggregate every scanner output into one readable index	scripts/render-security-reports.py	Runs even after a failed gate	`index.html`	**Verified in a real run**
B. Acceptance						
8	Compile, test and coverage	Unit and HTTP integration tests with coverage measurement	Maven, JUnit (Surefire), JaCoCo	Any failed test blocks the image build	`build/report.html`	**Verified in a real run**
9	Code quality gate	Static analysis with a blocking quality gate	SonarQube Community Build	The pipeline waits for the gate and fails if it fails	`quality/report.html`	**Verified in a real run**
10	Artifact repository	Publish the tested JAR, then compare the stored checksum with the tested JAR	Sonatype Nexus	A different stored checksum fails the stage	`artifact/report.html`	**Verified in a real run**
11	Image build and vulnerability gate	Build a non-root image from the tested JAR and scan the final image. The parallel commit workflow also smoke-tests the image on ephemeral k3s.	Docker, Trivy, k3d	Any HIGH/CRITICAL finding fails, including unfixed ones	`image/report.html`	**Verified in a real run**
12	Image registry	Push the scanned image and deploy by immutable digest	Docker Distribution registry (runner loopback)	The digest must belong to the pushed image	`registry/report.html`	**Verified in a real run**
13	Acceptance lab	Start the lab's Compose stack on the runner and verify readiness before testing TCP exposure	Docker Compose, Spring Boot, MySQL	The running image must match the scanned digest and a database-backed API request must pass	`deploy/report.html`	**Verified in a real run**
14	Network acceptance	Scan the runner's primary IPv4 address and loopback against a TCP allowlist	Nmap	Unexpected open, missing required or incomplete scans fail	`acceptance/report.html`	**Verified in a real run**
C. Production						
15	Production smoke test	After Nmap passes, verify the running image digest and a database-backed API response	Docker image inspection, Spring Boot API, MySQL	The running image must match the scanned digest and the API must return a JSON array	`production/report.html`	**Verified in a real run**
D. Operations						
16	Monitoring: Prometheus and Grafana	Verify scrape targets, sample real queries after light API traffic, list provisioned dashboards	Prometheus, Node Exporter, Grafana	API and runner exporter UP, Grafana database healthy, both dashboards provisioned	`monitoring/, prometheus/, grafana/ report.html`	**Verified in a real run**
Supporting controls						
17	Dependency maintenance	Report weekly version-update PRs for five ecosystems and the status of GitHub's vulnerability alerts	Dependabot, GitHub REST API	Reported, not blocking: disabled alerts, HIGH/CRITICAL alerts and failing update PRs are highlighted for attention	`dependabot/report.html`	**Verified in a real run**
18	Email notification	Status, per-stage results and the run link sent at the end of every master run	SMTP over STARTTLS	Runs even after failure or cancellation	`the email, and the job in the run graph`	**Verified in a real run**

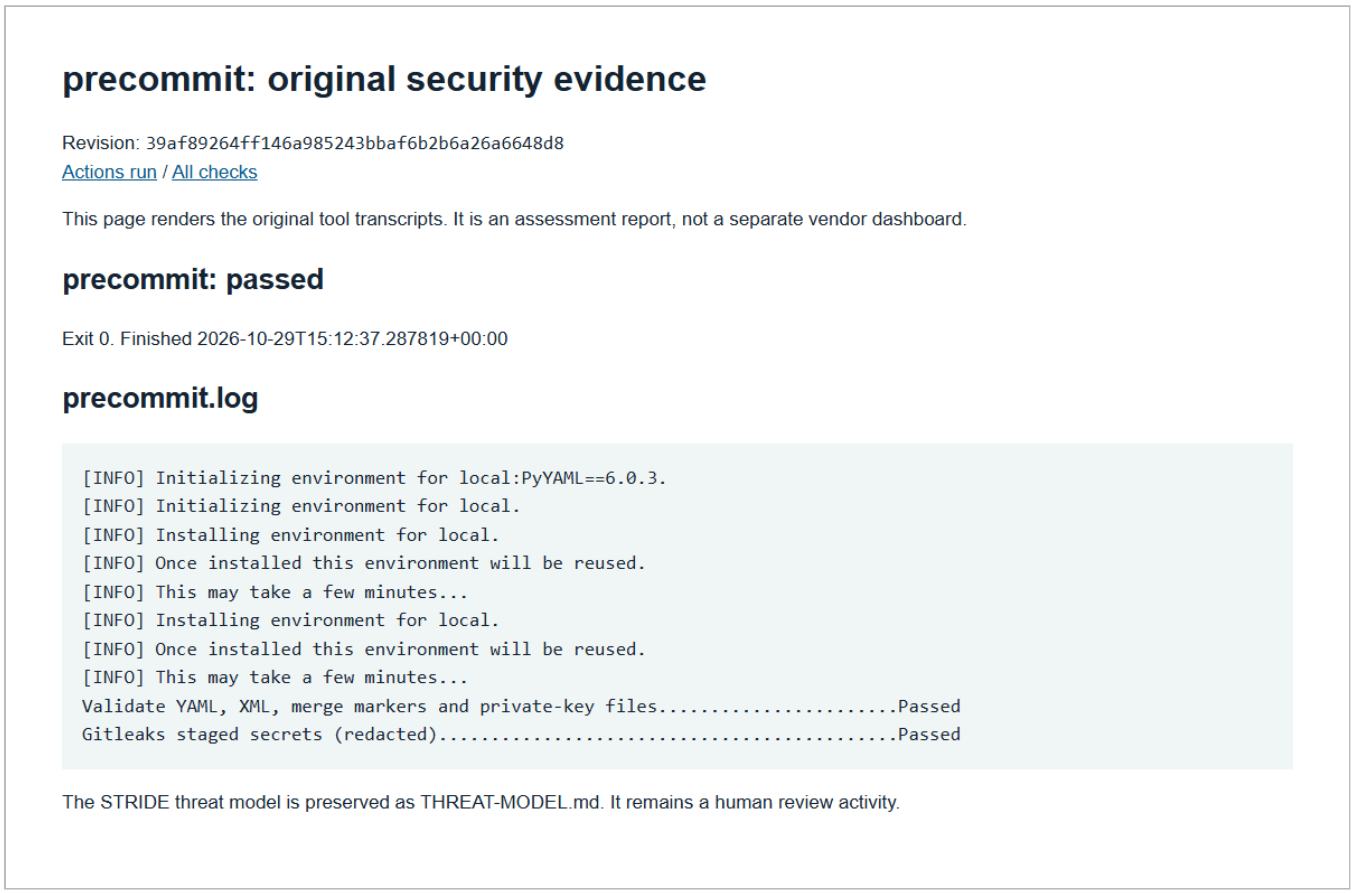
Stage by stage, with proof

A. Development

1. Threat modelling [Verified in a real run]

Technique: STRIDE threat model, reviewed by a human before coding
Tool: documentation/THREAT-MODEL.md
Blocks the pipeline when: The document must exist; CI preserves it with the run's reports
Report: `precommit/THREAT-MODEL.md`

Threat modelling is a human review: a green job proves the file is preserved, not that the analysis is complete.



precommit: original security evidence

Revision: 39af89264ff146a985243bbaf6b2b6a26a6648d8
Actions run / All checks

This page renders the original tool transcripts. It is an assessment report, not a separate vendor dashboard.

precommit: passed

Exit 0. Finished 2026-10-29T15:12:37.287819+00:00

precommit.log

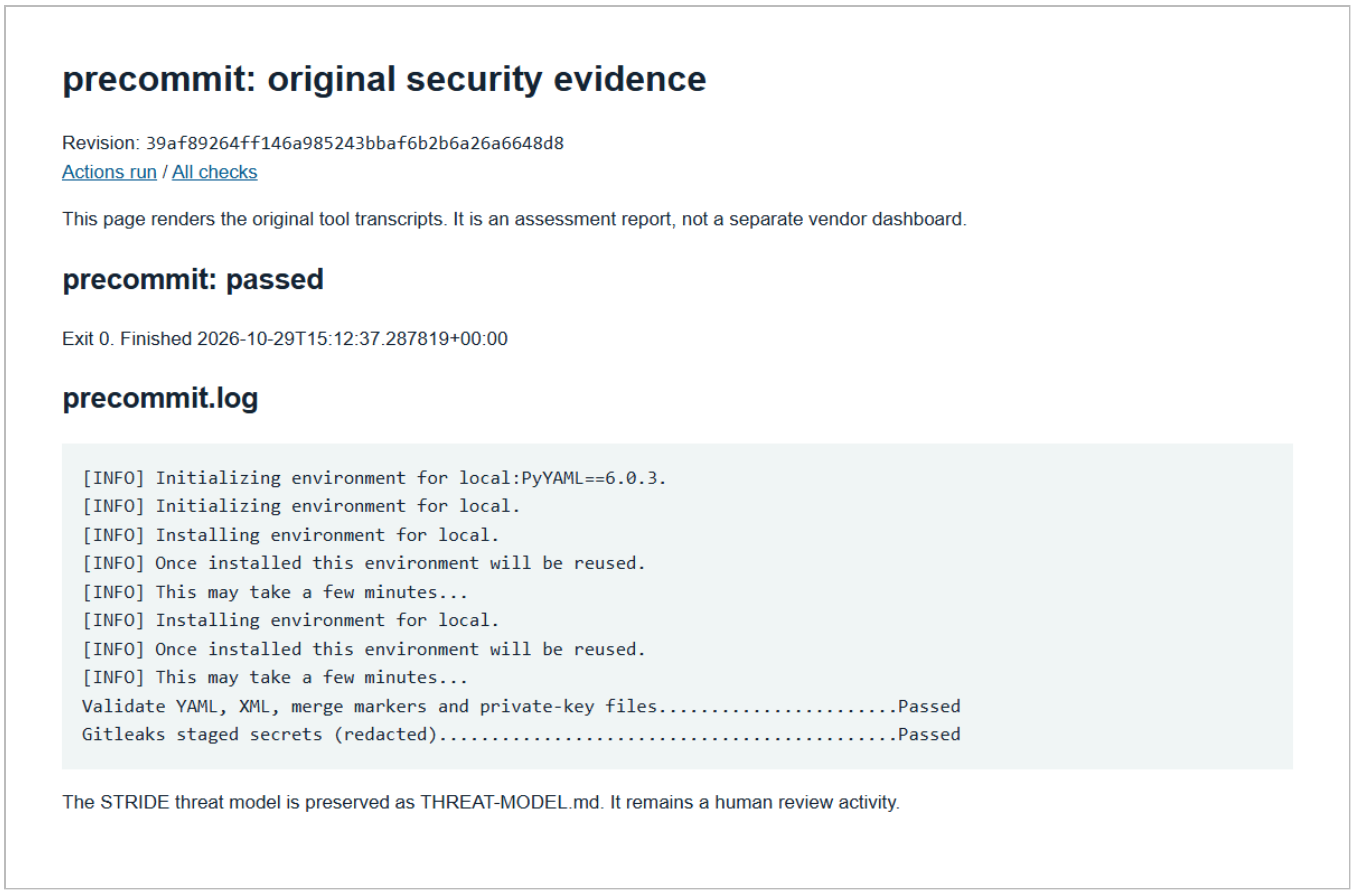
```
[INFO] Initializing environment for local:PyYAML==6.0.3.
[INFO] Initializing environment for local.
[INFO] Installing environment for local.
[INFO] Once installed this environment will be reused.
[INFO] This may take a few minutes...
[INFO] Installing environment for local.
[INFO] Once installed this environment will be reused.
[INFO] This may take a few minutes...
Validate YAML, XML, merge markers and private-key files.....................Passed
Gitleaks staged secrets (redacted)..........................................Passed
```

The STRIDE threat model is preserved as THREAT-MODEL.md. It remains a human review activity.

Pre-commit report page that preserves the threat model (run 40899036172, 29 Oct 2026)

2. Pre-commit hooks [Verified in a real run]

Technique: Local hooks replayed in CI: YAML/XML validity, merge markers, private-key headers, staged-secret scan
Tool: pre-commit, Gitleaks (staged snapshot)
Blocks the pipeline when: Any hook failure stops the pipeline
Report: `precommit/report.html`



precommit: original security evidence

Revision: `39af89264ff146a985243bbaf6b2b6a26a6648d8`
Actions run / All checks

This page renders the original tool transcripts. It is an assessment report, not a separate vendor dashboard.

precommit: passed

Exit 0. Finished 2026-10-29T15:12:37.287819+00:00

precommit.log

```
[INFO] Initializing environment for local:PyYAML==6.0.3.
[INFO] Initializing environment for local.
[INFO] Installing environment for local.
[INFO] Once installed this environment will be reused.
[INFO] This may take a few minutes...
[INFO] Installing environment for local.
[INFO] Once installed this environment will be reused.
[INFO] This may take a few minutes...
Validate YAML, XML, merge markers and private-key files.....................Passed
Gitleaks staged secrets (redacted)..........................................Passed
```

The STRIDE threat model is preserved as THREAT-MODEL.md. It remains a human review activity.

Hook transcript with Passed results (run 40899036172)

3. Static application security testing [Verified in a real run]

Technique: SAST with project rules for command execution, concatenated SQL and disabled TLS verification
Tool: Semgrep
Blocks the pipeline when: Any finding fails (--error --strict)
Report: `sast/report.html`

Deliberately narrow rule set, complemented by SonarQube.

sast: original security evidence

Revision: `39af89264ff146a985243bbaf6b2b6a26a6648d8`
Actions run / All checks

This page renders the original tool transcripts. It is an assessment report, not a separate vendor dashboard.

semgrep: passed

Exit 0. Finished 2026-10-29T15:13:05.819930+00:00

semgrep.log

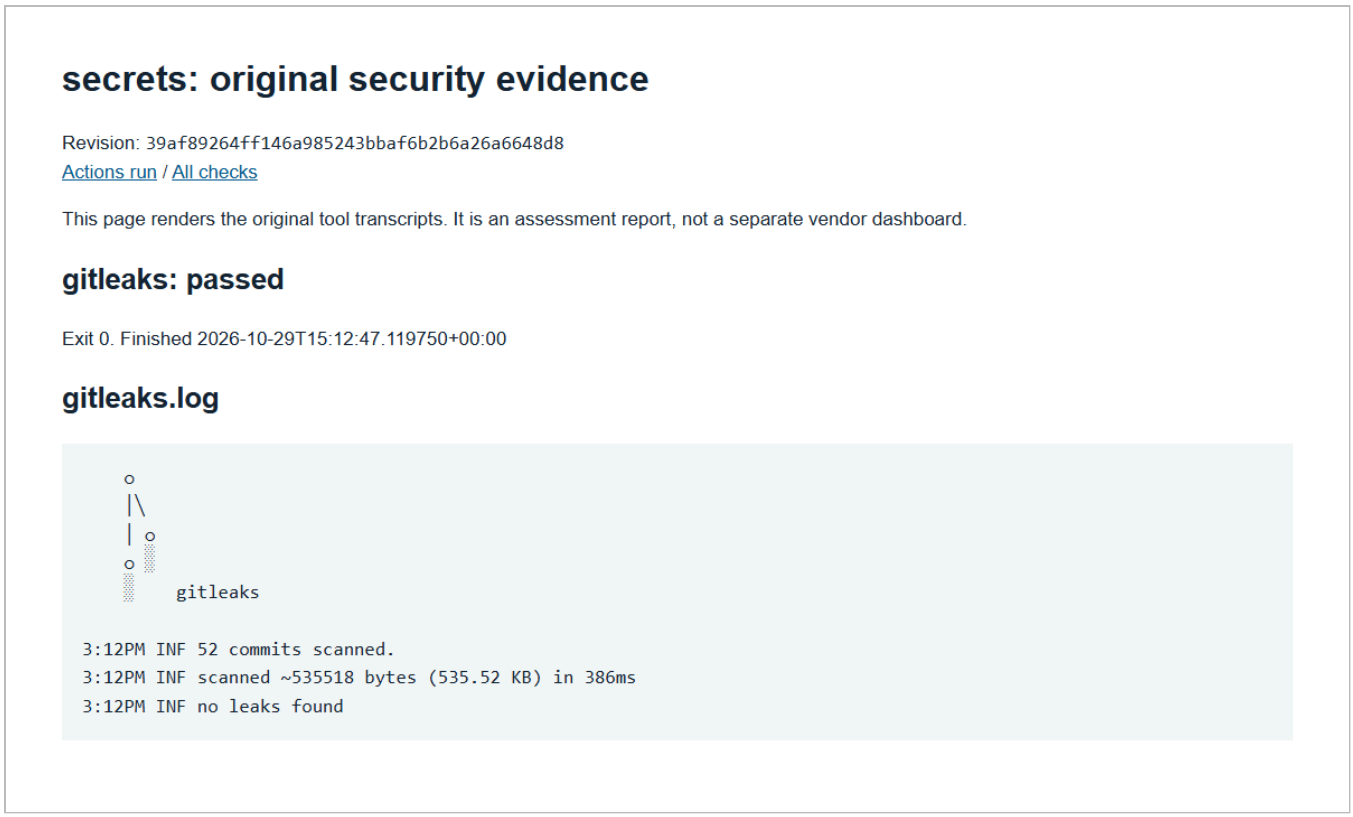
```
┌──────────────┐
│ Scan Status │
└──────────────┘
  Scanning 19 files tracked by git with 3 Code rules:
  Scanning 19 files with 3 java rules.


┌──────────────┐
│ Scan Summary │
└──────────────┘
✅ Scan completed successfully.
 • Findings: 0 (0 blocking)
 • Rules run: 3
 • Targets scanned: 19
 • Parsed lines: ~100.0%
 • Scan was limited to files tracked by git
 • For a detailed list of skipped files and lines, run semgrep with the --verbose flag
Ran 3 rules on 19 files: 0 findings.
If Semgrep missed a finding, please send us feedback to let us know!
See https://semgrep.dev/docs/reporting-false-negatives/
```

19 files scanned, 3 rules, 0 findings (run 40899036172)

4. Secret scanning [Verified in a real run]

Technique: Full Git history scan with redacted output
Tool: Gitleaks
Blocks the pipeline when: Any new finding fails; one exact historical fingerprint is documented in SECURITY.md
Report: `secrets/report.html`

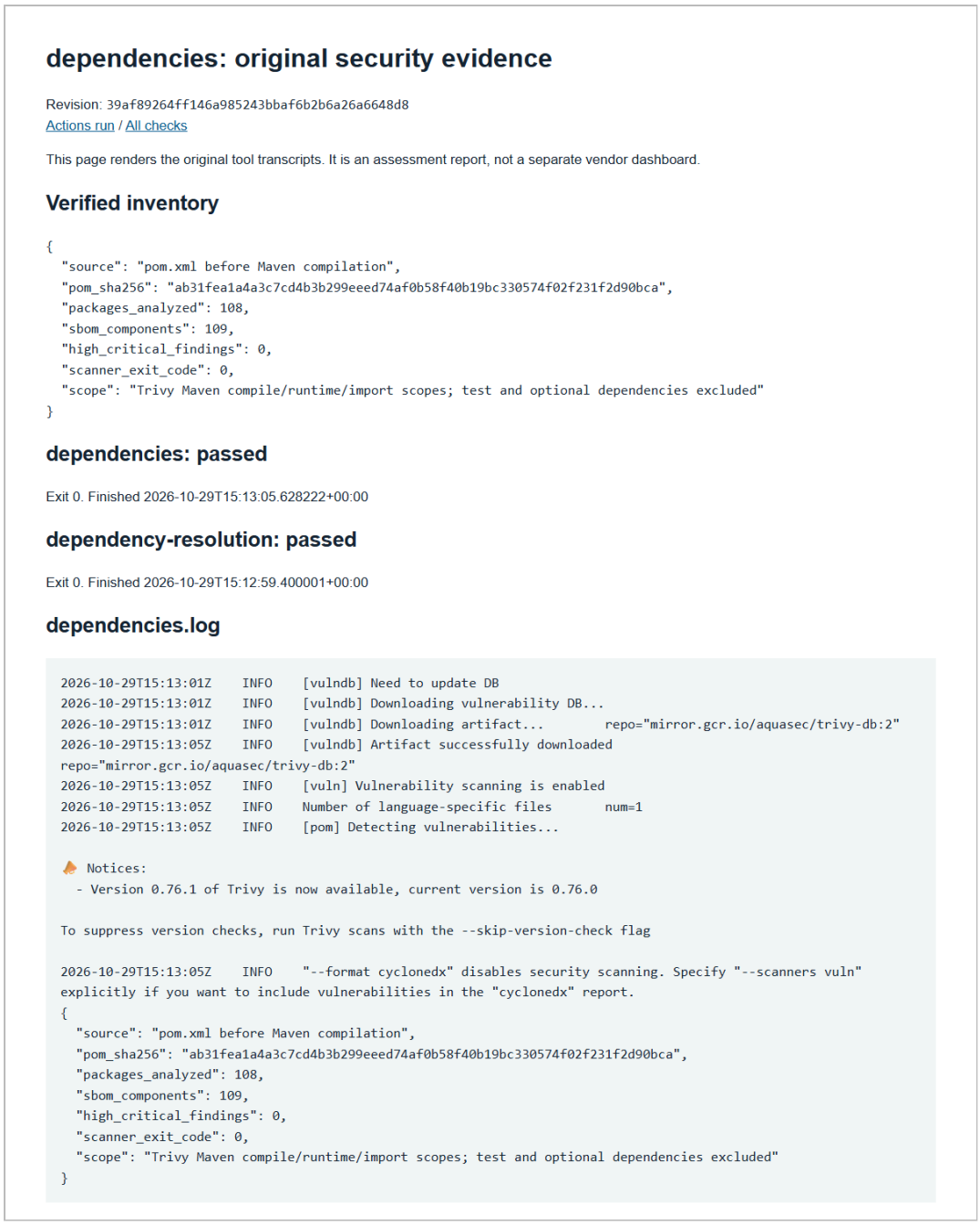


Gitleaks history scan passed (run 40899036172)

5. Dependency analysis and SBOM [Verified in a real run]

Technique: Software composition analysis of the source POM with a CycloneDX inventory
Tool: Trivy
Blocks the pipeline when: HIGH/CRITICAL fails; empty or unversioned inventory is rejected
Report: `dependencies/report.html`

An earlier green run had an empty inventory; the validator now rejects that.



dependencies: original security evidence

Revision: 39af89264ff146a985243bbaf6b2b6a26a6648d8
Actions run / All checks

This page renders the original tool transcripts. It is an assessment report, not a separate vendor dashboard.

Verified inventory


```
{
  "source": "pom.xml before Maven compilation",
  "pom_sha256": "ab31fea1a4a3c7cd4b3b299eeed74af0b58f40b19bc330574f02f231f2d90bca",
  "packages_analyzed": 108,
  "sbom_components": 109,
  "high_critical_findings": 0,
  "scanner_exit_code": 0,
  "scope": "Trivy Maven compile/runtime/import scopes; test and optional dependencies excluded"
}
```


dependencies: passed

Exit 0. Finished 2026-10-29T15:13:05.628222+00:00

dependency-resolution: passed

Exit 0. Finished 2026-10-29T15:12:59.400001+00:00

dependencies.log


```
2026-10-29T15:13:01Z    INFO    [vulndb] Need to update DB
2026-10-29T15:13:01Z    INFO    [vulndb] Downloading vulnerability DB...
2026-10-29T15:13:01Z    INFO    [vulndb] Downloading artifact...        repo="mirror.gcr.io/aquasec/trivy-db:2"
2026-10-29T15:13:05Z    INFO    [vulndb] Artifact successfully downloaded
repo="mirror.gcr.io/aquasec/trivy-db:2"
2026-10-29T15:13:05Z    INFO    [vuln] Vulnerability scanning is enabled
2026-10-29T15:13:05Z    INFO    Number of language-specific files       num=1
2026-10-29T15:13:05Z    INFO    [pom] Detecting vulnerabilities...

📣 Notices:
  - Version 0.76.1 of Trivy is now available, current version is 0.76.0

To suppress version checks, run Trivy scans with the --skip-version-check flag

2026-10-29T15:13:05Z    INFO    "--format cyclonedx" disables security scanning. Specify "--scanners vuln"
explicitly if you want to include vulnerabilities in the "cyclonedx" report.
{
  "source": "pom.xml before Maven compilation",
  "pom_sha256": "ab31fea1a4a3c7cd4b3b299eeed74af0b58f40b19bc330574f02f231f2d90bca",
  "packages_analyzed": 108,
  "sbom_components": 109,
  "high_critical_findings": 0,
  "scanner_exit_code": 0,
  "scope": "Trivy Maven compile/runtime/import scopes; test and optional dependencies excluded"
}
```


Verified inventory and SBOM summary (run 40899036172)

6. Infrastructure-as-code policy [Verified in a real run]

Technique: Terraform fmt/validate, policy scan, custom SSH-to-internet rule, workflow lint, Caddy config validation
Tool: Terraform, Checkov, actionlint
Blocks the pipeline when: Any unexcepted failure; ten exclusions are documented in SECURITY.md
Report: `iac/report.html`

iac: original security evidence

Revision: `39af89264ff146a985243bbaf6b2b6a26a6648d8`
Actions run / All checks

This page renders the original tool transcripts. It is an assessment report, not a separate vendor dashboard.

Policy counts

- checkov-course.json: 43 passed, 0 failed, 0 skipped
- checkov-default.json: 27 passed, 0 failed, 0 skipped

checkov-course: passed

Exit 0. Finished 2026-10-29T15:13:26.230894+00:00

checkov-default: passed

Exit 0. Finished 2026-10-29T15:13:23.519117+00:00

checkov-course.log

```
terraform scan results:

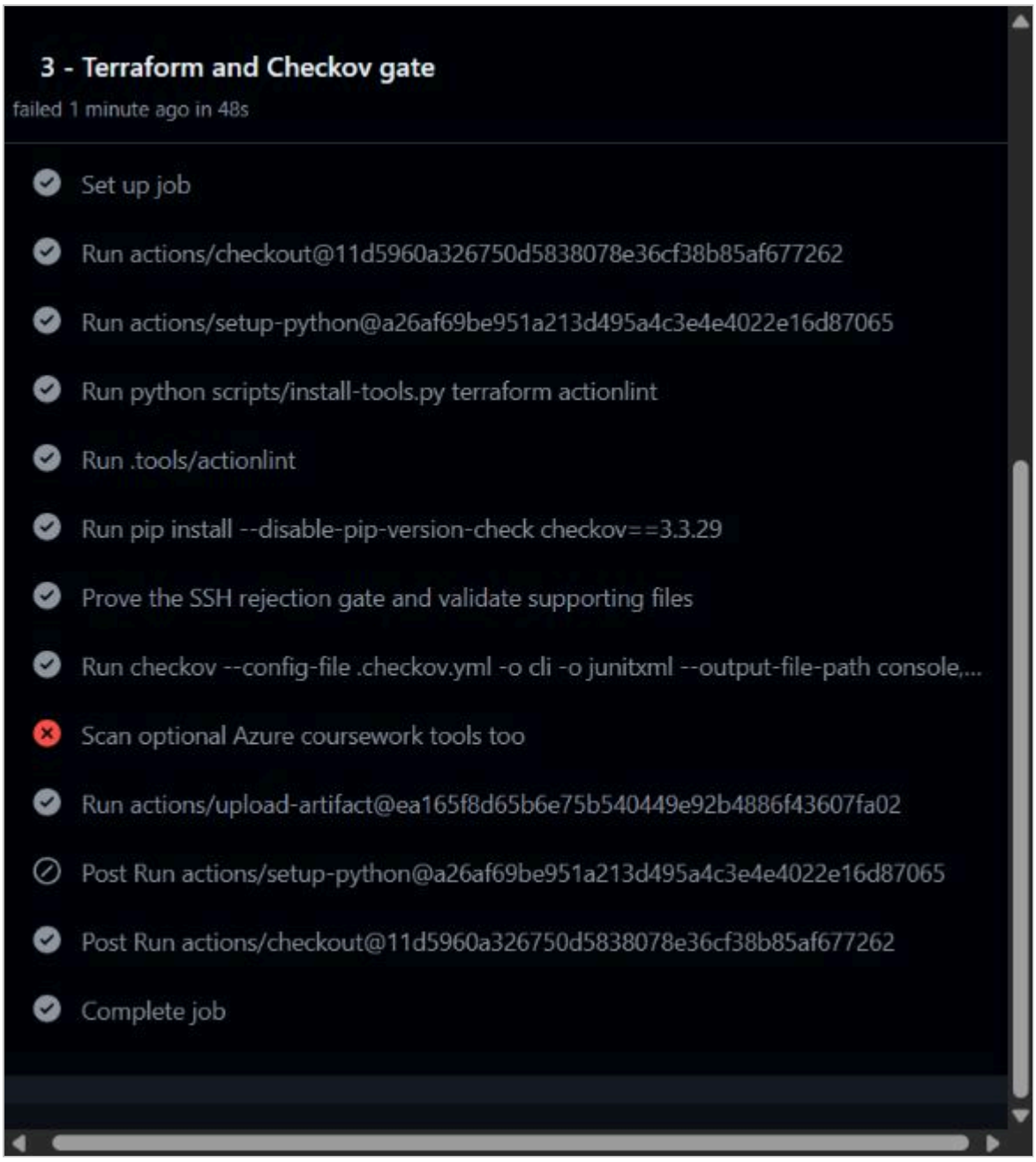
Passed checks: 43, Failed checks: 0, Skipped checks: 0
```

checkov-default.log

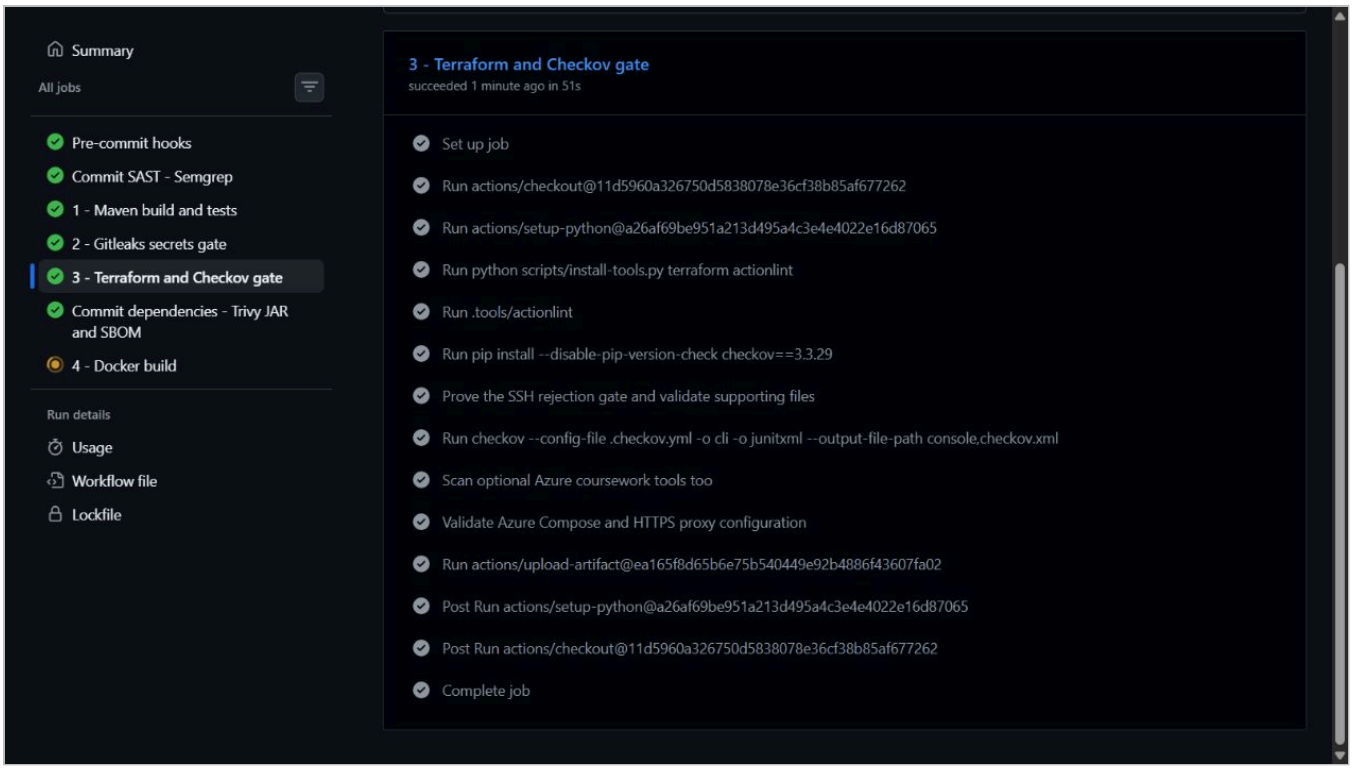
```
terraform scan results:

Passed checks: 27, Failed checks: 0, Skipped checks: 0
```

Checkov policy counts (run 40899036172)



Real finding CKV_AZURE_160 (public HTTP port 80) failing the gate (run 39805052147)



Passing rescan after the port was closed (run 39805591559)

7. Collect pre-build reports [Verified in a real run]

Technique: Aggregate every scanner output into one readable index
Tool: scripts/render-security-reports.py
Blocks the pipeline when: Runs even after a failed gate
Report: `index.html`

DevSecOps security reports

Report execution revision: `521e41e06bbb43163d35d8bc8b711c63993f796b`
Run: https://github.com/oussamakou/DEVOPS-Esprit-4NIDS6/actions/runs/42055245961

Order: checkout, local-hook replay and commit security gates before Maven compilation; Nmap acceptance after deployment. Each original record retains its own execution time and provenance. Threat modeling remains a human review activity.

Pipeline stages at a glance

Stage	Tool	Outcome	What it measured	Report
Pre-commit hooks and threat model	pre-commit, Gitleaks hook	**passed**	hook transcript and threat model	Open
Commit SAST	Semgrep	**passed**	Semgrep: 19 files scanned, 0 application findings, 0 scanner errors	Open
Commit secrets scan	Gitleaks	**passed**	full available Git history	Open
Source dependency scan and SBOM	Trivy, CycloneDX	**passed**	108 packages analyzed	Open
Infrastructure policy	Terraform, Checkov	**passed**	checkov-course.json: 43 passed, 0 failed, 0 skipped; checkov-default.json: 27 passed, 0 failed, 0 skipped	Open
Compile, test and coverage	Maven, Surefire, JaCoCo	**passed**	Surefire: 6 tests in 3 classes, 0 failures, 0 errors, 0 skipped; JaCoCo line coverage: 41.5% (17/41)	Open
Code quality gate	SonarQube	not run in this snapshot	-	-
Artifact repository	Nexus	not run in this snapshot	-	-
Image build and vulnerability gate	Docker, k3d smoke test, Trivy	**passed**	Trivy image scan of /tmp/image.tar: 0 CRITICAL, 0 HIGH findings across 2 scanned targets	Open
Image registry	Azure Container Registry	not run in this snapshot	-	-
Deployment	Docker Compose through Azure Run Command	not run in this snapshot	-	-
Network acceptance	Nmap	not run in this snapshot	-	-
Monitoring verification	API request, image and scrape-target check	not run in this snapshot	-	-
Metrics collection	Prometheus, Node Exporter	not run in this snapshot	-	-
Dashboards	Grafana	not run in this snapshot	-	-

Grafana (`http://127.0.0.1:3000/d/student-devsecops`, `/d/student-vms`) and Prometheus (`http://127.0.0.1:9091/targets`) are private: open them through the owner's SSH tunnel described in documentation/MONITORING-DEMO.md.

Security job outcomes

- security: success
- build: success
- docker: success
- trivy: success

Scanner measurements

- checkov-course.json: 43 passed, 0 failed, 0 skipped
- checkov-default.json: 27 passed, 0 failed, 0 skipped
- Semgrep: 19 files scanned, 0 application findings, 0 scanner errors
- Source dependency packages analyzed: 108

Combined index generated by CI (run 42055245961, pull request 25)

B. Acceptance

8. Compile, test and coverage [Verified in a real run]

Technique: Unit and HTTP integration tests with coverage measurement
Tool: Maven, JUnit (Surefire), JaCoCo
Blocks the pipeline when: Any failed test blocks the image build
Report: `build/report.html`

6 tests, 41.5% line coverage in the CI run shown.



Compile, test and coverage: original evidence

Tool: Maven, Surefire, JaCoCo
Revision: 521e41e06bbb43163d35d8bc8b711c63993f796b
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- Surefire: 6 tests in 3 classes, 0 failures, 0 errors, 0 skipped
- JaCoCo line coverage: 41.5% (17/41)

maven: passed

Exit 0. Started 2026-11-05T15:29:57.804310+00:00; finished 2026-11-05T15:30:26.168951+00:00

maven.log

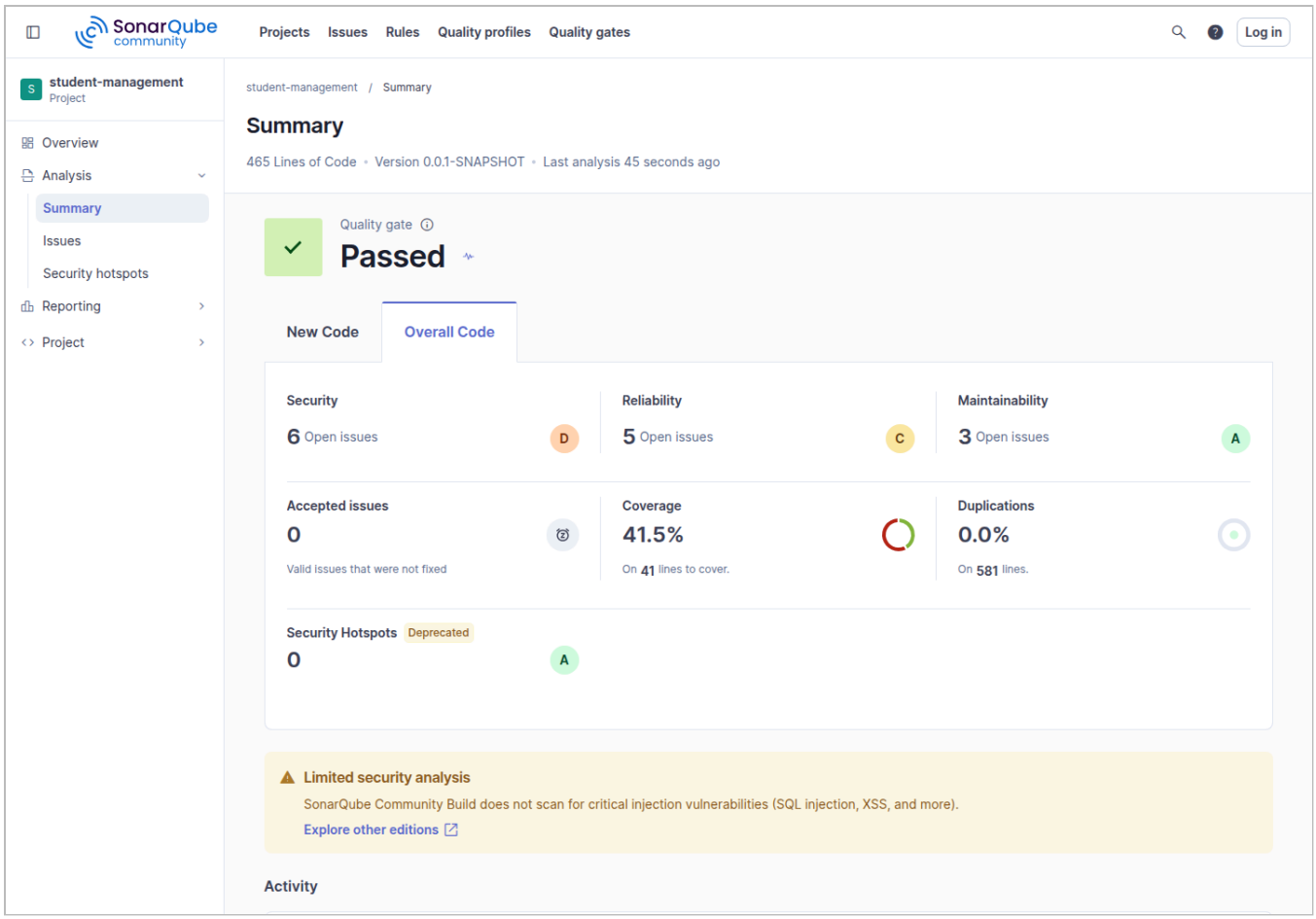
```
[INFO] Scanning for projects...
[INFO]
[INFO] --------------------< tn.esprit:student-management >--------------------
[INFO] Building student-management 0.0.1-SNAPSHOT
[INFO]   from pom.xml
[INFO] --------------------------------[ jar ]---------------------------------
[INFO]
[INFO] --- jacoco:0.8.11:prepare-agent (prepare-agent) @ student-management ---
[INFO] argLine set to -javaagent:/home/runner/.m2/repository/org/jacoco/org.jacoco.agent/0.8.11/org.jacoco.agent-
0.8.11-runtime.jar=destfile=/home/runner/work/DEVOPS-Esprit-4NIDS6/DEVOPS-Esprit-4NIDS6/target/jacoco.exec
[INFO]
[INFO] --- resources:3.5.0:resources (default-resources) @ student-management ---
[INFO] Copying 1 resource from src/main/resources to target/classes
[INFO] Copying 0 resource from src/main/resources to target/classes
[INFO]
[INFO] --- compiler:3.15.0:compile (default-compile) @ student-management ---
[INFO] Recompiling the module because of changed source code.
[INFO] Compiling 19 source files with javac [debug parameters release 17] to target/classes
[INFO]
[INFO] --- resources:3.5.0:testResources (default-testResources) @ student-management ---
[INFO] Copying 1 resource from src/test/resources to target/test-classes
[INFO]
[INFO] --- compiler:3.15.0:testCompile (default-testCompile) @ student-management ---
[INFO] Recompiling the module because of changed dependency.
[INFO] Compiling 3 source files with javac [debug parameters release 17] to target/test-classes
[INFO]
[INFO] --- surefire:3.5.6:test (default-test) @ student-management ---
[INFO] Using auto detected provider org.apache.maven.surefire.junitplatform.JUnitPlatformProvider
[INFO]
[INFO] -------------------------------------------------------
[INFO]  T E S T S
[INFO] -------------------------------------------------------
[INFO] Running tn.esprit.studentmanagement.StudentManagementApplicationTests
15:30:10.743 [main] INFO org.springframework.test.context.support.AnnotationConfigContextLoaderUtils -- Could not
detect default configuration classes for test class
[tn.esprit.studentmanagement.StudentManagementApplicationTests]: StudentManagementApplicationTests does not
declare any static, non-private, non-final, nested classes annotated with @Configuration.
15:30:10.960 [main] INFO org.springframework.boot.test.context.SpringBootTestContextBootstrapper -- Found
@SpringBootConfiguration tn.esprit.studentmanagement.StudentManagementApplication for test class
tn.esprit.studentmanagement.StudentManagementApplicationTests
15:30:11.227 [main] INFO org.springframework.test.context.support.AnnotationConfigContextLoaderUtils -- Could not
detect default configuration classes for test class
[tn.esprit.studentmanagement.StudentManagementApplicationTests]: StudentManagementApplicationTests does not
declare any static, non-private, non-final, nested classes annotated with @Configuration.
```

Maven stage page: log, test counts and coverage (run 42055245961)

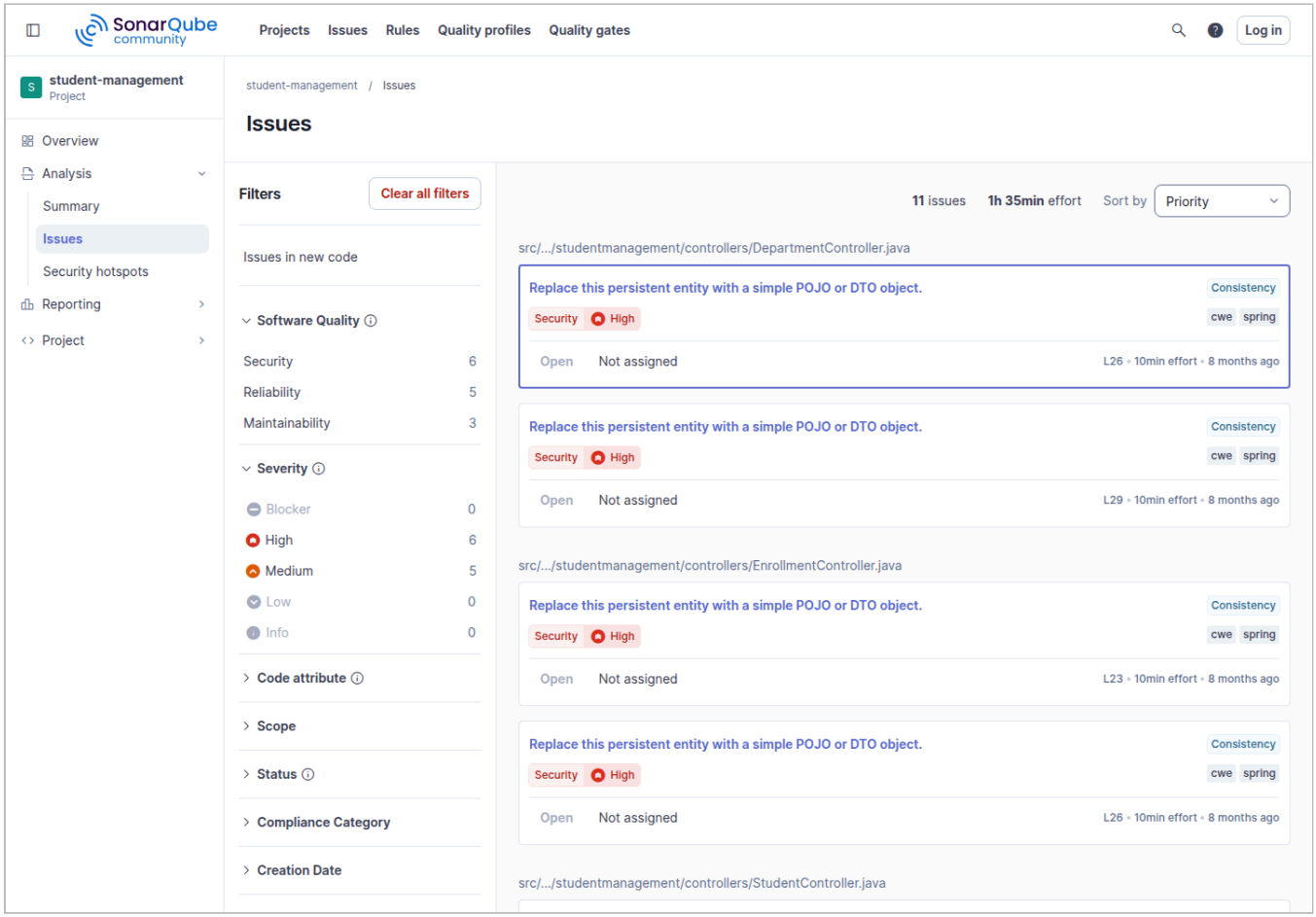
9. Code quality gate [Verified in a real run]

Technique: Static analysis with a blocking quality gate
Tool: SonarQube Community Build
Blocks the pipeline when: The pipeline waits for the gate and fails if it fails
Report: `quality/report.html`

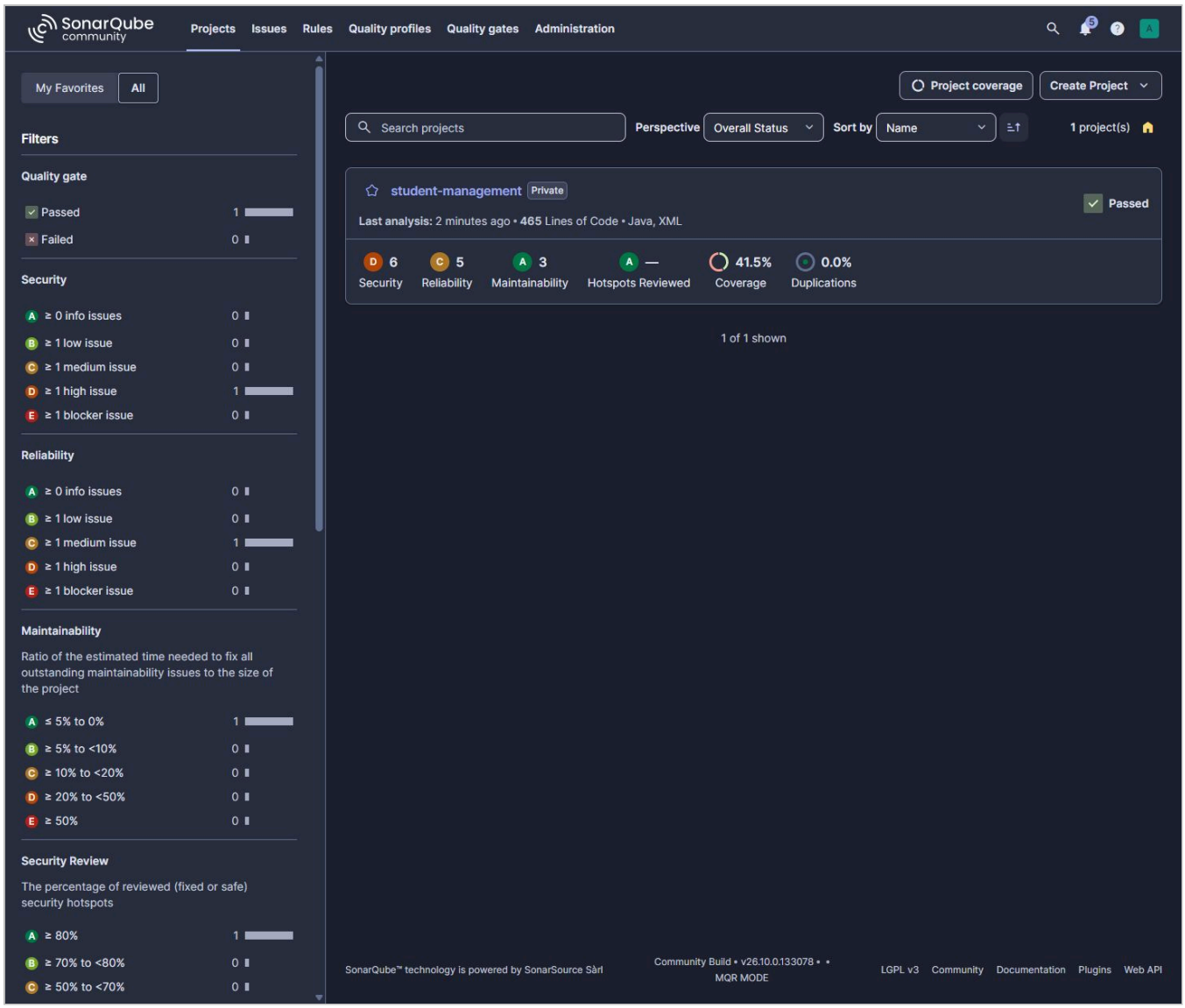
The blocking gate passed on the GitHub-hosted runner. The earlier Azure baseline recorded 11 issues, including six HIGH entity-binding findings.



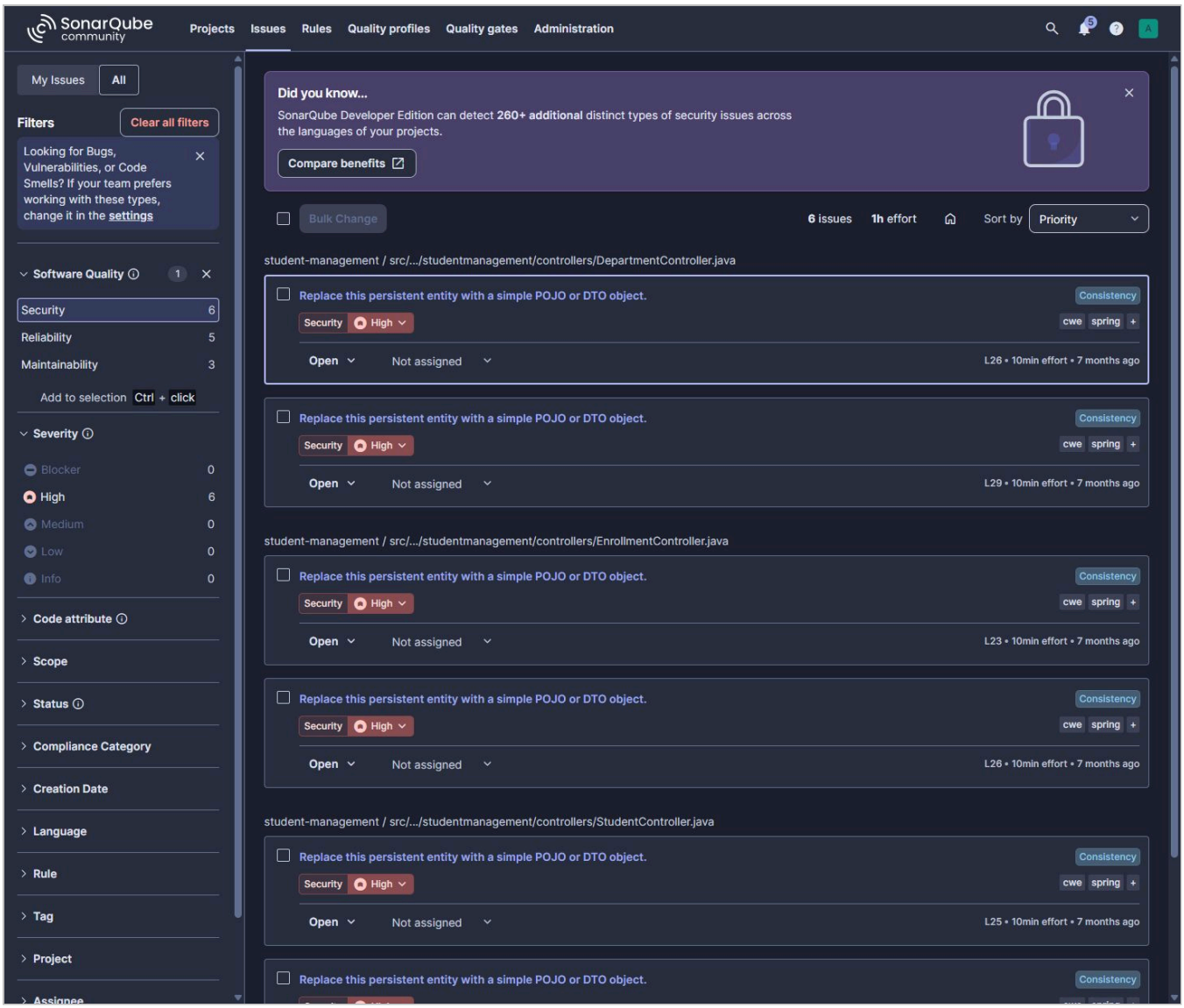
SonarQube project dashboard on the hosted runner (run 43076300738)



SonarQube issue list for the same analysis (run 43076300738)



First baseline: 41.5% coverage and 11 issues (run 39883066388)

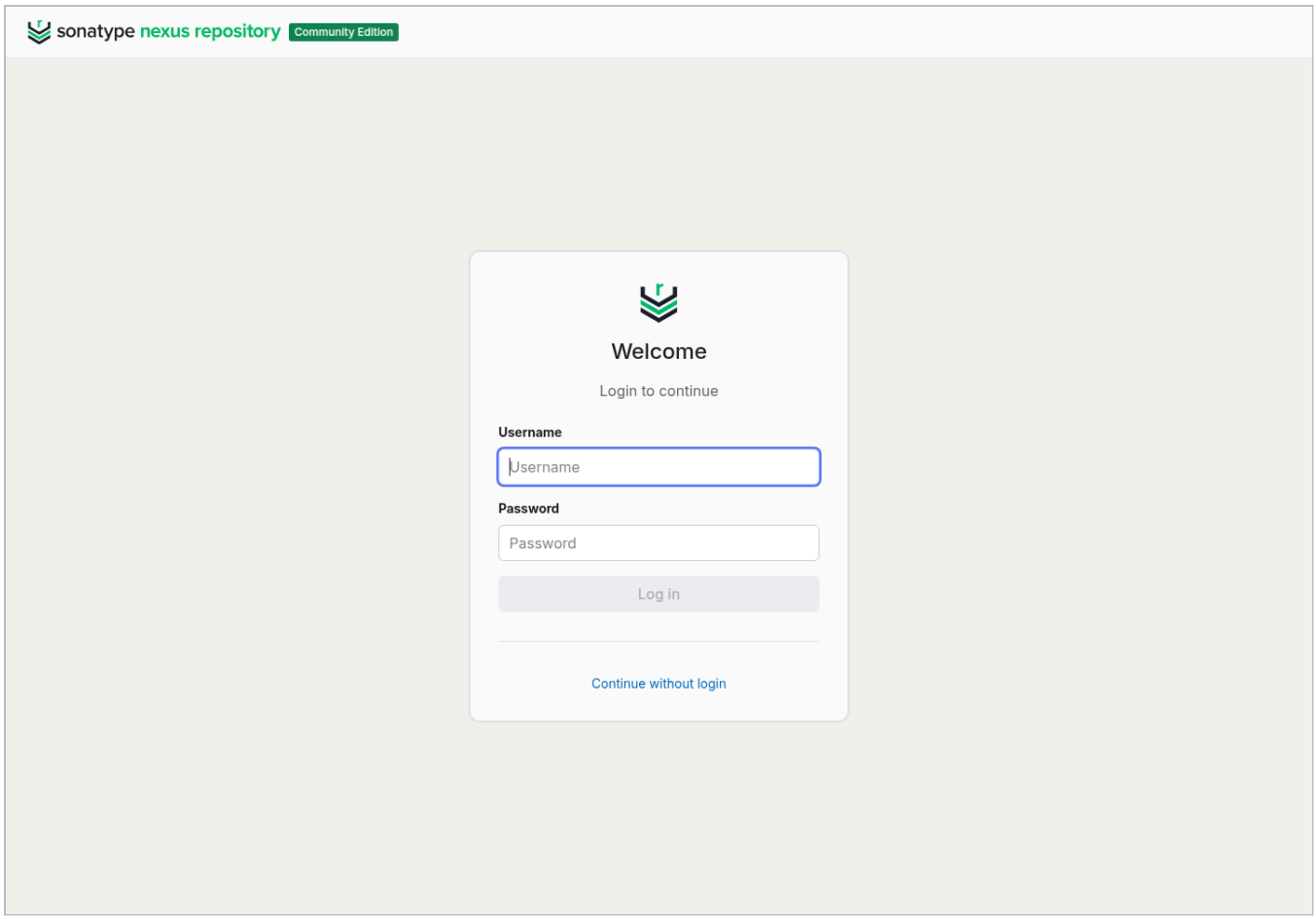


Six HIGH java:S4684 findings in the controllers from the earlier Azure baseline

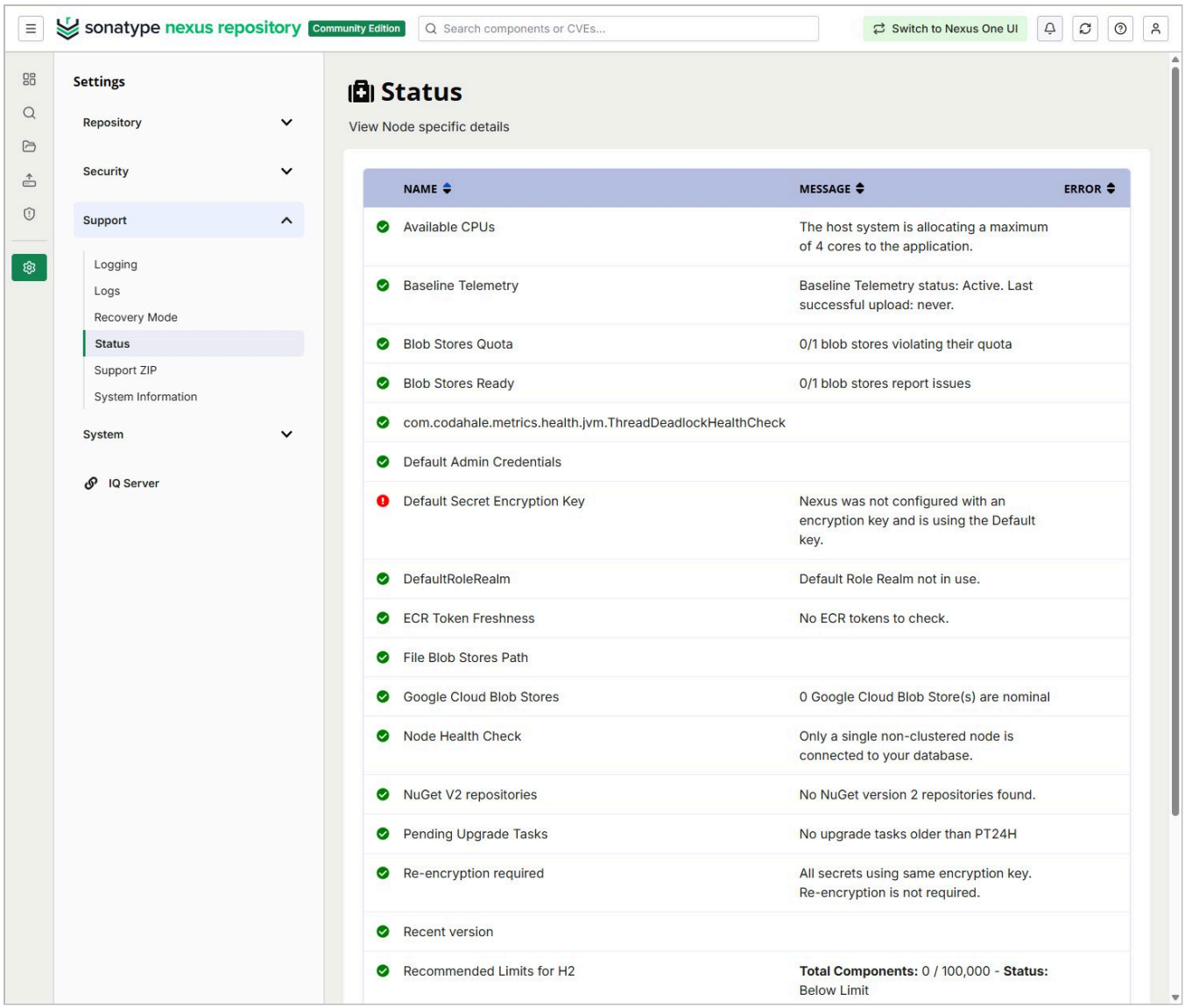
10. Artifact repository [Verified in a real run]

Technique: Publish the tested JAR, then compare the stored checksum with the tested JAR
Tool: Sonatype Nexus
Blocks the pipeline when: A different stored checksum fails the stage
Report: `artifact/report.html`

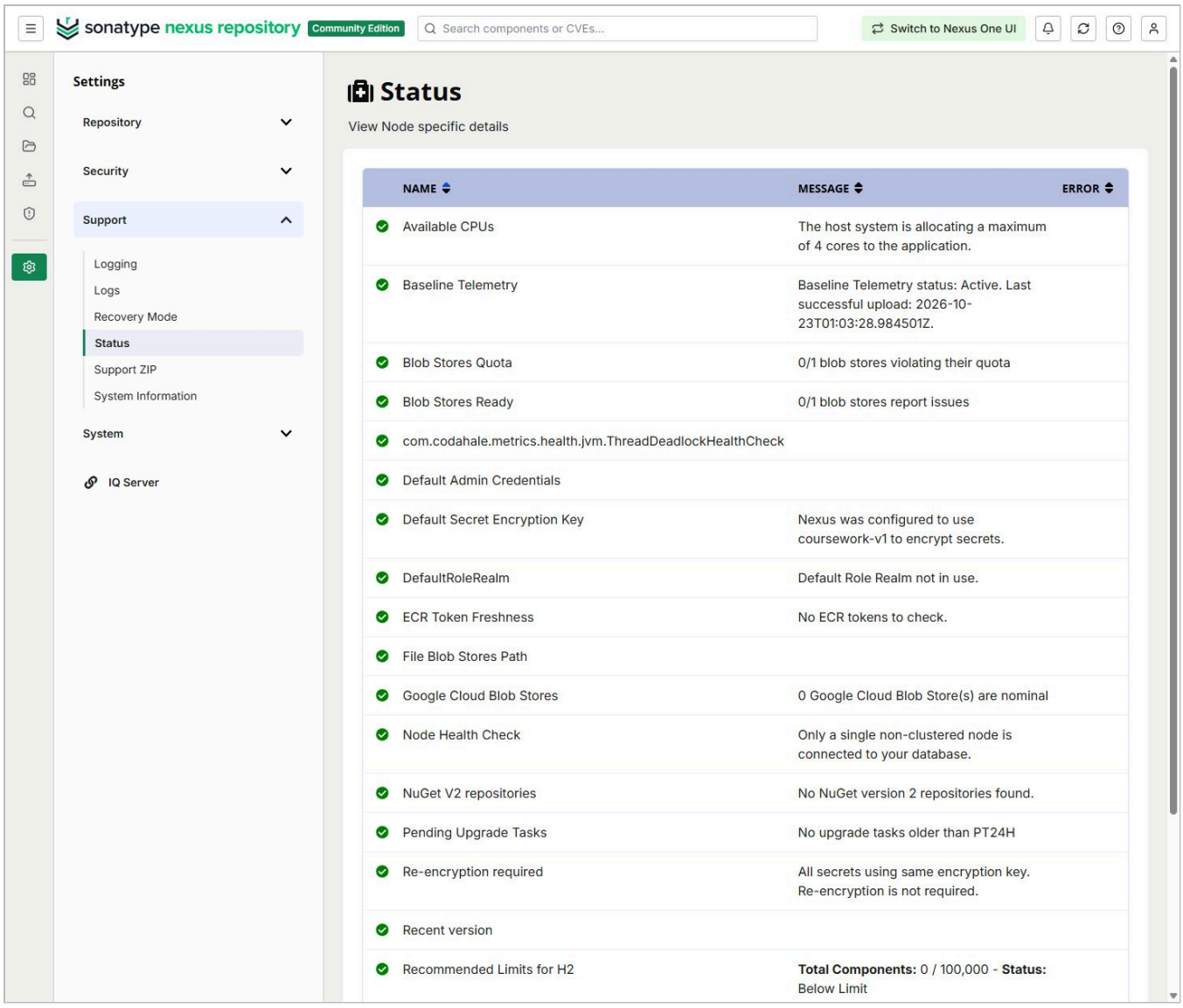
The hosted run's artifact report records matching SHA-1 checksums for the published snapshot and the tested JAR. The screenshot captured Nexus's sign-in screen when the runner opened the snapshot browser.



Nexus sign-in screen captured while opening the snapshot browser (run 43076300738)



Earlier real finding: Nexus used the default encryption key



After remediation with a private key

11. Image build and vulnerability gate [Verified in a real run]

Technique: Build a non-root image from the tested JAR and scan the final image. The parallel commit workflow also smoke-tests the image on ephemeral k3s.
Tool: Docker, Trivy, k3d
Blocks the pipeline when: Any HIGH/CRITICAL finding fails, including unfixed ones
Report: `image/report.html`

An earlier run was blocked by 11 HIGH/CRITICAL findings; see SECURITY-GATE-CASE-STUDY.md.

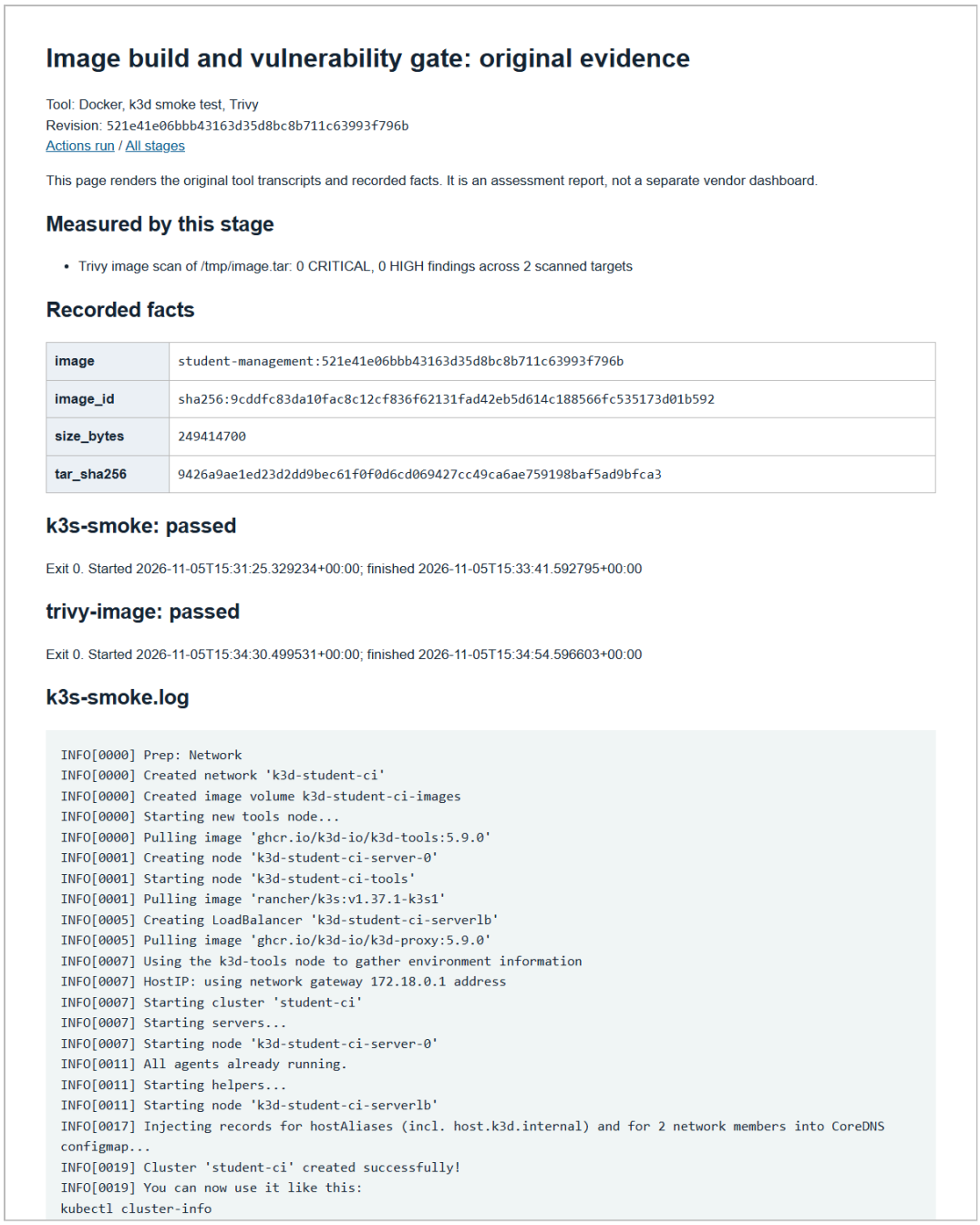


Image build and vulnerability gate: original evidence

Tool: Docker, k3d smoke test, Trivy
Revision: `521e41e06bbb43163d35d8bc8b711c63993f796b`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- Trivy image scan of /tmp/image.tar: 0 CRITICAL, 0 HIGH findings across 2 scanned targets

Recorded facts

image	`student-management:521e41e06bbb43163d35d8bc8b711c63993f796b`
image_id	`sha256:9cddfc83da10fac8c12cf836f62131fad42eb5d614c188566fc535173d01b592`
size_bytes	`249414700`
tar_sha256	`9426a9ae1ed23d2dd9bec61f0f0d6cd069427cc49ca6ae759198baf5ad9bfca3`

k3s-smoke: passed

Exit 0. Started 2026-11-05T15:31:25.329234+00:00; finished 2026-11-05T15:33:41.592795+00:00

trivy-image: passed

Exit 0. Started 2026-11-05T15:34:30.499531+00:00; finished 2026-11-05T15:34:54.596603+00:00

k3s-smoke.log

```
INFO[0000] Prep: Network
INFO[0000] Created network 'k3d-student-ci'
INFO[0000] Created image volume k3d-student-ci-images
INFO[0000] Starting new tools node...
INFO[0000] Pulling image 'ghcr.io/k3d-io/k3d-tools:5.9.0'
INFO[0001] Creating node 'k3d-student-ci-server-0'
INFO[0001] Starting node 'k3d-student-ci-tools'
INFO[0001] Pulling image 'rancher/k3s:v1.37.1-k3s1'
INFO[0005] Creating LoadBalancer 'k3d-student-ci-serverlb'
INFO[0005] Pulling image 'ghcr.io/k3d-io/k3d-proxy:5.9.0'
INFO[0007] Using the k3d-tools node to gather environment information
INFO[0007] HostIP: using network gateway 172.18.0.1 address
INFO[0007] Starting cluster 'student-ci'
INFO[0007] Starting servers...
INFO[0007] Starting node 'k3d-student-ci-server-0'
INFO[0011] All agents already running.
INFO[0011] Starting helpers...
INFO[0011] Starting node 'k3d-student-ci-serverlb'
INFO[0017] Injecting records for hostAliases (incl. host.k3d.internal) and for 2 network members into CoreDNS
configmap...
INFO[0019] Cluster 'student-ci' created successfully!
INFO[0019] You can now use it like this:
kubectl cluster-info
```

Image stage page: build facts, k3s smoke test and Trivy result, 0 HIGH/CRITICAL (run 42055245961)

12. Image registry [Verified in a real run]

Technique: Push the scanned image and deploy by immutable digest
Tool: Docker Distribution registry (runner loopback)
Blocks the pipeline when: The digest must belong to the pushed image
Report: `registry/report.html`

The hosted run publishes to localhost:5000. Its report records the push log and digest. The screenshot records the earlier Azure registry push.

Image registry: original evidence

Tool: Azure Container Registry
Revision: `db36f8379df2e0c6c38f8a2b7561df5e2b69418e`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- image: studentcourse323d3b9d04d2.azurecr.io/student-management@sha256:a70de5456189a6ce0cef73b9ea9b28988c079bdb8a184ae8bfab4314e71e5d1c

Recorded facts

registry	`studentcourse323d3b9d04d2.azurecr.io`
tag	`db36f8379df2e0c6c38f8a2b7561df5e2b69418e`
image	`studentcourse323d3b9d04d2.azurecr.io/student-management@sha256:a70de5456189a6ce0cef73b9ea9b28988c079bdb8a184ae8bfab4314e71e5d1c`

acr-push: passed

Exit 0. Started 2026-11-05T21:03:51.174725+00:00; finished 2026-11-05T21:04:02.006296+00:00

acr-push.log

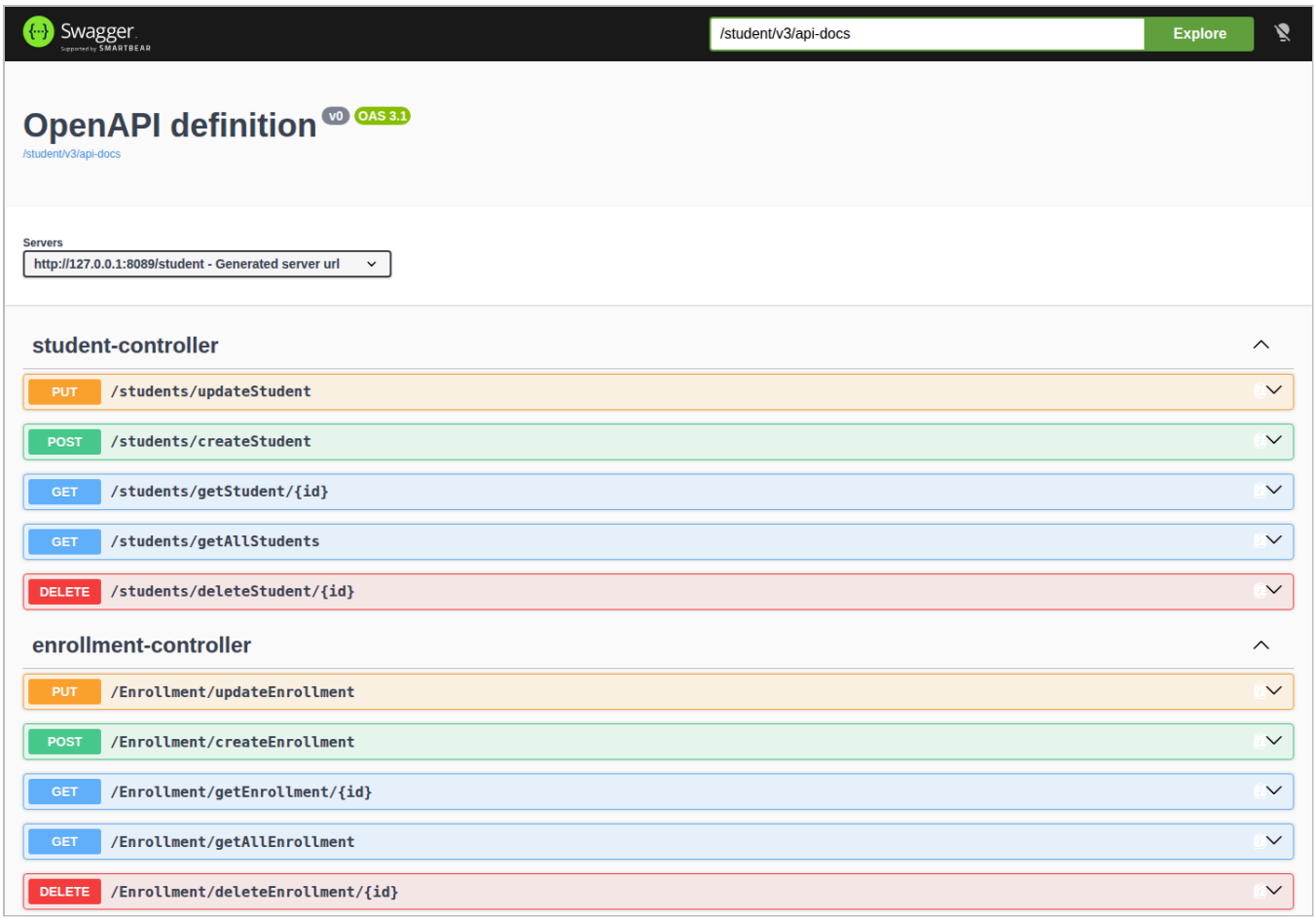
```
The push refers to repository [studentcourse323d3b9d04d2.azurecr.io/student-management]
bab38130ad99: Preparing
6c444736d45f: Preparing
11a649abf36e: Preparing
f0f3c4e2e1e0: Preparing
fcba58aaefa4: Preparing
b7a888f89d2b: Preparing
1c181ab443b7: Preparing
75c137aedfb2: Preparing
b7a888f89d2b: Waiting
1c181ab443b7: Waiting
75c137aedfb2: Waiting
6c444736d45f: Pushed
f0f3c4e2e1e0: Pushed
fcba58aaefa4: Pushed
11a649abf36e: Pushed
75c137aedfb2: Layer already exists
1c181ab443b7: Pushed
bab38130ad99: Pushed
```

Historical Azure registry push and immutable digest (run 42108525318)

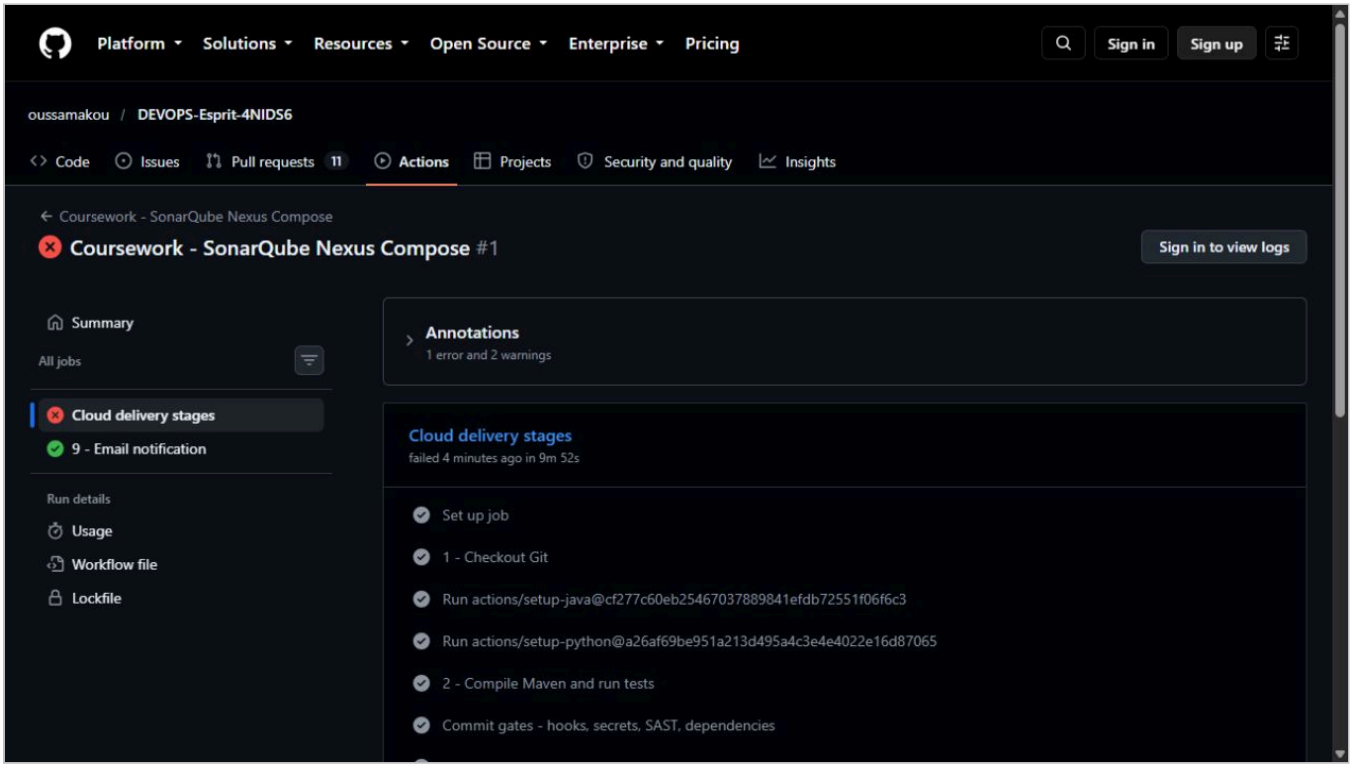
13. Acceptance lab [Verified in a real run]

Technique: Start the lab's Compose stack on the runner and verify readiness before testing TCP exposure
Tool: Docker Compose, Spring Boot, MySQL
Blocks the pipeline when: The running image must match the scanned digest and a database-backed API request must pass
Report: `deploy/report.html`

The Compose stack runs for the duration of the job. The first hosted run recorded DEPLOY_SUCCEEDED and verified a database-backed API response.



Swagger UI for the API deployed on the runner (run 43076300738)

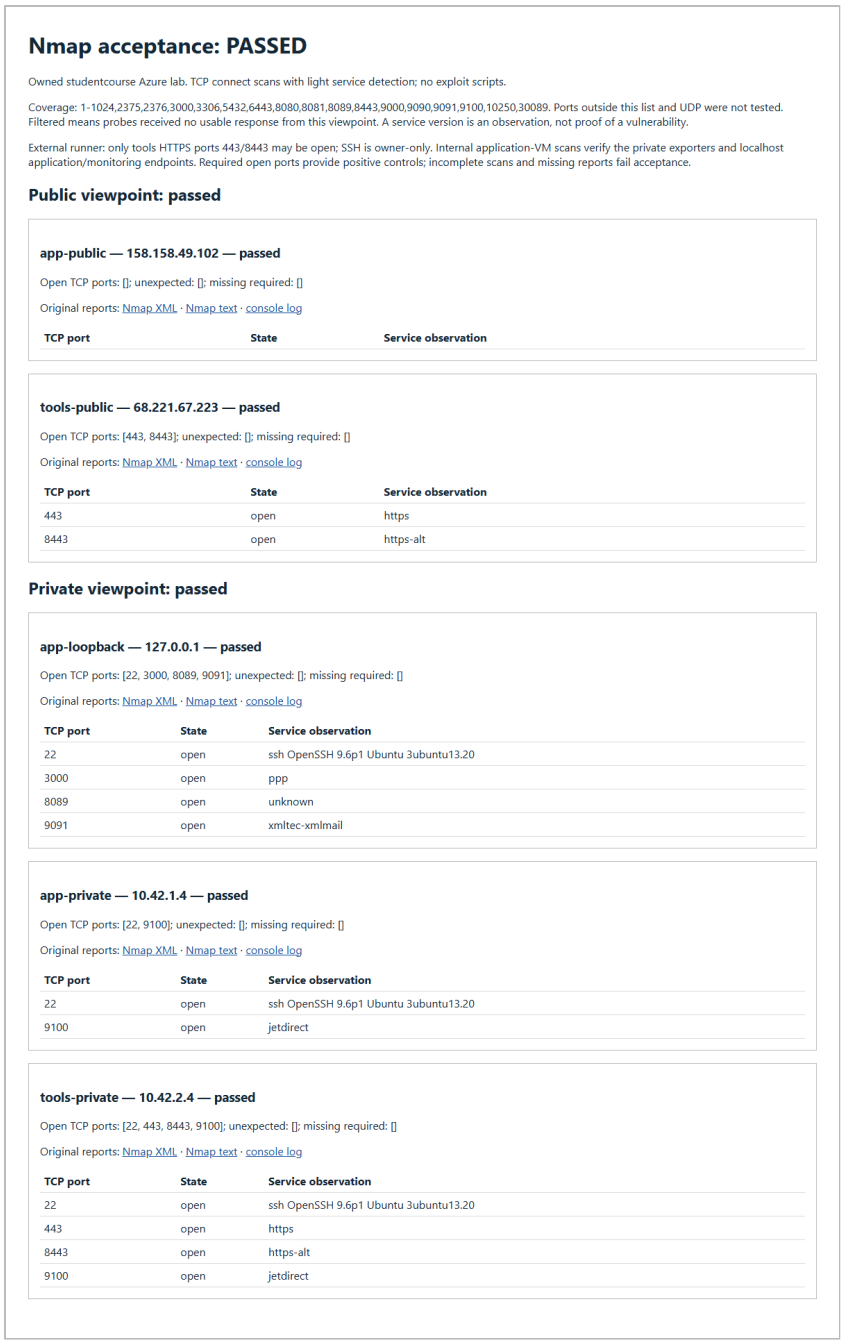


Historical Azure Compose startup failure, repaired before the later Azure run (run 39883066388)

14. Network acceptance [Verified in a real run]

Technique: Scan the runner's primary IPv4 address and loopback against a TCP allowlist
Tool: Nmap
Blocks the pipeline when: Unexpected open, missing required or incomplete scans fail
Report: `acceptance/report.html`

The hosted run checks 1,041 TCP ports per target. The primary interface allows only the runner's OpenSSH listener. Loopback requires Grafana, the registry, the API and Prometheus, and also allows OpenSSH.



Nmap acceptance: PASSED

Owned studentcourse Azure lab. TCP connect scans with light service detection; no exploit scripts.

Coverage: 1-1024,2375,2376,3000,3306,5432,6443,8080,8081,8089,8443,9000,9090,9091,9100,10250,30089. Ports outside this list and UDP were not tested. Filtered means probes received no usable response from this viewpoint. A service version is an observation, not proof of a vulnerability.

External runner: only tools HTTPS ports 443/8443 may be open; SSH is owner-only. Internal application-VM scans verify the private exporters and localhost application/monitoring endpoints. Required open ports provide positive controls; incomplete scans and missing reports fail acceptance.

Public viewpoint: passed

app-public — 158.158.49.102 — passed

Open TCP ports: []; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

TCP port	State	Service observation

tools-public — 68.221.67.223 — passed

Open TCP ports: [443, 8443]; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

TCP port	State	Service observation
443	open	https
8443	open	https-alt

Private viewpoint: passed

app-loopback — 127.0.0.1 — passed

Open TCP ports: [22, 3000, 8089, 9091]; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

TCP port	State	Service observation
22	open	ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.20
3000	open	ppp
8089	open	unknown
9091	open	xmltec-xmlmail

app-private — 10.42.1.4 — passed

Open TCP ports: [22, 9100]; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

TCP port	State	Service observation
22	open	ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.20
9100	open	jetdirect

tools-private — 10.42.2.4 — passed

Open TCP ports: [22, 443, 8443, 9100]; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

TCP port	State	Service observation
22	open	ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.20
443	open	https
8443	open	https-alt
9100	open	jetdirect

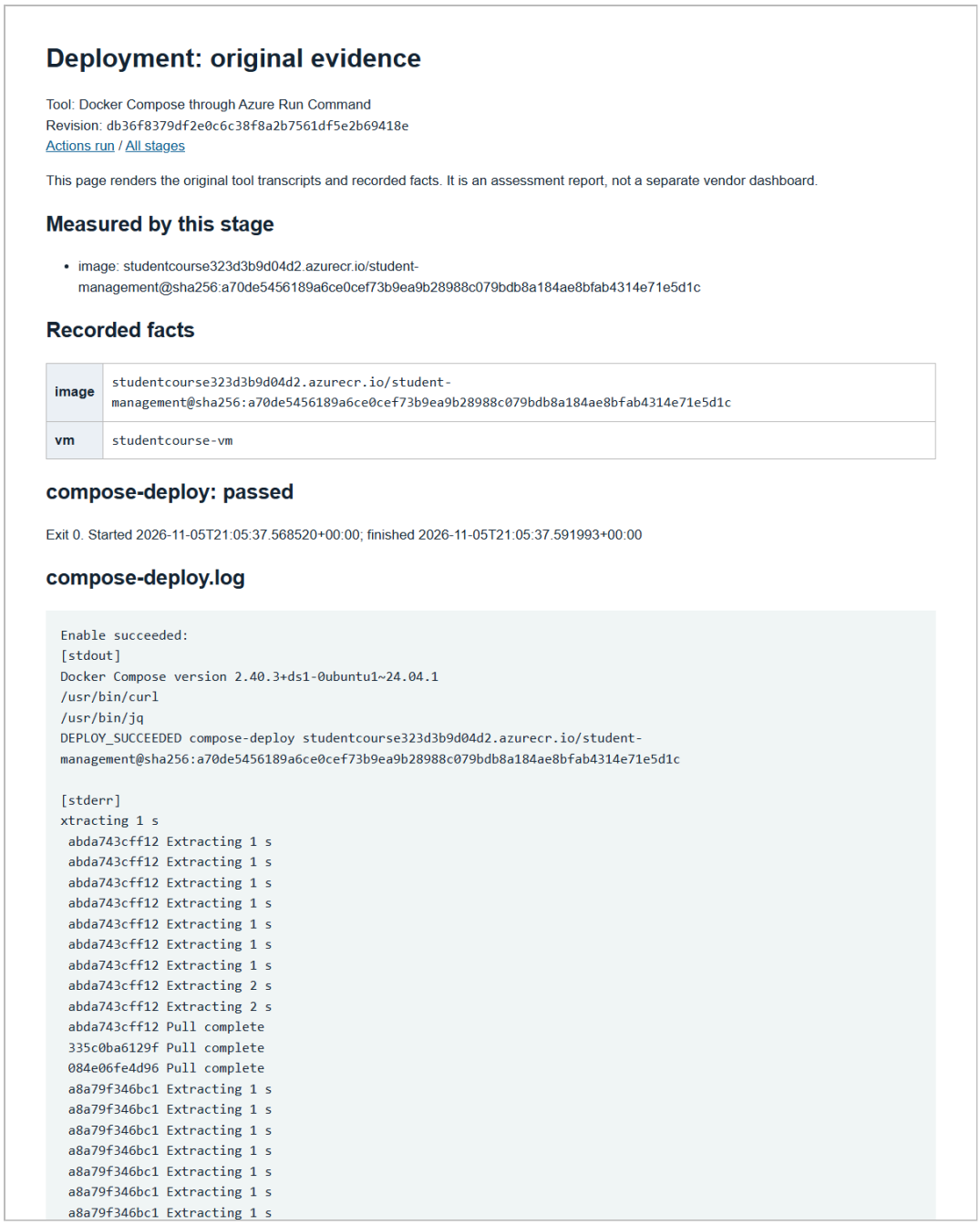
Historical Azure acceptance from public and private viewpoints (run 42016218929)

C. Production

15. Production smoke test [Verified in a real run]

Technique: After Nmap passes, verify the running image digest and a database-backed API response
Tool: Docker image inspection, Spring Boot API, MySQL
Blocks the pipeline when: The running image must match the scanned digest and the API must return a JSON array
Report: `production/report.html`

The lab demonstrates a production smoke test on the same Compose stack. The first hosted run recorded the digest and API checks in deploy/report.html. The course-aligned workflow also records a dedicated smoke result after Nmap.



Deployment: original evidence

Tool: Docker Compose through Azure Run Command
Revision: `db36f8379df2e0c6c38f8a2b7561df5e2b69418e`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- image: studentcourse323d3b9d04d2.azurecr.io/student-management@sha256:a70de5456189a6ce0cef73b9ea9b28988c079bdb8a184ae8bfab4314e71e5d1c

Recorded facts

image	`studentcourse323d3b9d04d2.azurecr.io/student-management@sha256:a70de5456189a6ce0cef73b9ea9b28988c079bdb8a184ae8bfab4314e71e5d1c`
vm	`studentcourse-vm`

compose-deploy: passed

Exit 0. Started 2026-11-05T21:05:37.568520+00:00; finished 2026-11-05T21:05:37.591993+00:00

compose-deploy.log

```
Enable succeeded:
[stdout]
Docker Compose version 2.40.3+ds1-0ubuntu1~24.04.1
/usr/bin/curl
/usr/bin/jq
DEPLOY_SUCCEEDED compose-deploy studentcourse323d3b9d04d2.azurecr.io/student-
management@sha256:a70de5456189a6ce0cef73b9ea9b28988c079bdb8a184ae8bfab4314e71e5d1c

[stderr]
xtracting 1 s
 abda743cff12 Extracting 1 s
 abda743cff12 Extracting 1 s
 abda743cff12 Extracting 1 s
 abda743cff12 Extracting 1 s
 abda743cff12 Extracting 1 s
 abda743cff12 Extracting 1 s
 abda743cff12 Extracting 1 s
 abda743cff12 Extracting 2 s
 abda743cff12 Extracting 2 s
 abda743cff12 Pull complete
 335c0ba6129f Pull complete
 084e06fe4d96 Pull complete
 a8a79f346bc1 Extracting 1 s
 a8a79f346bc1 Extracting 1 s
 a8a79f346bc1 Extracting 1 s
 a8a79f346bc1 Extracting 1 s
 a8a79f346bc1 Extracting 1 s
 a8a79f346bc1 Extracting 1 s
 a8a79f346bc1 Extracting 1 s
```

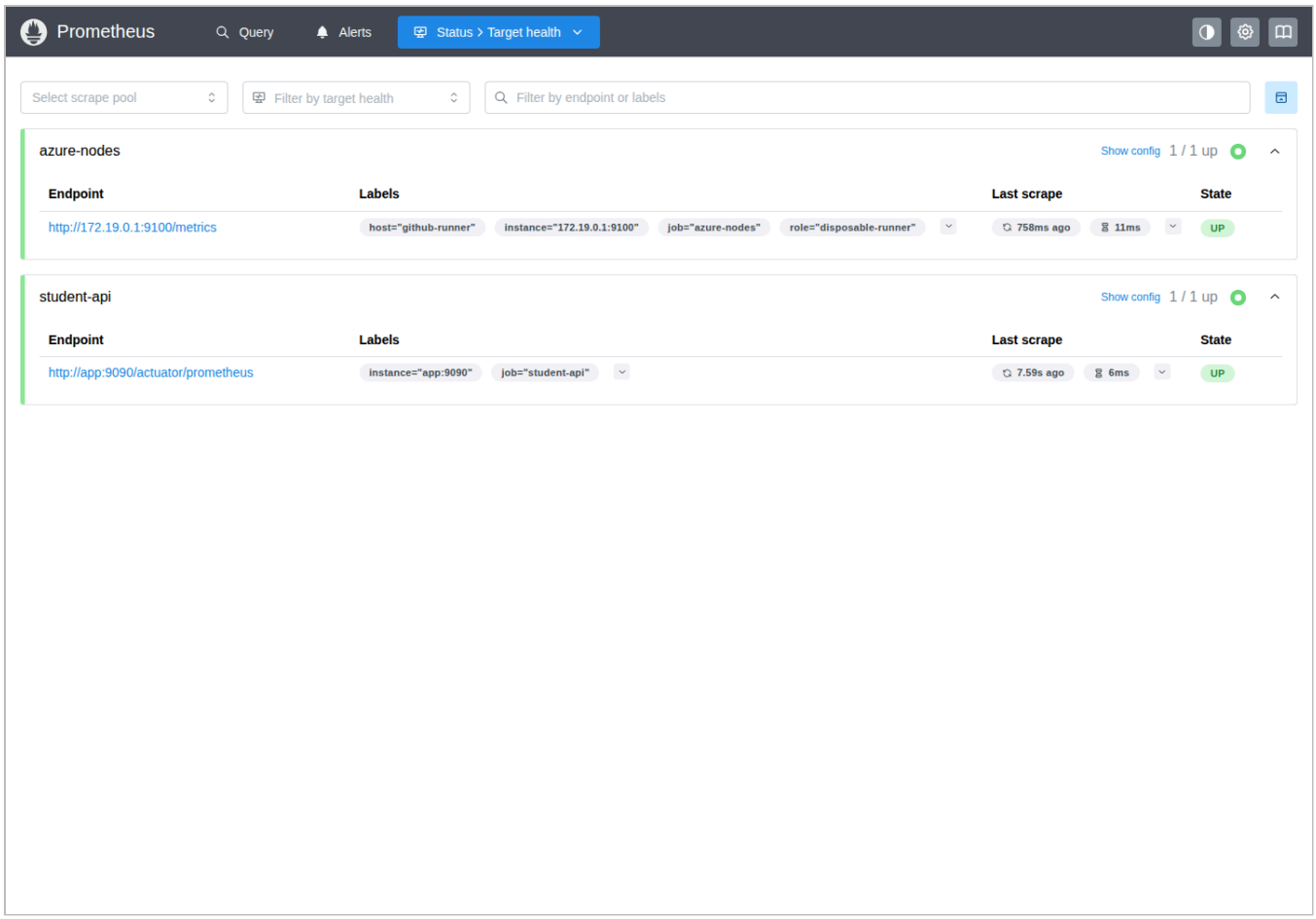
Historical Azure Compose verification of the scanned image (run 42108525318)

D. Operations

16. Monitoring: Prometheus and Grafana [Verified in a real run]

Technique: Verify scrape targets, sample real queries after light API traffic, list provisioned dashboards
Tool: Prometheus, Node Exporter, Grafana
Blocks the pipeline when: API and runner exporter UP, Grafana database healthy, both dashboards provisioned
Report: `monitoring/, prometheus/, grafana/ report.html`

The hosted run recorded both scrape targets UP and 30 successful read-only requests. The combined report includes the native metrics and the UI screenshots below.



Prometheus targets for the application and runner exporter (run 43076300738)



Grafana dashboard for the student API (run 43076300738)



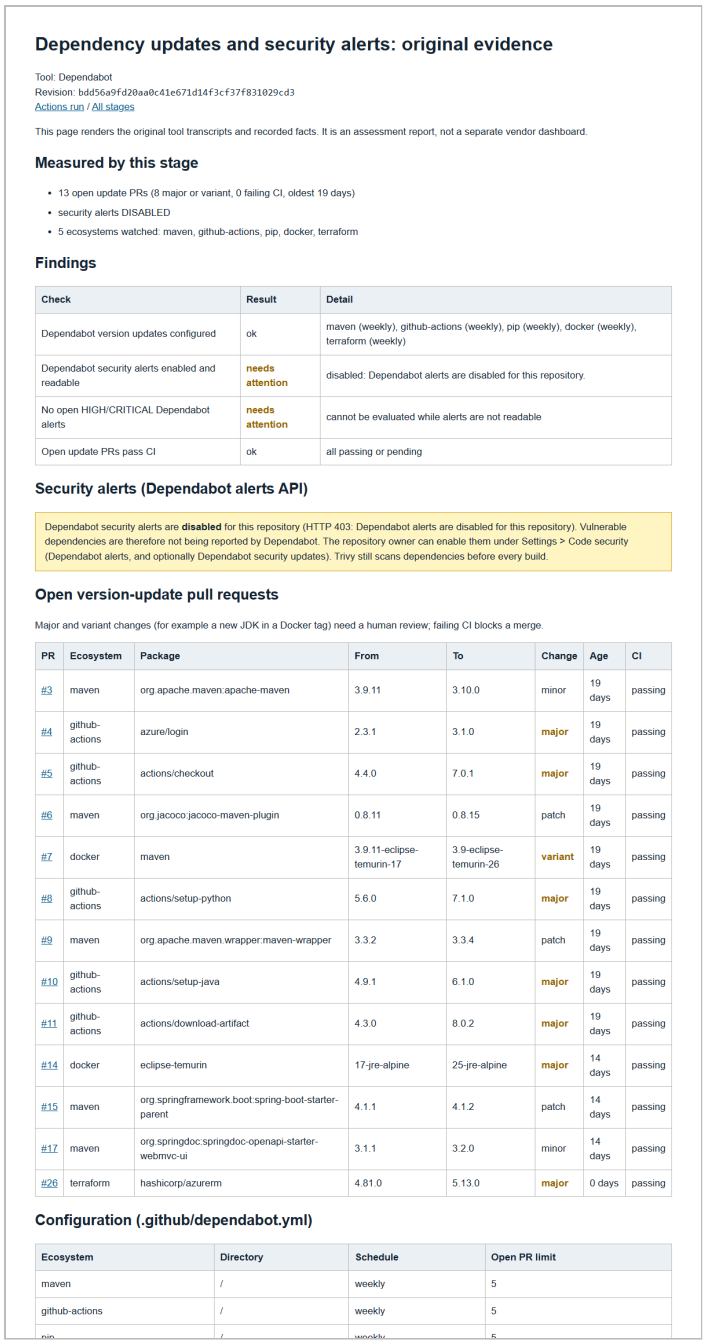
Grafana host dashboard showing the GitHub runner exporter (run 43076300738)

Supporting controls

17. Dependency maintenance [Verified in a real run]

Technique: Report weekly version-update PRs for five ecosystems and the status of GitHub's vulnerability alerts
Tool: Dependabot, GitHub REST API
Blocks the pipeline when: Reported, not blocking: disabled alerts, HIGH/CRITICAL alerts and failing update PRs are highlighted for attention
Report: `dependabot/report.html`

The first CI run found 13 open update PRs (8 major or variant changes, all passing CI, oldest 19 days) and Dependabot security alerts DISABLED on the repository (GitHub answered HTTP 403, alerts disabled). Status is attention, not passed: enabling alerts is a repository setting for the owner.



Dependency updates and security alerts: original evidence

Tool: Dependabot
Revision: bdd56a9fd20aa0c41e671d14f3cf37f831029cd3
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- 13 open update PRs (8 major or variant, 0 failing CI, oldest 19 days)
- security alerts DISABLED
- 5 ecosystems watched: maven, github-actions, pip, docker, terraform

Findings

Check	Result	Detail
Dependabot version updates configured	ok	maven (weekly), github-actions (weekly), pip (weekly), docker (weekly), terraform (weekly)
Dependabot security alerts enabled and readable	needs attention	disabled: Dependabot alerts are disabled for this repository.
No open HIGH/CRITICAL Dependabot alerts	needs attention	cannot be evaluated while alerts are not readable
Open update PRs pass CI	ok	all passing or pending

Security alerts (Dependabot alerts API)

Dependabot security alerts are **disabled** for this repository (HTTP 403: Dependabot alerts are disabled for this repository). Vulnerable dependencies are therefore not being reported by Dependabot. The repository owner can enable them under Settings > Code security (Dependabot alerts, and optionally Dependabot security updates). Trivy still scans dependencies before every build.

Open version-update pull requests

Major and variant changes (for example a new JDK in a Docker tag) need a human review; failing CI blocks a merge.

PR	Ecosystem	Package	From	To	Change	Age	CI
#3	maven	org.apache.maven:apache-maven	3.9.11	3.10.0	minor	19 days	passing
#4	github-actions	azure/login	2.3.1	3.1.0	major	19 days	passing
#5	github-actions	actions/checkout	4.4.0	7.0.1	major	19 days	passing
#6	maven	org.jacoco:jacoco-maven-plugin	0.8.11	0.8.15	patch	19 days	passing
#7	docker	maven	3.9.11-eclipse-temurin-17	3.9-eclipse-temurin-26	variant	19 days	passing
#8	github-actions	actions/setup-python	5.6.0	7.1.0	major	19 days	passing
#9	maven	org.apache.maven.wrapper:maven-wrapper	3.3.2	3.3.4	patch	19 days	passing
#10	github-actions	actions/setup-java	4.9.1	6.1.0	major	19 days	passing
#11	github-actions	actions/download-artifact	4.3.0	8.0.2	major	19 days	passing
#14	docker	eclipse-temurin	17-jre-alpine	25-jre-alpine	major	14 days	passing
#15	maven	org.springframework.boot:spring-boot-starter-parent	4.1.1	4.1.2	patch	14 days	passing
#17	maven	org.springdoc:springdoc-openapi-starter-webmvc-ui	3.1.1	3.2.0	minor	14 days	passing
#26	terraform	hashicorp/azurerm	4.81.0	5.13.0	major	0 days	passing

Configuration (.github/dependabot.yml)

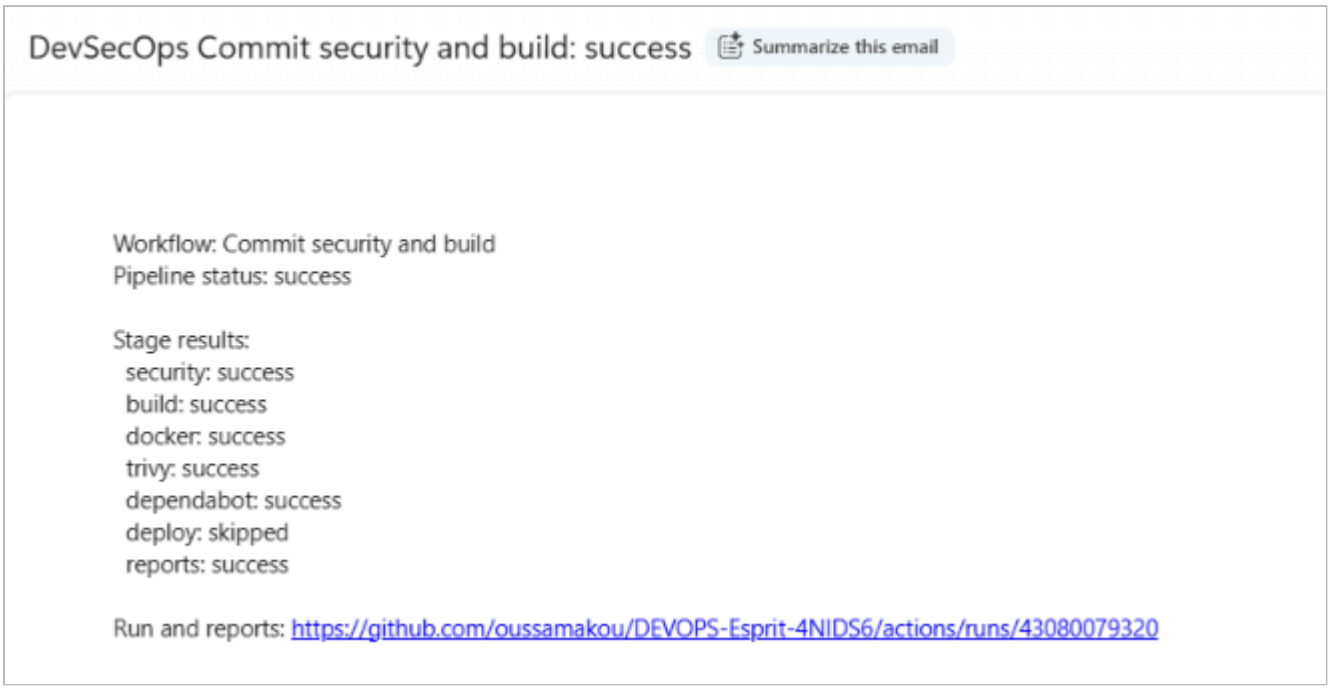
Ecosystem	Directory	Schedule	Open PR limit
maven	/	weekly	5
github-actions	/	weekly	5
pip	/	weekly	5

Dependabot stage page: alerts-disabled finding, 13 update PRs with major and variant changes highlighted (run 43047106961, pull request 27, 11 Nov 2026)

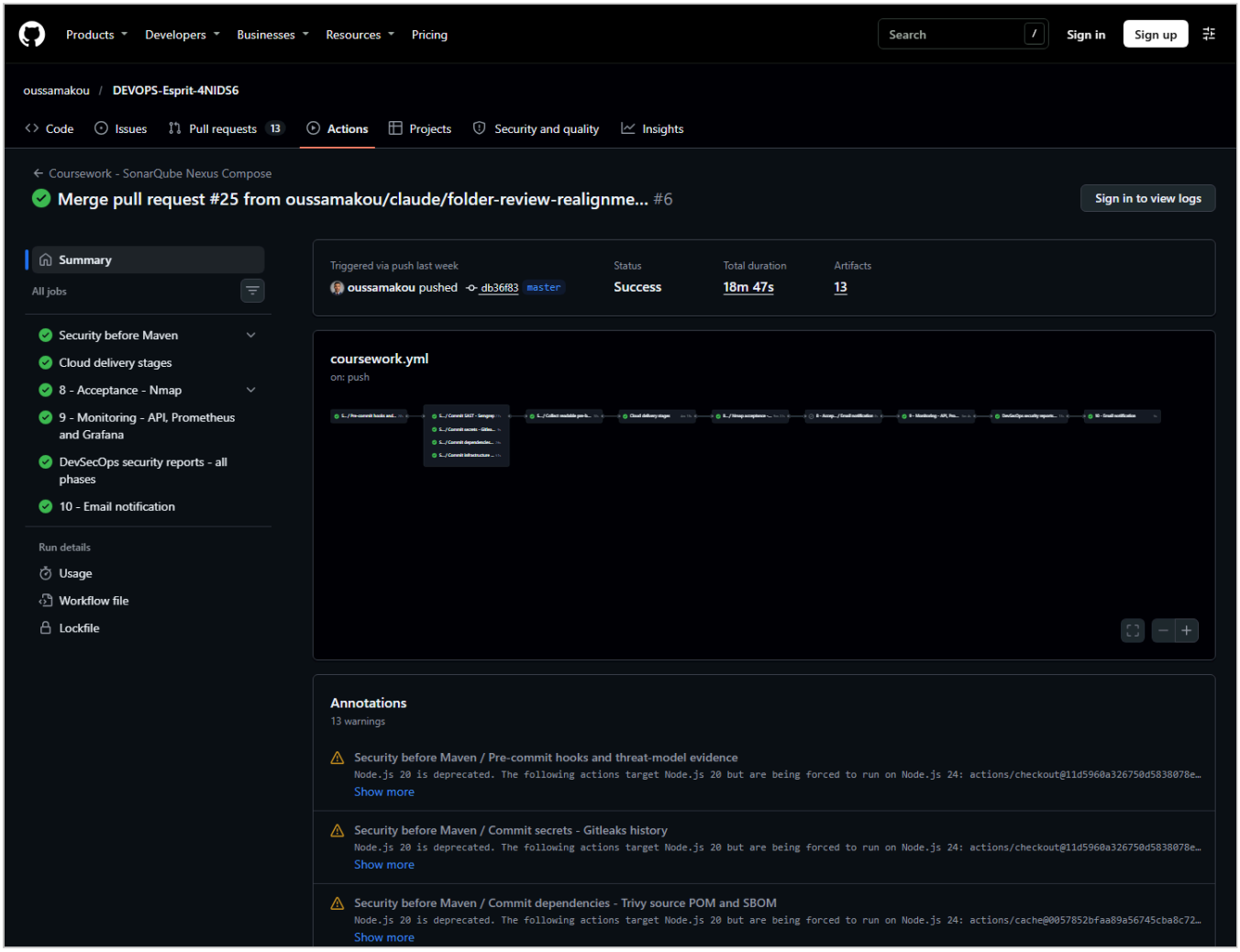
18. Email notification [Verified in a real run]

Technique: Status, per-stage results and the run link sent at the end of every master run
Tool: SMTP over STARTTLS
Blocks the pipeline when: Runs even after failure or cancellation
Report: `the email, and the job in the run graph`

The inbox screenshot verifies receipt of the commit-security notification for run 43080079320. The course-aligned full pipeline run 43082725820 separately records SMTP acceptance for its status message.



Inbox evidence for the commit-security notification (run 43080079320). The address header is obscured.



Historical Azure run with a successful email job (run 42108525318)

Real failures found and fixed

- Trivy blocked the first image with 11 HIGH/CRITICAL findings; fixed by upgrading Spring Boot and Jackson (SECURITY-GATE-CASE-STUDY.md).

- Checkov rejected public HTTP port 80 (CKV_AZURE_160); the port was closed and the rescan passed (screenshots under Infrastructure-as-code policy).
- The first Compose deployment failed on a missing localhost port mapping and config file permissions; repaired and re-run (see Deployment).
- Nexus reported the default encryption key; replaced with a private key (see Artifact repository).
- The first hosted PR run stopped at Nmap when it detected the runner's OpenSSH listener. The runner policy now allows TCP 22 and continues to enforce loopback-only access for lab services.
- The historical Azure SonarQube baseline recorded six HIGH entity-binding findings.

Not yet proven (to capture)

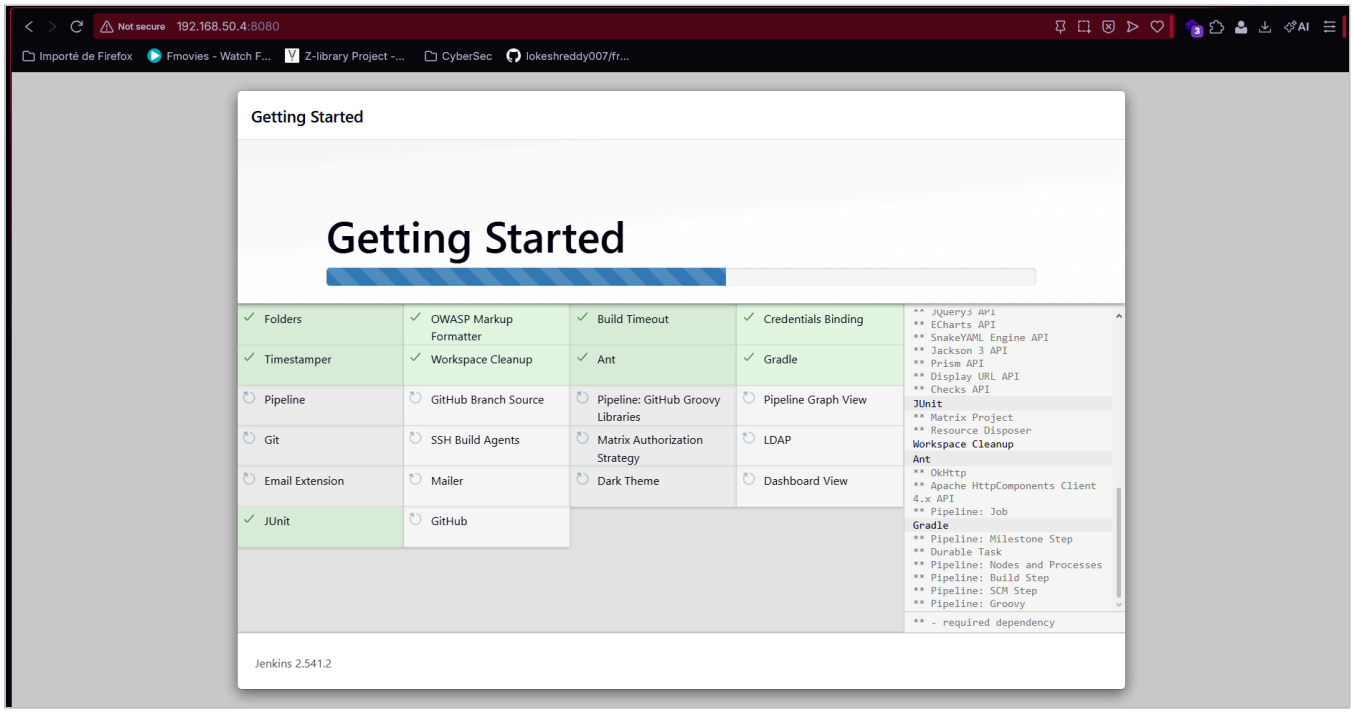
- Dependabot security alerts are disabled on the repository: enable them, then the report will list real alert findings

How to open the evidence

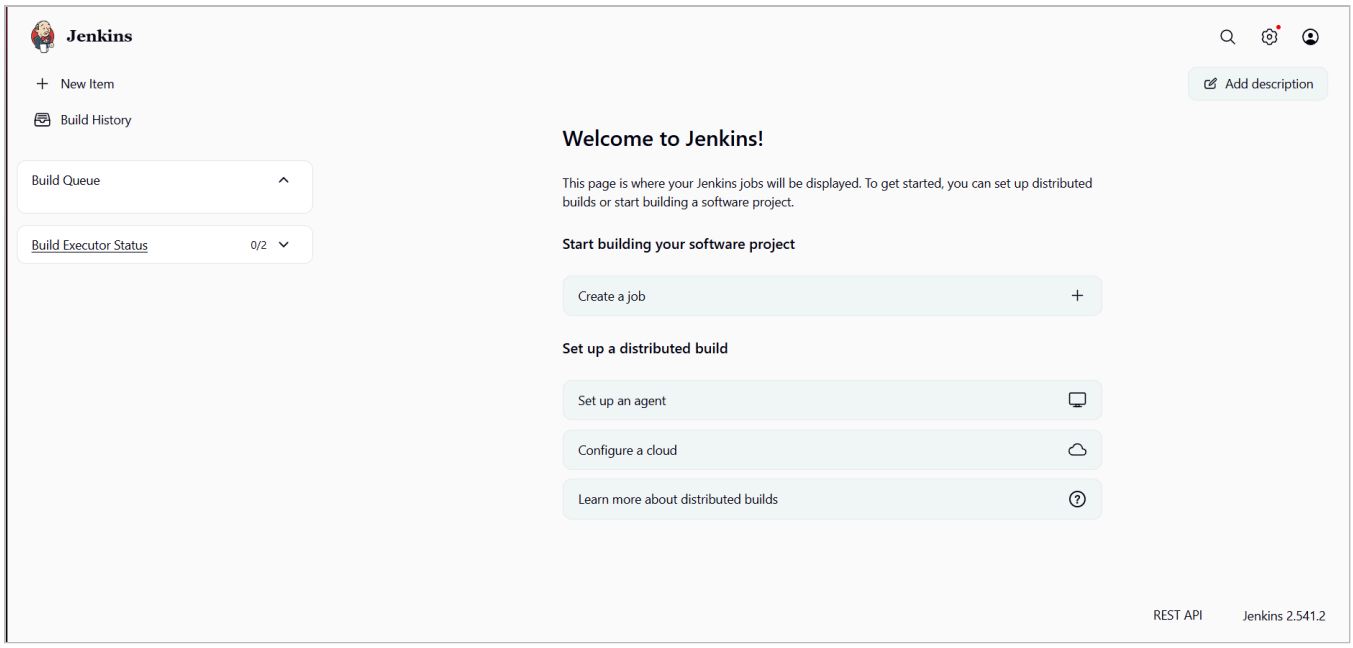
From the hosted run's artifacts, download **devsecops-security-reports**, extract it and open `index.html`. The index links to stage reports, original measurements and the screenshot gallery. The runner and its services stop after the job.

Appendix A. The original Jenkins and Minikube pipeline

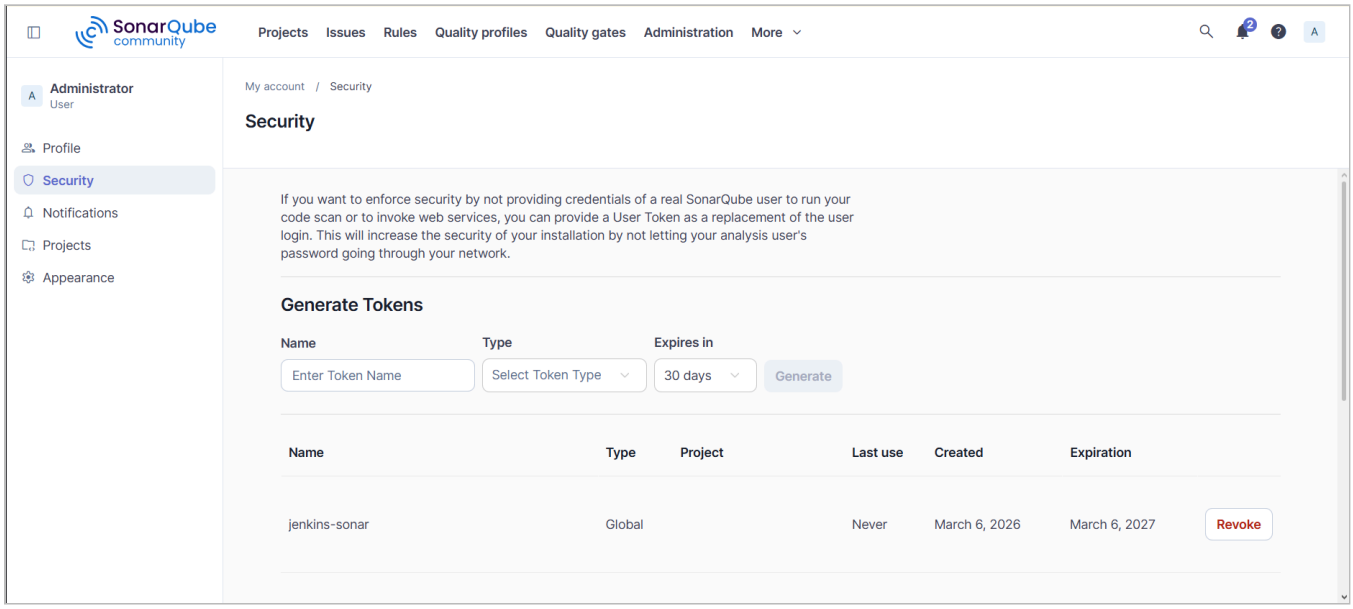
The project started with this school pipeline, preserved in documentation/LEGACY-JENKINS-MINIKUBE.md.



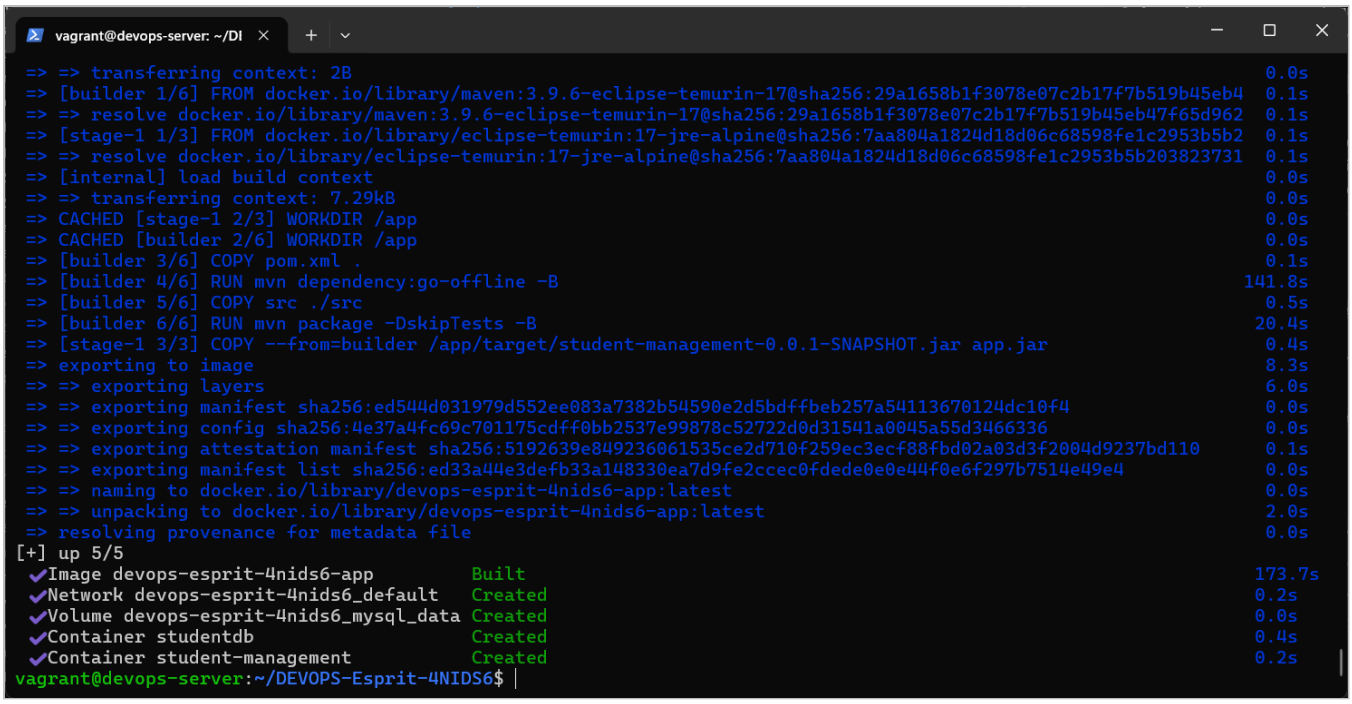
Jenkins plugin installation



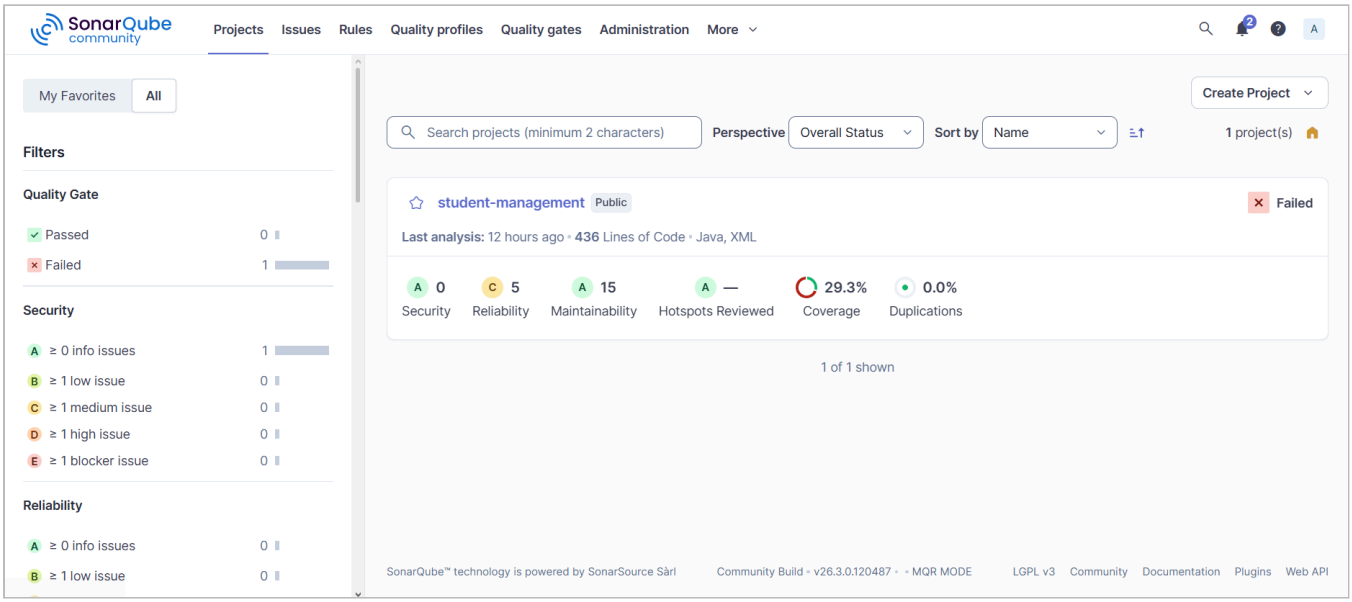
Jenkins dashboard



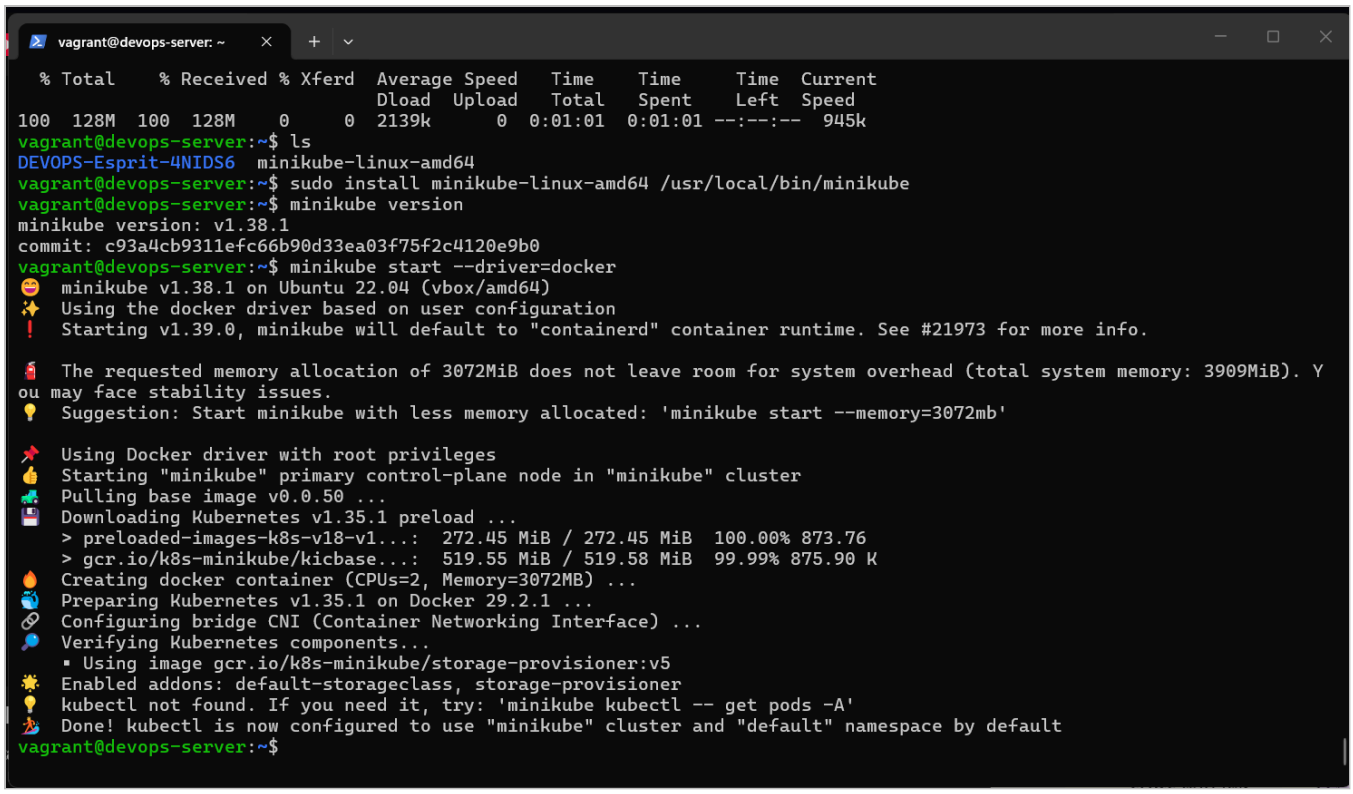
SonarQube interface



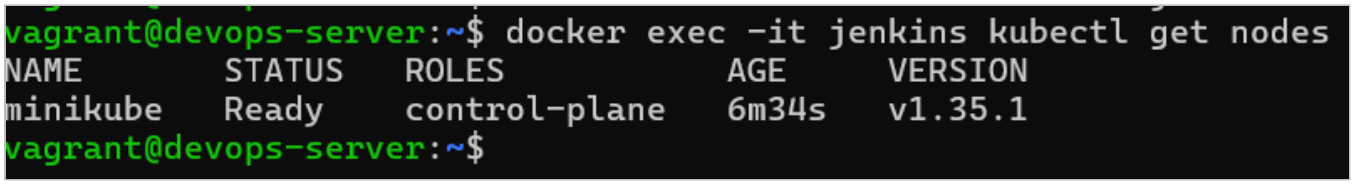
Containers running



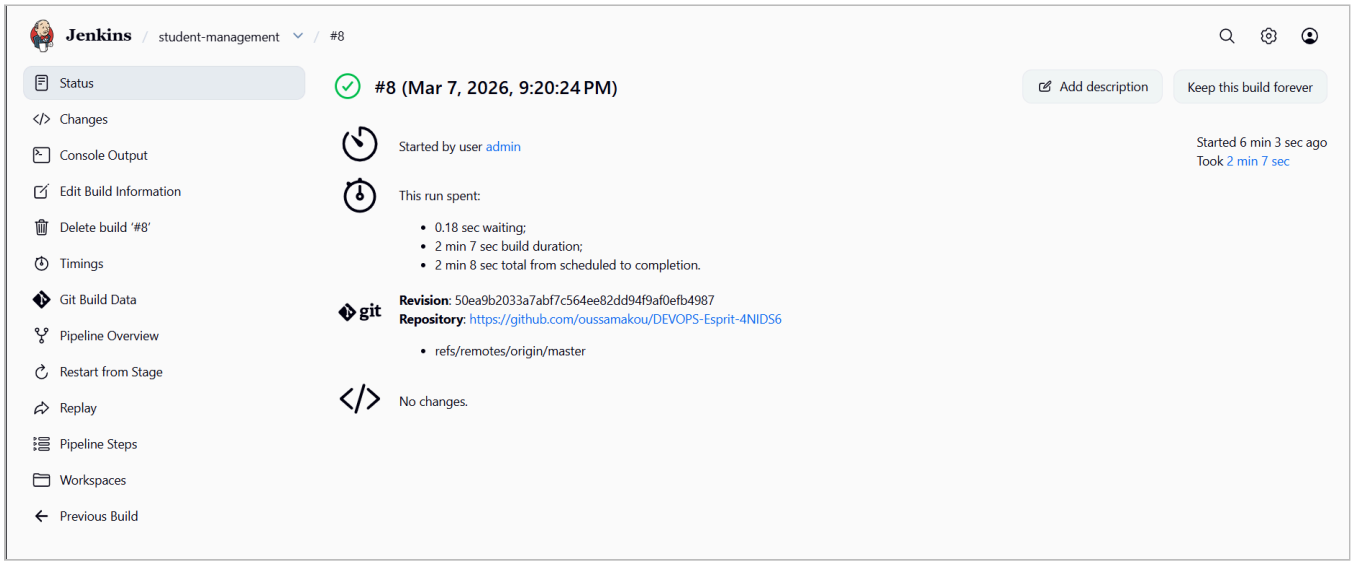
SonarQube 29% coverage



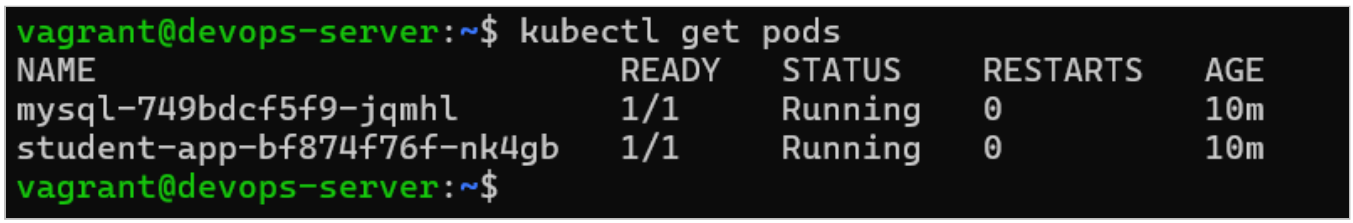
Minikube start



Minikube ready



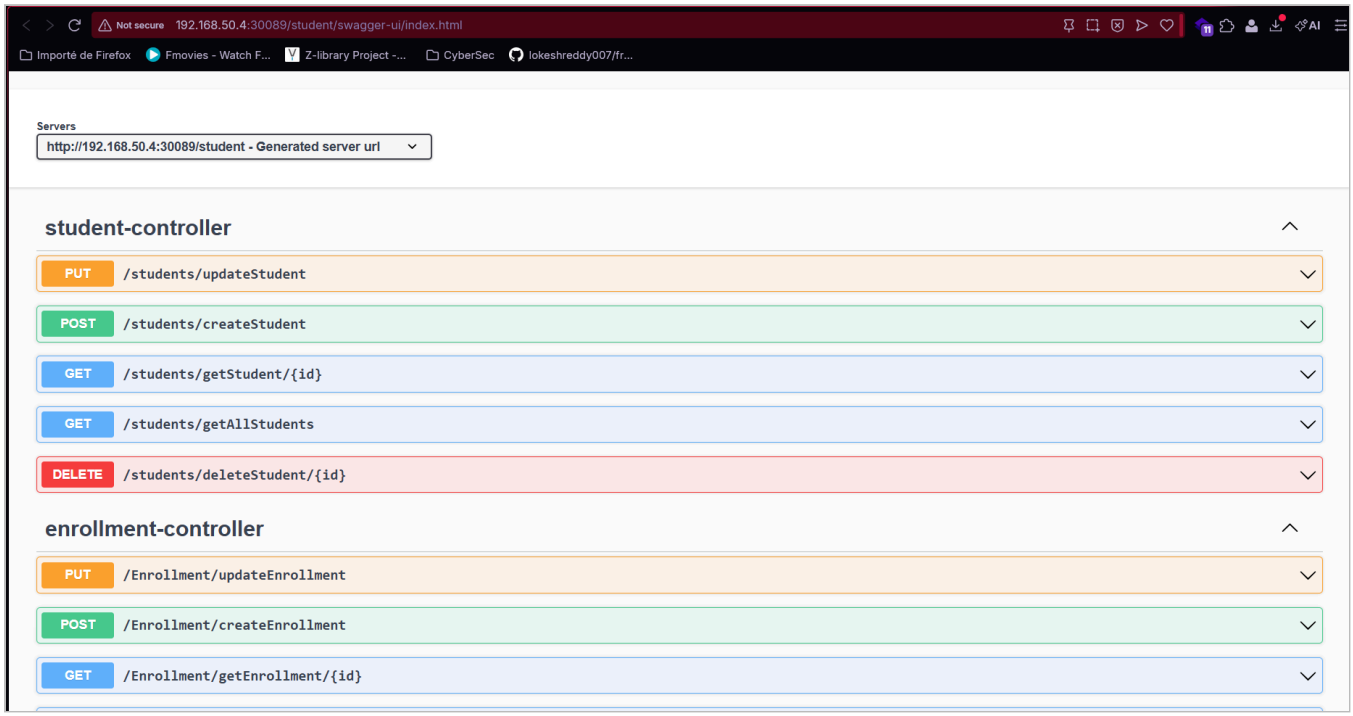
Green Jenkins pipeline



kubectl get pods

```
vagrant@devops-server:~$ kubectl get svc
NAME              TYPE        CLUSTER-IP      EXTERNAL-IP   PORT(S)          AGE
kubernetes        ClusterIP   10.96.0.1       <none>        443/TCP          23m
mysql             ClusterIP   10.107.211.25   <none>        3306/TCP         12m
student-service   NodePort    10.97.246.53    <none>        8089:30089/TCP   12m
vagrant@devops-server:~$ minikube service student-service --url
http://192.168.49.2:30089
```

kubectl get svc



Swagger UI

Appendix B. Tool reports from the hosted run

These are the original report pages from the combined evidence archive for run 43082725820, with excerpts from long console logs. For the original JSON, XML, full logs and screenshots, open the ZIP attached to this PDF or download it from GitHub.

- Pre-commit and threat model
- Semgrep SAST
- Gitleaks
- Trivy dependencies and SBOM
- Terraform and Checkov
- Maven, Surefire and JaCoCo
- SonarQube
- Nexus
- Docker and Trivy image scan
- Registry and digest
- Compose acceptance lab
- Nmap
- Production smoke test
- Operations verification
- Prometheus and Node Exporter
- Grafana
- Dependabot

Pre-commit hooks and threat model: original evidence

Tool: pre-commit, Gitleaks hook
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

precommit: passed

Exit 0. Started 2026-11-11T18:58:14.658361+00:00; finished 2026-11-11T18:58:19.776553+00:00

precommit.log

```
[INFO] Initializing environment for local:PyYAML==6.0.3.
[INFO] Initializing environment for local.
[INFO] Installing environment for local.
[INFO] Once installed this environment will be reused.
[INFO] This may take a few minutes...
[INFO] Installing environment for local.
[INFO] Once installed this environment will be reused.
[INFO] This may take a few minutes...
Validate YAML, XML, merge markers and private-key files.....................Passed
Gitleaks staged secrets (redacted)..........................................Passed
```

The STRIDE threat model is preserved as THREAT-MODEL.md. It remains a human review activity.

Commit SAST: original evidence

Tool: Semgrep
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

semgrep: passed

Exit 0. Started 2026-11-11T18:58:51.370744+00:00; finished 2026-11-11T18:58:53.533453+00:00

semgrep.log

```
┌──────────────┐
│ Scan Status │
└──────────────┘
  Scanning 19 files tracked by git with 3 Code rules:
  Scanning 19 files with 3 java rules.


┌─────────────┐
│ Scan Summary │
└─────────────┘
✅ Scan completed successfully.
 • Findings: 0 (0 blocking)
 • Rules run: 3
 • Targets scanned: 19
 • Parsed lines: ~100.0%
 • Scan was limited to files tracked by git
 • For a detailed list of skipped files and lines, run semgrep with the --verbose flag
Ran 3 rules on 19 files: 0 findings.

A new version of Semgrep is available. See https://semgrep.dev/docs/upgrading
If Semgrep missed a finding, please send us feedback to let us know!
See https://semgrep.dev/docs/reporting-false-negatives/
```

Commit secrets scan: original evidence

Tool: Gitleaks
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

gitleaks: passed

Exit 0. Started 2026-11-11T18:58:27.911520+00:00; finished 2026-11-11T18:58:28.348774+00:00

gitleaks.log

```
    ○
    │╲
    │ ○
    ○ ░
    ░    gitleaks

6:58PM INF 68 commits scanned.
6:58PM INF scanned ~824712 bytes (824.71 KB) in 254ms
6:58PM INF no leaks found
```

Source dependency scan and SBOM: original evidence

Tool: Trivy, CycloneDX
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Verified inventory


```
{
  "source": "pom.xml before Maven compilation",
  "pom_sha256": "ab31fea1a4a3c7cd4b3b299eeed74af0b58f40b19bc330574f02f231f2d90bca",
  "packages_analyzed": 108,
  "sbom_components": 109,
  "high_critical_findings": 0,
  "scanner_exit_code": 0,
  "scope": "Trivy Maven compile/runtime/import scopes; test and optional dependencies excluded"
}
```


dependencies: passed

Exit 0. Started 2026-11-11T18:58:39.049725+00:00; finished 2026-11-11T18:58:44.837068+00:00

dependency-resolution: passed

Exit 0. Started 2026-11-11T18:58:28.690703+00:00; finished 2026-11-11T18:58:37.194369+00:00

dependencies.log


```
2026-11-11T18:58:39Z    INFO    [vulndb] Need to update DB
2026-11-11T18:58:39Z    INFO    [vulndb] Downloading vulnerability DB...
2026-11-11T18:58:39Z    INFO    [vulndb] Downloading artifact...        repo="mirror.gcr.io/aquasec/trivy-db:2"
2026-11-11T18:58:44Z    INFO    [vulndb] Artifact successfully downloaded       repo="mirror.gcr.io/aquasec/trivy-db:2"
2026-11-11T18:58:44Z    INFO    [vuln] Vulnerability scanning is enabled
2026-11-11T18:58:44Z    INFO    Number of language-specific files       num=1
2026-11-11T18:58:44Z    INFO    [pom] Detecting vulnerabilities...

📣 Notices:
  - Version 0.76.2 of Trivy is now available, current version is 0.76.0

To suppress version checks, run Trivy scans with the --skip-version-check flag

2026-11-11T18:58:44Z    INFO    "--format cyclonedx" disables security scanning. Specify "--scanners vuln" explicitly if you want to
include vulnerabilities in the "cyclonedx" report.
{
  "source": "pom.xml before Maven compilation",
  "pom_sha256": "ab31fea1a4a3c7cd4b3b299eeed74af0b58f40b19bc330574f02f231f2d90bca",
  "packages_analyzed": 108,
  "sbom_components": 109,
  "high_critical_findings": 0,
  "scanner_exit_code": 0,
  "scope": "Trivy Maven compile/runtime/import scopes; test and optional dependencies excluded"
}
```


dependency-resolution.log


```
[INFO] Scanning for projects...
[INFO]
[INFO] --------------------< tn.esprit:student-management >--------------------
[INFO] Building student-management 0.0.1-SNAPSHOT
[INFO]   from pom.xml
[INFO] --------------------------------[ jar ]---------------------------------
[INFO]
[INFO] --- dependency:3.10.0:resolve (default-cli) @ student-management ---
[Full log in the attached ZIP. 132 lines omitted here.]
```

```
[INFO]    org.springdoc:springdoc-openapi-starter-webmvc-api:jar:3.1.1:compile -- module org.springdoc.openapi.webmvc.core [auto]
[INFO]    org.springdoc:springdoc-openapi-starter-common:jar:3.1.1:compile -- module org.springdoc.openapi.common [auto]
[INFO]    org.springframework.boot:spring-boot-validation:jar:4.1.1:compile -- module spring.boot.validation [auto]
[INFO]    org.hibernate.validator:hibernate-validator:jar:9.1.3.Final:compile -- module org.hibernate.validator
[INFO]    com.fasterxml:classmate:jar:1.7.3:compile -- module com.fasterxml.classmate
[INFO]    io.swagger.core.v3:swagger-core-jakarta:jar:2.2.55:compile -- module io.swagger.v3.core [auto]
[INFO]    org.apache.commons:commons-lang3:jar:3.20.0:compile -- module org.apache.commons.lang3
[INFO]    io.swagger.core.v3:swagger-annotations-jakarta:jar:2.2.55:compile -- module io.swagger.v3.oas.annotations [auto]
[INFO]    io.swagger.core.v3:swagger-models-jakarta:jar:2.2.55:compile -- module io.swagger.v3.oas.models [auto]
[INFO]    jakarta.validation:jakarta.validation-api:jar:3.1.1:compile -- module jakarta.validation
[INFO]    com.fasterxml.jackson.core:jackson-databind:jar:2.21.8:compile -- module com.fasterxml.jackson.databind
[INFO]    com.fasterxml.jackson.core:jackson-core:jar:2.21.8:compile -- module com.fasterxml.jackson.core
[INFO]    com.fasterxml.jackson.dataformat:jackson-dataformat-yaml:jar:2.21.8:compile -- module com.fasterxml.jackson.dataformat.yaml
[INFO]    com.fasterxml.jackson.datatype:jackson-datatype-jsr310:jar:2.21.8:compile -- module com.fasterxml.jackson.datatype.jsr310
[INFO]    org.webjars:swagger-ui:jar:5.32.14:compile -- module swagger.ui (auto)
[INFO]    org.webjars:webjars-locator-lite:jar:1.1.4:compile -- module org.webjars.locator_lite [auto]
[INFO]    com.h2database:h2:jar:2.4.240:test -- module com.h2database [auto]
[INFO]
[INFO] ------------------------------------------------------------------------
[INFO] BUILD SUCCESS
[INFO] ------------------------------------------------------------------------
[INFO] Total time:  6.659 s
[INFO] Finished at: 2026-11-11T18:58:37Z
[INFO] ------------------------------------------------------------------------
```

Infrastructure policy: original evidence

Tool: Terraform, Checkov
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Policy counts

- checkov-course.json: 43 passed, 0 failed, 0 skipped
- checkov-default.json: 27 passed, 0 failed, 0 skipped

checkov-course: passed

Exit 0. Started 2026-11-11T18:58:58.743088+00:00; finished 2026-11-11T18:59:00.945423+00:00

checkov-default: passed

Exit 0. Started 2026-11-11T18:58:56.445959+00:00; finished 2026-11-11T18:58:58.700662+00:00

checkov-course.log

```
terraform scan results:

Passed checks: 43, Failed checks: 0, Skipped checks: 0
```

checkov-default.log

```
terraform scan results:

Passed checks: 27, Failed checks: 0, Skipped checks: 0
```

Compile, test and coverage: original evidence

Tool: Maven, Surefire, JaCoCo
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- Surefire: 6 tests in 3 classes, 0 failures, 0 errors, 0 skipped
- JaCoCo line coverage: 41.5% (17/41)

maven: passed

Exit 0. Started 2026-11-11T19:01:33.427503+00:00; finished 2026-11-11T19:02:55.630869+00:00

maven.log

```
[INFO] Scanning for projects...
[INFO]
[INFO] --------------------< tn.esprit:student-management >--------------------
[INFO] Building student-management 0.0.1-SNAPSHOT
[INFO]   from pom.xml
[INFO] --------------------------------[ jar ]---------------------------------
[INFO]
[INFO] --- jacoco:0.8.11:prepare-agent (prepare-agent) @ student-management ---
[Full log in the attached ZIP. 163 lines omitted here.]
Hibernate: select
s1_0.id_student,s1_0.address,s1_0.date_of_birth,s1_0.department_id_department,s1_0.email,s1_0.first_name,s1_0.last_name,s1_0.phone from
student s1_0
[INFO] Tests run: 2, Failures: 0, Errors: 0, Skipped: 0, Time elapsed: 0.678 s -- in tn.esprit.studentmanagement.StudentServiceTest
[INFO]
[INFO] Results:
[INFO]
[INFO] Tests run: 6, Failures: 0, Errors: 0, Skipped: 0
[INFO]
[INFO]
[INFO] --- jacoco:0.8.11:report (report) @ student-management ---
[INFO] Loading execution data file /home/runner/work/DEVOPS-Esprit-4NIDS6/DEVOPS-Esprit-4NIDS6/target/jacoco.exec
[INFO] Analyzed bundle 'student-management' with 8 classes
[INFO]
[INFO] --- jar:3.5.1:jar (default-jar) @ student-management ---
[INFO] Building jar: /home/runner/work/DEVOPS-Esprit-4NIDS6/DEVOPS-Esprit-4NIDS6/target/student-management-0.0.1-SNAPSHOT.jar
[INFO]
[INFO] --- spring-boot:4.1.1:repackage (repackage) @ student-management ---
[INFO] Replacing main artifact /home/runner/work/DEVOPS-Esprit-4NIDS6/DEVOPS-Esprit-4NIDS6/target/student-management-0.0.1-SNAPSHOT.jar
with repackaged archive, adding nested dependencies in BOOT-INF/.
[INFO] The original artifact has been renamed to /home/runner/work/DEVOPS-Esprit-4NIDS6/DEVOPS-Esprit-4NIDS6/target/student-management-
0.0.1-SNAPSHOT.jar.original
[INFO] ------------------------------------------------------------------------
[INFO] BUILD SUCCESS
[INFO] ------------------------------------------------------------------------
[INFO] Total time:  01:16 min
[INFO] Finished at: 2026-11-11T19:02:55Z
[INFO] ------------------------------------------------------------------------
```

Code quality gate: original evidence

Tool: SonarQube
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- SonarQube quality gate: PASSED
- SonarQube project: student-management

Recorded facts

server	`http://127.0.0.1:9000`
version	`26.10.0.133078`
project	`student-management`
admin_password	`replaced with a random per-run value`
anonymous_read	`enabled (disposable runner only)`

sonar: passed

Exit 0. Started 2026-11-11T19:03:21.710077+00:00; finished 2026-11-11T19:03:44.466606+00:00

sonar-setup: passed

Exit 0. Started 2026-11-11T19:03:19.533012+00:00; finished 2026-11-11T19:03:21.655766+00:00

tools-start: passed

Exit 0. Started 2026-11-11T19:01:03.924891+00:00; finished 2026-11-11T19:01:33.373315+00:00

sonar-setup.log

```
SonarQube ready after 0 s
SonarQube 26.10.0.133078 ready: project student-management created, analysis token issued
```

sonar.log

```
[INFO] Scanning for projects...
[INFO]
[INFO] --------------------< tn.esprit:student-management >--------------------
[INFO] Building student-management 0.0.1-SNAPSHOT
[INFO]   from pom.xml
[INFO] --------------------------------[ jar ]---------------------------------
[INFO]
[INFO] --- sonar:5.8.0.7211:sonar (default-cli) @ student-management ---
[Full log in the attached ZIP. 117 lines omitted here.]
[INFO] Sensor Java CPD Block Indexer (done) | time=23ms
[INFO] ------------- Gather SCA dependencies on project
[INFO] Dependency analysis skipped
[INFO] SCM Publisher SCM provider for this project is: git
[INFO] SCM Publisher 23 source files to be analyzed
[INFO] SCM Publisher 23/23 source files have been analyzed (done) | time=522ms
[INFO] CPD Executor 9 files had no CPD blocks
[INFO] CPD Executor Calculating CPD for 10 files
```

```
[INFO] CPD Executor CPD calculation finished (done) | time=10ms
[INFO] SCM revision ID '1abd57170f35bac5b2aae04689eb8f4ae078ae98'
[INFO] Analysis report generated in 97ms, dir size=206.7 kB
[INFO] Analysis report compressed in 59ms, zip size=63.4 kB
[INFO] Analysis report uploaded in 77ms
[INFO] ------------- Check Quality Gate status
[INFO] Waiting for the analysis report to be processed (max 300s)
[INFO] QUALITY GATE STATUS: PASSED - View details on http://127.0.0.1:9000/dashboard?id=student-management
[INFO] Analysis total time: 14.273 s
[INFO] SonarScanner Engine completed successfully
[INFO] ------------------------------------------------------------------------
[INFO] BUILD SUCCESS
[INFO] ------------------------------------------------------------------------
[INFO] Total time:  20.392 s
[INFO] Finished at: 2026-11-11T19:03:44Z
[INFO] ------------------------------------------------------------------------
```

tools-start.log

```
vm.max_map_count = 524288
fs.file-max = 131072
 sonarqube Pulling
 nexus Pulling
 postgres Pulling
 37fb86c2a767 Pulling fs layer
 56c5b61c6d2b Pulling fs layer
 c2f4b34f5119 Pulling fs layer
[Full log in the attached ZIP. 450 lines omitted here.]
 Volume "student-tools_sonar_data"  Created
 Volume "student-tools_sonar_extensions"  Creating
 Volume "student-tools_sonar_extensions"  Created
 Volume "student-tools_sonar_logs"  Creating
 Volume "student-tools_sonar_logs"  Created
 Volume "student-tools_nexus_data"  Creating
 Volume "student-tools_nexus_data"  Created
 Volume "student-tools_postgres_data"  Creating
 Volume "student-tools_postgres_data"  Created
 Container student-tools-postgres-1  Creating
 Container student-tools-nexus-1  Creating
 Container student-tools-postgres-1  Created
 Container student-tools-sonarqube-1  Creating
 Container student-tools-nexus-1  Created
 Container student-tools-sonarqube-1  Created
 Container student-tools-postgres-1  Starting
 Container student-tools-nexus-1  Starting
 Container student-tools-postgres-1  Started
 Container student-tools-postgres-1  Waiting
 Container student-tools-nexus-1  Started
 Container student-tools-postgres-1  Healthy
 Container student-tools-sonarqube-1  Starting
 Container student-tools-sonarqube-1  Started
SonarQube and Nexus starting on 127.0.0.1:9000 and 127.0.0.1:8081 (Caddy HTTPS profile not started)
```

Artifact repository: original evidence

Tool: Nexus
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- match: true
- snapshot_version: 0.0.1-20261111.190402-1

Recorded facts

repository_url	`http://localhost:8081/repository/maven-snapshots/tn/esprit/student-management/0.0.1-SNAPSHOT/`
stored_jar	`http://localhost:8081/repository/maven-snapshots/tn/esprit/student-management/0.0.1-SNAPSHOT/student-management-0.0.1-20261111.190402-1.jar`
snapshot_version	`0.0.1-20261111.190402-1`
last_updated	`20261111190402`
local_sha1	`91d61c4591c967e7b5dd29eaad1887f2cf9ed114`
remote_sha1	`91d61c4591c967e7b5dd29eaad1887f2cf9ed114`
size_bytes	`64154606`
match	`true`
server	`http://127.0.0.1:8081`
repository	`maven-snapshots`
eula	`accepted (disclaimer saved)`
admin_password	`replaced with a random per-run value`
anonymous_read	`enabled (disposable runner only)`

nexus-deploy: passed

Exit 0. Started 2026-11-11T19:04:01.079397+00:00; finished 2026-11-11T19:04:05.400886+00:00

nexus-setup: passed

Exit 0. Started 2026-11-11T19:04:00.322153+00:00; finished 2026-11-11T19:04:01.041676+00:00

nexus-verify: passed

Exit 0. Started 2026-11-11T19:04:05.438871+00:00; finished 2026-11-11T19:04:05.863731+00:00

nexus-deploy.log

```
[INFO] Scanning for projects...
[INFO]
[INFO] --------------------< tn.esprit:student-management >--------------------
[INFO] Building student-management 0.0.1-SNAPSHOT
[INFO]   from pom.xml
[INFO] --------------------------------[ jar ]---------------------------------
[INFO]
```

```
[INFO] --- deploy:3.1.4:deploy-file (default-cli) @ student-management ---
[INFO] ------------------------------------------------------------------------
[INFO] BUILD SUCCESS
[INFO] ------------------------------------------------------------------------
[INFO] Total time:  2.975 s
[INFO] Finished at: 2026-11-11T19:04:05Z
[INFO] ------------------------------------------------------------------------
```

nexus-setup.log

```
Nexus ready after 0 s
Nexus initial password ready after 0 s
Nexus ready: admin password replaced, EULA accepted, maven-snapshots present
```

nexus-verify.log

```
repository_url: http://localhost:8081/repository/maven-snapshots/tn/esprit/student-management/0.0.1-SNAPSHOT/
stored_jar: http://localhost:8081/repository/maven-snapshots/tn/esprit/student-management/0.0.1-SNAPSHOT/student-management-0.0.1-
20261111.190402-1.jar
snapshot_version: 0.0.1-20261111.190402-1
last_updated: 20261111190402
local_sha1: 91d61c4591c967e7b5dd29eaad1887f2cf9ed114
remote_sha1: 91d61c4591c967e7b5dd29eaad1887f2cf9ed114
size_bytes: 64154606
match: true
NEXUS_VERIFIED: stored JAR matches the tested JAR
```

Image build and vulnerability gate: original evidence

Tool: Docker, k3d smoke test, Trivy
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- Trivy image scan of student-management:1abd57170f35bac5b2aae04689eb8f4ae078ae98: 0 CRITICAL, 0 HIGH findings across 2 scanned targets

Recorded facts

image	`student-management:1abd57170f35bac5b2aae04689eb8f4ae078ae98`
image_id	`sha256:63b667e8060bd063e506c89594d6683b0b39ee002abde22c8393d8d525729acb`
size_bytes	`248677849`

docker-build: passed

Exit 0. Started 2026-11-11T19:04:13.690641+00:00; finished 2026-11-11T19:04:19.036424+00:00

trivy-image: passed

Exit 0. Started 2026-11-11T19:04:19.135678+00:00; finished 2026-11-11T19:04:47.200697+00:00

docker-build.log

```
#0 building with "default" instance using docker driver

#1 [internal] load build definition from Dockerfile
#1 transferring dockerfile: 921B done
#1 DONE 0.0s

#2 resolve image config for docker-image://docker.io/docker/dockerfile:1
#2 ...
[Full log in the attached ZIP. 60 lines omitted here.]
#8 extracting sha256:62fc65da0c5fbc0036993160c5218ccf5f099137891cc3173dd0584fe80ca6ec
#8 extracting sha256:62fc65da0c5fbc0036993160c5218ccf5f099137891cc3173dd0584fe80ca6ec 0.6s done
#8 extracting sha256:1cd29f11df7190b54d024588b636720cf0dce330a910e4b9e777e712485e9c2b
#8 extracting sha256:1cd29f11df7190b54d024588b636720cf0dce330a910e4b9e777e712485e9c2b done
#8 extracting sha256:5a1d02633a996e89809e5ec77ed71a8ec39581554fbb82ae1d86ca5ff7613e95 done
#8 DONE 1.7s

#10 [runtime 2/3] RUN apk upgrade --no-cache && addgroup -g 10001 app && adduser -D -u 10001 -G app app
#10 0.503 (1/1) Upgrading zlib (1.3.2-r1 -> 1.4-r0)
#10 0.513 OK: 40.9 MiB in 73 packages
#10 DONE 0.5s

#11 [runtime 3/3] WORKDIR /app
#11 DONE 0.0s

#12 [ci 1/1] COPY --chown=10001:10001 target/student-management-0.0.1-SNAPSHOT.jar /app/app.jar
#12 DONE 0.1s

#13 exporting to image
#13 exporting layers
#13 exporting layers 0.4s done
#13 writing image sha256:63b667e8060bd063e506c89594d6683b0b39ee002abde22c8393d8d525729acb done
#13 naming to docker.io/library/student-management:1abd57170f35bac5b2aae04689eb8f4ae078ae98 done
#13 DONE 0.4s
```

trivy-image.log

```
2026-11-11T19:04:19Z    INFO    [vulndb] Need to update DB
2026-11-11T19:04:19Z    INFO    [vulndb] Downloading vulnerability DB...
2026-11-11T19:04:19Z    INFO    [vulndb] Downloading artifact...        repo="mirror.gcr.io/aquasec/trivy-db:2"
42.27 MiB / 133.03 MiB [------------------->_____________________________________] 31.77% ? p/s ?106.02 MiB / 133.03 MiB [----------
----------------------------------->___________] 79.69% ? p/s ?133.03 MiB / 133.03 MiB [-----------------------------------------
------------>] 100.00% ? p/s ?133.03 MiB / 133.03 MiB [----------------------------------------->] 100.00% 151.27 MiB p/s ETA
0s133.03 MiB / 133.03 MiB [----------------------------------------->] 100.00% 151.27 MiB p/s ETA 0s133.03 MiB / 133.03 MiB [--------
----------------------------------->] 100.00% 151.27 MiB p/s ETA 0s133.03 MiB / 133.03 MiB [-----------------------------------------
>] 100.00% 141.51 MiB p/s ETA 0s133.03 MiB / 133.03 MiB [----------------------------------------->] 100.00% 141.51 MiB p/s ETA
0s133.03 MiB / 133.03 MiB [----------------------------------------->] 100.00% 141.51 MiB p/s ETA 0s133.03 MiB / 133.03 MiB [--------
----------------------------------->] 100.00% 132.38 MiB p/s ETA 0s133.03 MiB / 133.03 MiB [-----------------------------------------
>] 100.00% 132.38 MiB p/s ETA 0s133.03 MiB / 133.03 MiB [----------------------------------------->] 100.00% 132.38 MiB p/s ETA
0s133.03 MiB / 133.03 MiB [----------------------------------------->] 100.00% 123.84 MiB p/s ETA 0s133.03 MiB / 133.03 MiB [--------
----------------------------------->] 100.00% 123.84 MiB p/s ETA 0s133.03 MiB / 133.03 MiB [-----------------------------------------
>] 100.00% 123.84 MiB p/s ETA 0s133.03 MiB / 133.03 MiB [----------------------------------------->] 100.00% 115.85 MiB p/s ETA
0s133.03 MiB / 133.03 MiB [----------------------------------------->] 100.00% 115.85 MiB p/s ETA 0s133.03 MiB / 133.03 MiB [--------
----------------------------------->] 100.00% 115.85 MiB p/s ETA 0s133.03 MiB / 133.03 MiB [-----------------------------------------
>] 100.00% 108.38 MiB p/s ETA 0s133.03 MiB / 133.03 MiB [----------------------------------------->] 100.00% 108.38 MiB p/s ETA
0s133.03 MiB / 133.03 MiB [----------------------------------------->] 100.00% 108.38 MiB p/s ETA 0s133.03 MiB / 133.03 MiB [--------
--------------------------------------] 100.00% 32.77 MiB p/s 4.3s2026-11-11T19:04:24Z INFO    [vulndb] Artifact successfully
downloaded      repo="mirror.gcr.io/aquasec/trivy-db:2"
2026-11-11T19:04:24Z    INFO    [vuln] Vulnerability scanning is enabled
2026-11-11T19:04:29Z    INFO    [javadb] Downloading Java DB...
2026-11-11T19:04:29Z    INFO    [javadb] Downloading artifact...        repo="mirror.gcr.io/aquasec/trivy-java-db:1"
36.23 MiB / 951.57 MiB [-->_____________________________________________________] 3.81% ? p/s ?95.81 MiB / 951.57 MiB [------
>_____________________________] 10.07% ? p/s ?158.19 MiB / 951.57 MiB [---------
>_____________________________________] 16.62% ? p/s ?220.06 MiB / 951.57 MiB [----------
>_____________________________] 23.13% 306.36 MiB p/s ETA 2s280.72 MiB / 951.57 MiB [-------------
>_____________________________] 29.50% 306.36 MiB p/s ETA 2s343.17 MiB / 951.57 MiB [---------------->_____________________________]
36.06% 306.36 MiB p/s ETA 1s408.00 MiB / 951.57 MiB [------------------->_____________________________] 42.88% 306.81 MiB p/s ETA 1s471.87
MiB / 951.57 MiB [---------------------->_____________________] 49.59% 306.81 MiB p/s ETA 1s536.45 MiB / 951.57 MiB [-----------------
-------->_____________________] 56.38% 306.81 MiB p/s ETA 1s599.03 MiB / 951.57 MiB [----------------------------->_________________]
62.95% 307.55 MiB p/s ETA 1s658.92 MiB / 951.57 MiB [------------------------------->_____________] 69.25% 307.55 MiB p/s ETA 0s723.65
MiB / 951.57 MiB [---------------------------------->___________] 76.05% 307.55 MiB p/s ETA 0s784.44 MiB / 951.57 MiB [-----------------
-------------------->________] 82.44% 307.64 MiB p/s ETA 0s849.22 MiB / 951.57 MiB [------------------------------------->____]
89.24% 307.64 MiB p/s ETA 0s910.93 MiB / 951.57 MiB [------------------------------------------>_] 95.73% 307.64 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [----------------------------------------->] 100.00% 305.75 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [-----------------
-------------------------->] 100.00% 305.75 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->]
100.00% 305.75 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->] 100.00% 286.02 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [----------------------------------------->] 100.00% 286.02 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [-----------------
-------------------------->] 100.00% 286.02 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->]
100.00% 267.57 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->] 100.00% 267.57 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [----------------------------------------->] 100.00% 267.57 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [-----------------
-------------------------->] 100.00% 250.31 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->]
100.00% 250.31 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->] 100.00% 250.31 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [----------------------------------------->] 100.00% 234.16 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [-----------------
-------------------------->] 100.00% 234.16 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->]
100.00% 234.16 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->] 100.00% 219.05 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [----------------------------------------->] 100.00% 219.05 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [-----------------
-------------------------->] 100.00% 219.05 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->]
100.00% 204.92 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->] 100.00% 204.92 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [----------------------------------------->] 100.00% 204.92 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [-----------------
-------------------------->] 100.00% 191.70 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->]
100.00% 191.70 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->] 100.00% 191.70 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [----------------------------------------->] 100.00% 179.33 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [-----------------
-------------------------->] 100.00% 179.33 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->]
100.00% 179.33 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->] 100.00% 167.76 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [----------------------------------------->] 100.00% 167.76 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [-----------------
-------------------------->] 100.00% 167.76 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->]
100.00% 156.94 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->] 100.00% 156.94 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [----------------------------------------->] 100.00% 156.94 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [-----------------
-------------------------->] 100.00% 146.81 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->]
100.00% 146.81 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->] 100.00% 146.81 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [----------------------------------------->] 100.00% 137.34 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [-----------------
-------------------------->] 100.00% 137.34 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->]
100.00% 137.34 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->] 100.00% 128.48 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [----------------------------------------->] 100.00% 128.48 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [-----------------
-------------------------->] 100.00% 128.48 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->]
100.00% 120.19 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->] 100.00% 120.19 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [----------------------------------------->] 100.00% 120.19 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [-----------------
-------------------------->] 100.00% 112.44 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->]
100.00% 112.44 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->] 100.00% 112.44 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [----------------------------------------->] 100.00% 105.18 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [-----------------
-------------------------->] 100.00% 105.18 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->]
100.00% 105.18 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------->] 100.00% 98.40 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [----------------------------------------->] 100.00% 98.40 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [-----------------
```

```
--------------------------->] 100.00% 98.40 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [---------------------------------------->]
100.00% 92.05 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [---------------------------------------->] 100.00% 92.05 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [---------------------------------------->] 100.00% 92.05 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------
--------------------------->] 100.00% 86.11 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [---------------------------------------->]
100.00% 86.11 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [---------------------------------------->] 100.00% 86.11 MiB p/s ETA 0s951.57
MiB / 951.57 MiB [---------------------------------------->] 100.00% 80.55 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------
--------------------------->] 100.00% 80.55 MiB p/s ETA 0s951.57 MiB / 951.57 MiB [----------------------------------------------]
100.00% 61.83 MiB p/s 16s2026-11-11T19:04:45Z   INFO    [javadb] Artifact successfully downloaded
repo="mirror.gcr.io/aquasec/trivy-java-db:1"
2026-11-11T19:04:45Z    INFO    [javadb] Java DB is cached for 3 days. If you want to update the database more frequently, "trivy clean
--java-db" command clears the DB cache.
2026-11-11T19:04:47Z    INFO    Detected OS     family="alpine" version="3.24.4"
2026-11-11T19:04:47Z    INFO    [alpine] Detecting vulnerabilities...   os_version="3.24" repository="3.24" pkg_num=73
2026-11-11T19:04:47Z    INFO    Number of language-specific files       num=1
2026-11-11T19:04:47Z    INFO    [jar] Detecting vulnerabilities...

🔔 Notices:
  - Version 0.76.2 of Trivy is now available, current version is 0.76.0

To suppress version checks, run Trivy scans with the --skip-version-check flag
```

Image registry, deploy by digest: original evidence

Tool: OCI registry: ACR (Azure lane) or registry:2 (runner lane)
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- image: localhost:5000/student-management@sha256:c3cd6408e831f0de187ccc1b3d11b2736715606bb9a3bb4cae7fb38351f71c25

Recorded facts

registry	`localhost:5000 (registry:2.8.3 on the runner)`
tag	`1abd57170f35bac5b2aae04689eb8f4ae078ae98`
image	`localhost:5000/student-management@sha256:c3cd6408e831f0de187ccc1b3d11b2736715606bb9a3bb4cae7fb38351f71c25`

registry-push: passed

Exit 0. Started 2026-11-11T19:04:51.660311+00:00; finished 2026-11-11T19:04:56.959359+00:00

registry-push.log

```
The push refers to repository [localhost:5000/student-management]
8b226afd2a84: Preparing
63219d3f9e0d: Preparing
290dfe5eb15b: Preparing
e42b45efe389: Preparing
55a1b1496e64: Preparing
96e76f7affeb: Preparing
60e249de9156: Preparing
75f1d9657d88: Preparing
96e76f7affeb: Waiting
60e249de9156: Waiting
75f1d9657d88: Waiting
e42b45efe389: Pushed
63219d3f9e0d: Pushed
55a1b1496e64: Pushed
290dfe5eb15b: Pushed
75f1d9657d88: Pushed
60e249de9156: Pushed
8b226afd2a84: Pushed
96e76f7affeb: Pushed
1abd57170f35bac5b2aae04689eb8f4ae078ae98: digest: sha256:c3cd6408e831f0de187ccc1b3d11b2736715606bb9a3bb4cae7fb38351f71c25 size: 1995
```

Compose deployment: original evidence

Tool: Docker Compose: Azure VM via Run Command, or the runner acceptance lab
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- image: localhost:5000/student-management@sha256:c3cd6408e831f0de187ccc1b3d11b2736715606bb9a3bb4cae7fb38351f71c25

Recorded facts

image	`localhost:5000/student-management@sha256:c3cd6408e831f0de187ccc1b3d11b2736715606bb9a3bb4cae7fb38351f71c25`
target	`disposable Docker Compose acceptance lab`

compose-deploy: passed

Exit 0. Started 2026-11-11T19:04:57.083741+00:00; finished 2026-11-11T19:05:39.132949+00:00

compose-deploy.log

```
 prometheus Pulling
 grafana Pulling
 mysql Pulling
 e2de96513ba9 Already exists
 4932f6e18969 Pulling fs layer
 2e969a642f62 Pulling fs layer
 6a79d0b513bb Pulling fs layer
 3c698657c75d Pulling fs layer
[Full log in the attached ZIP. 482 lines omitted here.]
 72dcf69f72aa Extracting [==================================================>]    801kB/801kB
 d1acc8122a17 Downloading [=========>                                         ]  2.478MB/13.41MB
 d1acc8122a17 Downloading [==============================================>     ]  12.13MB/13.41MB
 72dcf69f72aa Pull complete
 d1acc8122a17 Verifying Checksum
 d1acc8122a17 Download complete
 456bdf926fcd Extracting [=====>                                             ]  32.77kB/322.1kB
 456bdf926fcd Extracting [==================================================>]  322.1kB/322.1kB
 456bdf926fcd Extracting [==================================================>]  322.1kB/322.1kB
 456bdf926fcd Pull complete
 d1acc8122a17 Extracting [>                                                  ]  163.8kB/13.41MB
 d1acc8122a17 Extracting [==================>                                ]  4.915MB/13.41MB
 d1acc8122a17 Extracting [========================================>          ]  10.49MB/13.41MB
 d1acc8122a17 Extracting [==================================================>]  13.41MB/13.41MB
 d1acc8122a17 Extracting [==================================================>]  13.41MB/13.41MB
 d1acc8122a17 Pull complete
 node-exporter Pulled
 Container student-node-exporter-node-exporter-1  Creating
 Container student-node-exporter-node-exporter-1  Created
 Container student-node-exporter-node-exporter-1  Starting
 Container student-node-exporter-node-exporter-1  Started
Node Exporter listening on the private Docker bridge address 172.19.0.1:9100 (not on the runner's network interface)
API returned a database-backed JSON array; the running container uses the scanned digest
DEPLOY_SUCCEEDED compose-deploy localhost:5000/student-management@sha256:c3cd6408e831f0de187ccc1b3d11b2736715606bb9a3bb4cae7fb38351f71c25
```

Nmap acceptance: PASSED

Disposable GitHub-hosted runner environment, scanned by the runner itself and destroyed after the run. TCP connect scans with light service detection; no exploit scripts.

Coverage: 1-1024,2375,2376,3000,3306,5000,5432,6443,8080,8081,8089,8443,9000,9090,9091,9100,10250,30089. Ports outside this list and UDP were not tested. Filtered means probes received no usable response from this viewpoint. A service version is an observation, not proof of a vulnerability.

TCP 22 is allowed on both viewpoints for the hosted runner's SSH listener. The runner's primary IPv4 must expose no lab services. Loopback must expose Grafana (3000), the image registry (5000), the API (8089) and Prometheus (9091); MySQL, the management port and the build tools must stay closed. Required open ports provide positive controls; incomplete scans and missing reports fail acceptance.

Public viewpoint: passed

runner-interface — 10.1.0.122 — passed

Open TCP ports: [22]; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

TCP port	State	Service observation
22	open	ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.20

Private viewpoint: passed

runner-loopback — 127.0.0.1 — passed

Open TCP ports: [22, 3000, 5000, 8089, 9091]; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

TCP port	State	Service observation
22	open	ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.20
3000	open	ppp
5000	open	upnp
8089	open	unknown
9091	open	xmltec-xmlmail

Production smoke test: original evidence

Tool: Docker image inspection, database-backed API request
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- image: localhost:5000/student-management@sha256:c3cd6408e831f0de187ccc1b3d11b2736715606bb9a3bb4cae7fb38351f71c25

Recorded facts

image	`localhost:5000/student-management@sha256:c3cd6408e831f0de187ccc1b3d11b2736715606bb9a3bb4cae7fb38351f71c25`

production-smoke: passed

Exit 0. Started 2026-11-11T19:06:21.875235+00:00; finished 2026-11-11T19:06:22.109424+00:00

production-smoke.log

```
API returned a database-backed JSON array; the running container uses the scanned digest
PRODUCTION_SMOKE_PASSED localhost:5000/student-management@sha256:c3cd6408e831f0de187ccc1b3d11b2736715606bb9a3bb4cae7fb38351f71c25
```

Operations monitoring verification: original evidence

Tool: API request and monitoring health checks
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

monitoring-check: passed

Exit 0. Started 2026-11-11T19:06:22.158118+00:00; finished 2026-11-11T19:06:22.263504+00:00

prometheus-grafana: passed

Exit 0. Started 2026-11-11T19:06:22.301147+00:00; finished 2026-11-11T19:07:12.726785+00:00

monitoring-check.log

```
MONITORING_VERIFIED: API and 1 runner exporter target(s) UP; Grafana database ok
DEPLOY_SUCCEEDED compose-monitor localhost:5000/student-
management@sha256:c3cd6408e831f0de187ccc1b3d11b2736715606bb9a3bb4cae7fb38351f71c25
```

prometheus-grafana.log

```
PASS: Prometheus student-api target UP - student-api: ['up']
PASS: Prometheus host exporter targets UP - azure-nodes: ['up']
PASS: Grafana database healthy - health: {'database': 'ok', 'version': '13.2.4', 'commit': '0e79aef9d91abf3bdadae9af15763029072fb45b'}
PASS: Grafana Prometheus data source provisioned - 1 data source(s)
PASS: Grafana dashboards provisioned - found ['student-devsecops', 'student-vms']
PASS (informational): Prometheus saw API request traffic - 30/30 requests succeeded; rate series 1
MONITORING_EVIDENCE_VERIFIED: Prometheus and Grafana evidence collected on the runner
```

Metrics collection: original evidence

Tool: Prometheus, Node Exporter
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- 2 of 2 scrape targets UP
- 30/30 read-only API requests generated before sampling

Checks

Check	Result	Detail
Prometheus student-api target UP	passed	student-api: ['up']
Prometheus host exporter targets UP	passed	azure-nodes: ['up']
Prometheus saw API request traffic	passed	30/30 requests succeeded; rate series 1

Sampled at 2026-11-11T19:06:22.369367+00:00 UTC after 30/30 read-only requests to `GET /student/students/getAllStudents (read-only)`. Alerting rule groups configured: 0 (no Alertmanager notifications exist).

Scrape targets (Prometheus /api/v1/targets)

Job	Instance	Host	Health	Last scrape	Last error
azure-nodes	172.19.0.1:9100	github-runner	up	2026-11-11T19:07:04.299230591Z	-
student-api	app:9090	-	up	2026-11-11T19:07:11.217235262Z	-

Instant query values

Metric	PromQL	Value
API scrape availability	`up{job="student-api"}`	instance=app:9090: 1.0
Requests per second	`sum(rate(http_server_requests_seconds_count{application="student-management",uri!~"/actuator.*"}[5m]))`	total: 0.108303
5xx responses per second	`sum(rate(http_server_requests_seconds_count{application="student-management",status=~"5.."}[5m]))`	no series
95th percentile latency (s)	`histogram_quantile(0.95, sum by (le) (rate(http_server_requests_seconds_bucket{application="student-management",uri!~"/actuator.*"}[5m])))`	total: 0.007959
JVM heap bytes	`sum(jvm_memory_used_bytes{application="student-management",area="heap"})`	total: 38731728.0
Java process CPU	`process_cpu_usage{application="student-management"}`	instance=app:9090: 0.001008
Host exporter scrape UP	`up{job="azure-nodes"}`	host=github-runner, instance=172.19.0.1:9100: 1.0

Host CPU busy %	`100 * (1 - avg by (host) (rate(node_cpu_seconds_total{job="azure-nodes",mode="idle"}[2m])))`	host=github-runner: 18.704538
Host memory used %	`100 * (1 - node_memory_MemAvailable_bytes{job="azure-nodes"} / node_memory_MemTotal_bytes{job="azure-nodes"})`	host=github-runner, instance=172.19.0.1:9100: 12.61239
Host root filesystem used %	`100 * (1 - node_filesystem_avail_bytes{job="azure-nodes",mountpoint="/",fstype!~"tmpfs|overlay|squashfs"} / node_filesystem_size_bytes{job="azure-nodes",mountpoint="/",fstype!~"tmpfs|overlay|squashfs"})`	host=github-runner, instance=172.19.0.1:9100: 33.934145

An empty series is not a measured zero: it means Prometheus has no matching samples.

Dashboards: original evidence

Tool: Grafana
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- database ok, version 13.2.4, 2 provisioned dashboards, 1 data source(s)

Checks

Check	Result	Detail
Grafana database healthy	passed	health: {'database': 'ok', 'version': '13.2.4', 'commit': '0e79aef9d91abf3bdadae9af15763029072fb45b'}
Grafana Prometheus data source provisioned	passed	1 data source(s)
Grafana dashboards provisioned	passed	found ['student-devsecops', 'student-vms']

Grafana health


```
{
  "database": "ok",
  "version": "13.2.4",
  "commit": "0e79aef9d91abf3bdadae9af15763029072fb45b"
}
```


Provisioned data sources

Name	Type	URL (inside the Docker network)	Default
Prometheus	prometheus	http://prometheus:9090	True

Provisioned dashboards

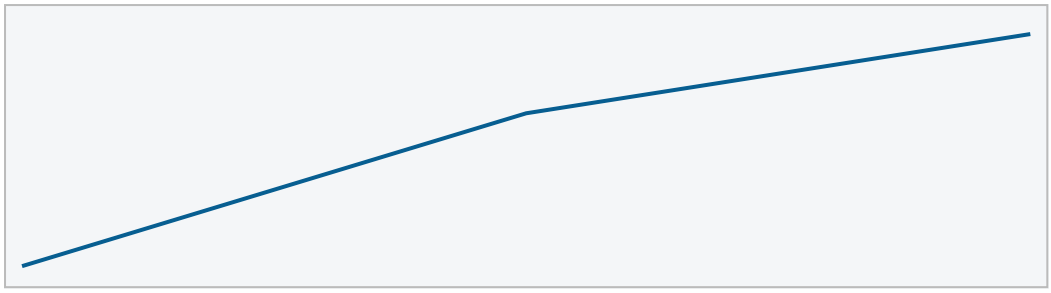
Open through the owner's SSH tunnel (documentation/MONITORING-DEMO.md).

Title	UID	Tunnel link
Azure VMs - Node Exporter	student-vms	http://127.0.0.1:3000/d/student-vms/azure-vms-node-exporter
Student API - DevSecOps Lab	student-devsecops	http://127.0.0.1:3000/d/student-devsecops/student-api-devsecops-lab

Dashboard panel data

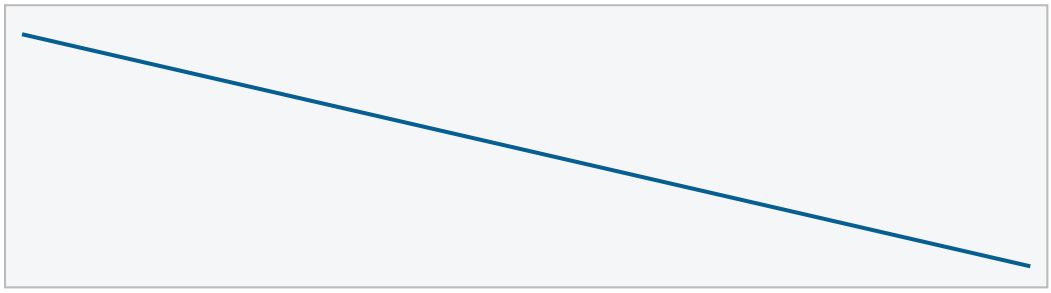
Drawn from Prometheus `query_range` (last 15 minutes, 30 s step) using the same PromQL as the dashboard panels. This is **not** a Grafana screenshot.

Requests per second



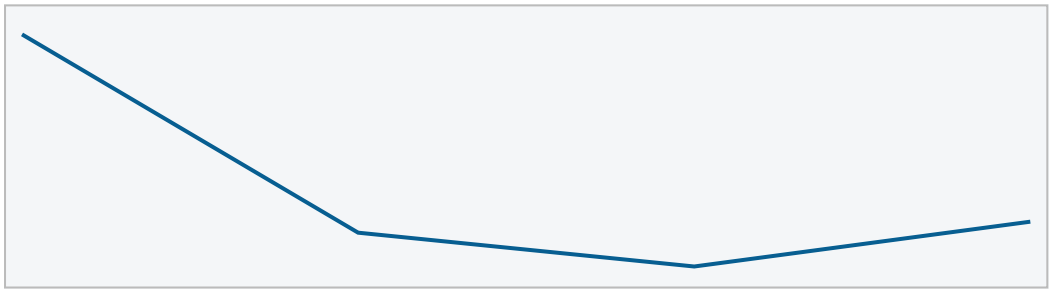
min 0, max 0.1076 over 1 minutes. ■ series

95th percentile latency (s)



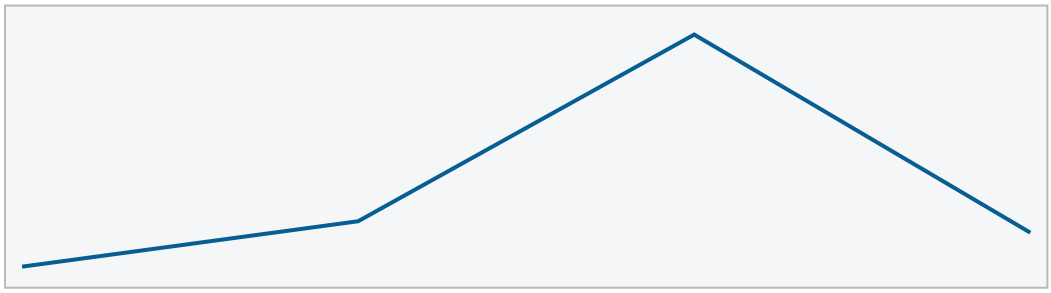
min 0.007963, max 0.008345 over 0 minutes. ■ series

JVM heap bytes



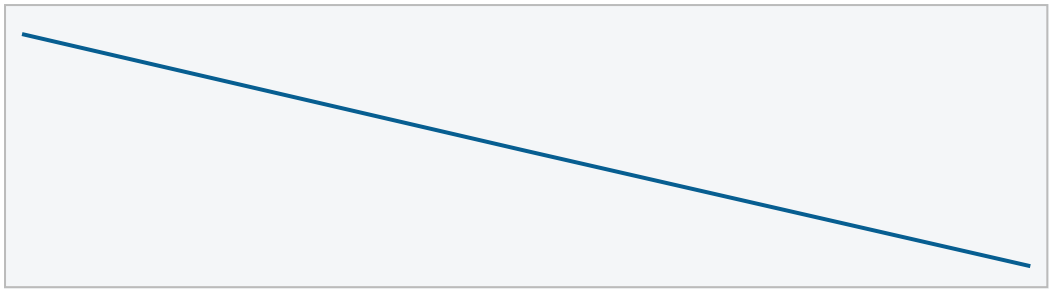
min 3.619e+07, max 4.935e+07 over 1 minutes. ■ series

Java process CPU



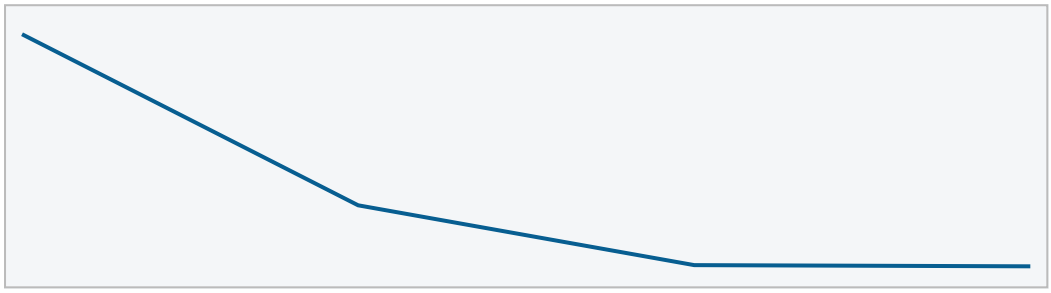
min 0, max 0.00689 over 1 minutes. ■ instance=app:9090, job=student-api

Host CPU busy %



min 19.2, max 69.3 over 1 minutes. ■ host=github-runner

Host memory used %



min 12.61, max 15.57 over 1 minutes. ■ host=github-runner, instance=172.19.0.1:9100, job=azure-nodes

Dependency updates and security alerts: original evidence

Tool: Dependabot
Revision: `1abd57170f35bac5b2aae04689eb8f4ae078ae98`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- 13 open update PRs (8 major or variant, 0 failing CI, oldest 19 days)
- security alerts DISABLED
- 5 ecosystems watched: maven, github-actions, pip, docker, terraform

Findings

Check	Result	Detail
Dependabot version updates configured	ok	maven (weekly), github-actions (weekly), pip (weekly), docker (weekly), terraform (weekly)
Dependabot security alerts enabled and readable	needs attention	disabled: Dependabot alerts are disabled for this repository.
No open HIGH/CRITICAL Dependabot alerts	needs attention	cannot be evaluated while alerts are not readable
Open update PRs pass CI	ok	all passing or pending

Security alerts (Dependabot alerts API)

Dependabot security alerts are **disabled** for this repository (HTTP 403: Dependabot alerts are disabled for this repository). Vulnerable dependencies are therefore not being reported by Dependabot. The repository owner can enable them under Settings > Code security (Dependabot alerts, and optionally Dependabot security updates). Trivy still scans dependencies before every build.

Open version-update pull requests

Major and variant changes (for example a new JDK in a Docker tag) need a human review; failing CI blocks a merge.

PR	Ecosystem	Package	From	To	Change	Age	CI
#3	maven	org.apache.maven:apache-maven	3.9.11	3.10.0	minor	19 days	passing
#4	github-actions	azure/login	2.3.1	3.1.0	major	19 days	passing
#5	github-actions	actions/checkout	4.4.0	7.0.1	major	19 days	passing
#6	maven	org.jacoco:jacoco-maven-plugin	0.8.11	0.8.15	patch	19 days	passing
#7	docker	maven	3.9.11-eclipse-temurin-17	3.9-eclipse-temurin-26	variant	19 days	passing
#8	github-actions	actions/setup-python	5.6.0	7.1.0	major	19 days	passing
#9	maven	org.apache.maven.wrapper:maven-wrapper	3.3.2	3.3.4	patch	19 days	passing
#10	github-actions	actions/setup-java	4.9.1	6.2.0	major	19 days	passing
#11	github-actions	actions/download-artifact	4.3.0	8.0.2	major	19 days	passing

#14	docker	eclipse-temurin	17-jre-alpine	25-jre-alpine	major	15 days	passing
#15	maven	org.springframework.boot:spring-boot-starter-parent	4.1.1	4.1.2	patch	15 days	passing
#17	maven	org.springdoc:springdoc-openapi-starter-webmvc-ui	3.1.1	3.2.0	minor	15 days	passing
#26	terraform	hashicorp/azurerm	4.81.0	5.13.0	major	1 days	passing

Configuration (.github/dependabot.yml)

Ecosystem	Directory	Schedule	Open PR limit
maven	/	weekly	5
github-actions	/	weekly	5
pip	/	weekly	5
docker	/	weekly	5
terraform	/terraform	weekly	5

Collected 2026-11-11T19:07:37.965507+00:00 UTC from the GitHub API for oussamakou/DEVOPS-Esprit-4NIDS6.

dependabot: passed

Exit 0. Started 2026-11-11T19:07:37.910652+00:00; finished 2026-11-11T19:07:46.206227+00:00

dependabot.log

```
DEPENDABOT: 13 open update PRs (8 major or variant, 0 failing CI, oldest 19 days)
DEPENDABOT: security alerts DISABLED
DEPENDABOT: 5 ecosystems watched: maven, github-actions, pip, docker, terraform
PASS: Dependabot version updates configured - maven (weekly), github-actions (weekly), pip (weekly), docker (weekly), terraform
(weekly)
FINDING: Dependabot security alerts enabled and readable - disabled: Dependabot alerts are disabled for this repository.
FINDING: No open HIGH/CRITICAL Dependabot alerts - cannot be evaluated while alerts are not readable
PASS (informational): Open update PRs pass CI - all passing or pending
```

Appendix C. Historical assessment PDFs

The following reports retain their original dates, pages and measurements.

- DevSecOps-security-reports-2026-10-29
- DevSecOps-security-reports-2026-11-05

DevSecOps security reports

Oussama Koudhai
Student management application
Assessment package - 29 October 2026

This standalone report summarizes original scanner outputs. The accompanying native JSON, XML, logs, SBOM and configuration files can be read locally without a GitHub account. The scans executed on a hosted Linux runner. Their execution host and exact revision remain recorded for provenance.

Tested revision: `39af89264ff146a985243bbaf6b2b6a26a6648d8`

Control	Measured result
Pre-commit hooks	File validation and staged-secret hooks passed
Semgrep SAST	19 Java files, 3 configured rules, 0 application findings
Checkov	Default: 27 passed / 0 failed. Tools enabled: 43 passed / 0 failed.
Trivy source dependencies	108 analyzed packages, 109 SBOM components, 0 HIGH/CRITICAL findings
Gitleaks history	0 detected secrets
Order before compilation	All six prerequisite security/report jobs finished before Maven compilation started

Limits: these results apply to the configured checks and the recorded scan/database snapshot. Threat modeling is a human review activity. Six existing HIGH Sonar entity-binding findings remain open in the application baseline, and API authentication/authorization remains future work.

1. Threat modeling before implementation changes

Technique: STRIDE review of assets, data flows, trust boundaries, threats, controls and residual risk. The application already existed when this security work was added. CI preserves the document but cannot prove the quality of a human review.

STRIDE category	Project example and current response
Spoofing	An unauthenticated API caller could impersonate another user. Limit access to the owner SSH tunnel and synthetic data. Authentication remains open.
Tampering	A change could alter deployment commands or the image. Restrict delivery to master and use the scanned image digest.
Repudiation	Missing change history makes releases difficult to trace. Preserve commit IDs, scanner reports and delivery records.
Information disclosure	Credentials could enter Git or logs. Use staged/history Gitleaks, environment secrets and redacted reports.
Denial of service	Requests could exhaust the lab VM. Apply resource limits and monitor readiness/metrics. Rate limiting remains open.
Elevation of privilege	Unsafe source patterns or excessive cloud permissions could increase access. Apply selected SAST checks and scoped deployment identities.

Original document: native-reports/precommit/THREAT-MODEL.md. The matching repository configuration snapshot is under configuration/.

2. Pre-commit hooks

Tool: pre-commit 4.7.0 with local file checks and Gitleaks staged-secret detection. Local hooks run before a commit is created. CI replays the file checks and separately scans Git history because a developer can bypass a local hook.

Hook	Behavior
file-checks	Validate YAML/XML and reject unresolved merge markers and private-key headers.
staged-secrets	Run Gitleaks against the staged Git snapshot with secret values redacted.

Original command transcript:

```
[INFO] Initializing environment for local:PyYAML==6.0.3.
[INFO] Initializing environment for local.
[INFO] Installing environment for local.
[INFO] Once installed this environment will be reused.
[INFO] This may take a few minutes...
[INFO] Installing environment for local.
[INFO] Once installed this environment will be reused.
[INFO] This may take a few minutes...
Validate YAML, XML, merge markers and private-key files.....................Passed
Gitleaks staged secrets (redacted)..........................................Passed
```

The CI checkout normally has no staged changes. Its staged-secret hook passing alone does not prove full-history secret coverage. The separate history scan supplies that evidence.

Original files: native-reports/precommit/precommit.log and precommit-result.json. Hook definitions: configuration/.pre-commit-config.yaml.

3. Commit SAST: Semgrep

Tool: Semgrep 1.182.1. The scanner analyzes Java source without running the application. This project uses three custom blocking rules, rather than claiming complete coverage of every vulnerability class.

Rule	Pattern checked
java-runtime-command-execution	Runtime.getRuntime().exec(...)
java-concatenated-sql	Selected JPA/SQL query calls built by concatenating values
java-disabled-tls-hostname-verification	A hostname verifier that unconditionally returns true

Actual application result: **19 files scanned**, **0 findings**, **0 scanner errors**.

```
Ran 3 rules on 19 files: 0 findings.
```

Separate controlled exercise: the real scanner reported 1 finding on an explicitly labelled temporary command-execution fixture. That fixture is not application code and is not an organically discovered incident.

Zero findings under these rules does not resolve the six existing HIGH Sonar alerts. The two analyses have different rule coverage.

Original application report: native-reports/sast/semgrep.json. Original exercise evidence: native-reports/sast/controlled-exercise/. Rule snapshot: configuration/.semgrep/.

4. Infrastructure policy scanning: Checkov

Tool: Checkov 3.3.29. Target: Terraform source configuration, including a separate scan with the optional coursework tools enabled. This is static infrastructure analysis, rather than an inspection of running Azure resources.

Configuration	Passed	Failed	Reported skipped	Parse errors
Default	27	0	0	0
Tools enabled	43	0	0	0

The two rows overlap and must not be added together as a count of distinct policies. The project also defines CKV_LAB_1 to reject internet-wide inbound SSH, including literal /0 CIDRs and port ranges that include port 22.

The policy configuration contains documented exclusions for the student lab, such as paid registry features and the VM agent needed for Azure Run Command. A reported skipped count of zero does not mean there are no configured policy exclusions. The full .checkov.yml and security notes are included.

```
Configured exclusions: CKV_AZURE_50, CKV_AZURE_119, CKV_AZURE_139, CKV_AZURE_163, CKV_AZURE_164,
 CKV_AZURE_165, CKV_AZURE_166, CKV_AZURE_167, CKV_AZURE_233, CKV_AZURE_237
```

Original machine-readable reports: native-reports/iac/checkov-default.json and checkov-course.json. Native JUnit XML, command outcomes and logs accompany them. Configuration and custom checks are under configuration/.

5. Dependency management: Trivy and SBOM

Tool: Trivy 0.76.0. The dependency job first resolves Maven dependency metadata into its cache without compiling, running tests or packaging the application. Trivy then analyzes the source POM using that metadata before the actual Maven build.

Measurement	Observed value
Source packages analyzed	108
CycloneDX SBOM components	109
HIGH/CRITICAL findings	0
Scanner exit code	0
Source POM SHA-256	ab31fea1a4a3c7cd4b3b299eeed74af0b58f40b19bc330574f02f231f2d90bca

The helper rejects empty inventories, missing expected runtime dependencies and unresolved versions/package URLs. It verifies that the SBOM retains every analyzed package. CI also asserts that application classes and the packaged JAR do not yet exist at this point.

Scope: Maven compile/runtime/import dependency analysis. Test and optional dependencies are excluded by the POM analyzer. The later full-image scan separately examines the packaged Java libraries and OS packages. Dependabot proposes scheduled updates; proposals still need review and validation.

Original files: native-reports/dependencies/dependencies.json, inventory-summary.json, sbom.cdx.json and the exact source pom.xml. The recorded dependency-resolution command is included.

6. Commit secret detection: Gitleaks

Tool: Gitleaks 8.30.1. The separate commit security job checks the available Git history with a full-history checkout and redacted report output. It complements the local staged-secret hook.

Actual result: **0 findings**. An empty findings array is a valid Gitleaks result after a real history scan. It has different semantics from an empty dependency inventory, which would not prove package coverage.

```
3:12PM INF 52 commits scanned.
3:12PM INF scanned ~535518 bytes (535.52 KB) in 386ms
3:12PM INF no leaks found
```

If a real credential is ever found, rotate it and investigate its exposure. Removing the current file alone does not remove Git history or invalidate the credential.

Original files: native-reports/secrets/gitleaks.json, gitleaks.log and gitleaks-result.json. The report uses redacted output.

7. Verified order before Maven compilation

Both workflow entry points depend on the same reusable pre-build security workflow. Hooks run first. Semgrep, Gitleaks, Checkov and source dependency checks follow. Report collection also completes before the Maven job can start.

Prerequisite job	Completed UTC
Pre-commit hooks and threat-model evidence	2026-10-29T15:12:41Z
Commit SAST - Semgrep	2026-10-29T15:13:10Z
Commit secrets - Gitleaks history	2026-10-29T15:12:49Z
Commit dependencies - Trivy source POM and SBOM	2026-10-29T15:13:09Z
Commit infrastructure - Terraform and Checkov	2026-10-29T15:13:31Z
Collect readable pre-build reports	2026-10-29T15:13:43Z
Maven compilation started	2026-10-29T15:13:52Z

Verified: every prerequisite completion timestamp precedes the Maven compilation start. The job dependency configuration provides the enforcement, while these timestamps demonstrate the order in the recorded execution.

The earlier dependency:resolve command is metadata resolution only. The later mvnw verify command performs compilation, testing and packaging. These operations are intentionally separate.

Source files: ordering-proof.json, native-reports/workflow-result.json and configuration/.github/workflows/prebuild-security.yml.

8. Actual failures and the response

Empty early dependency inventory: the 23 October target-directory scan returned no packages and an empty SBOM. A green exit did not establish dependency coverage. The new source-POM scan and explicit coverage checks correct this issue. The old report remains historical evidence.

Maven Central rate limit: the first 29 October hosted source scan received HTTP 429 while retrieving dependency metadata. It failed rather than claiming an incomplete scan passed. Maven compilation and downstream image jobs were skipped. The correction populates a dependency cache with dependency:resolve and scans the cached metadata. This was a repository-access failure, not a detected application vulnerability.

Historical Checkov failure: the optional tools configuration originally allowed public HTTP port 80. Checkov CKV_AZURE_160 blocked that revision. The correction closed port 80 and used TLS-ALPN certificate validation on port 443. The original JUnit reports are included under historical-failures/checkov-public-http/.

Remaining application work: six HIGH entity-binding Sonar findings, authentication/authorization, request validation, improved tests and tested off-VM backups remain open. The initial Sonar baseline had 41.5% overall coverage. A passed new-code gate did not establish overall application security.

Provenance: scans ran on a hosted Linux runner for the recorded revision. This local document is a readable view of the original tool outputs. The native reports, configuration snapshots and SHA-256 manifest accompany it. This report introduces no new finding suppressions. Existing Checkov policy exclusions remain documented.

Technical references: Trivy Java POM coverage at https://trivy.dev/docs/latest/guide/coverage/language/java/ and Trivy JSON conversion at https://www.trivy.dev/docs/v0.53/guide/configuration/reporting/.

DevSecOps security reports

Oussama Koudhai
Student management application
Assessment package - 5 November 2026

This standalone report summarizes original scanner outputs. The accompanying native JSON, XML, logs, SBOM and configuration files can be read locally without a GitHub account. The scans executed on a hosted Linux runner. Their execution host and exact revision remain recorded for provenance.

Pre-commit/commit scan revision (29 October): `39af89264ff146a985243bbaf6b2b6a26a6648d8`

Evidence dates: pre-commit/commit tool snapshots are from 29 October 2026; Nmap acceptance is from 5 November 2026. The earlier scans were preserved, not rerun or relabelled as current. The Nmap run checked the existing deployed Azure environment.

Nmap acceptance revision: `88c9e9f2c33658b5520a5471e7ace2c19dcc2076`

Control	Measured result
Nmap acceptance (5 November)	5 profiles passed; 1,040 TCP ports per profile; no unexpected open ports
Pre-commit hooks	File validation and staged-secret hooks passed
Semgrep SAST	19 Java files, 3 configured rules, 0 application findings
Checkov	Default: 27 passed / 0 failed. Tools enabled: 43 passed / 0 failed.
Trivy source dependencies	108 analyzed packages, 109 SBOM components, 0 HIGH/CRITICAL findings
Gitleaks history	0 detected secrets
Order before compilation	All six prerequisite security/report jobs finished before Maven compilation started

Limits: these results apply to the configured checks and the recorded scan/database snapshot. Threat modeling is a human review activity. Six existing HIGH Sonar entity-binding findings remain open in the application baseline, and API authentication/authorization remains future work.

1. Threat modeling before implementation changes

Technique: STRIDE review of assets, data flows, trust boundaries, threats, controls and residual risk. The application already existed when this security work was added. CI preserves the document but cannot prove the quality of a human review.

STRIDE category	Project example and current response
Spoofing	An unauthenticated API caller could impersonate another user. Limit access to the owner SSH tunnel and synthetic data. Authentication remains open.
Tampering	A change could alter deployment commands or the image. Restrict delivery to master and use the scanned image digest.
Repudiation	Missing change history makes releases difficult to trace. Preserve commit IDs, scanner reports and delivery records.
Information disclosure	Credentials could enter Git or logs. Use staged/history Gitleaks, environment secrets and redacted reports.
Denial of service	Requests could exhaust the lab VM. Apply resource limits and monitor readiness/metrics. Rate limiting remains open.
Elevation of privilege	Unsafe source patterns or excessive cloud permissions could increase access. Apply selected SAST checks and scoped deployment identities.

Original document: native-reports/precommit/THREAT-MODEL.md. The matching repository configuration snapshot is under configuration/.

2. Pre-commit hooks

Tool: pre-commit 4.7.0 with local file checks and Gitleaks staged-secret detection. Local hooks run before a commit is created. CI replays the file checks and separately scans Git history because a developer can bypass a local hook.

Hook	Behavior
file-checks	Validate YAML/XML and reject unresolved merge markers and private-key headers.
staged-secrets	Run Gitleaks against the staged Git snapshot with secret values redacted.

Original command transcript:

```
[INFO] Initializing environment for local:PyYAML==6.0.3.
[INFO] Initializing environment for local.
[INFO] Installing environment for local.
[INFO] Once installed this environment will be reused.
[INFO] This may take a few minutes...
[INFO] Installing environment for local.
[INFO] Once installed this environment will be reused.
[INFO] This may take a few minutes...
Validate YAML, XML, merge markers and private-key files.....................Passed
Gitleaks staged secrets (redacted)..........................................Passed
```

The CI checkout normally has no staged changes. Its staged-secret hook passing alone does not prove full-history secret coverage. The separate history scan supplies that evidence.

Original files: native-reports/precommit/precommit.log and precommit-result.json. Hook definitions: configuration/.pre-commit-config.yaml.

3. Commit SAST: Semgrep

Tool: Semgrep 1.182.1. The scanner analyzes Java source without running the application. This project uses three custom blocking rules, rather than claiming complete coverage of every vulnerability class.

Rule	Pattern checked
java-runtime-command-execution	Runtime.getRuntime().exec(...)
java-concatenated-sql	Selected JPA/SQL query calls built by concatenating values
java-disabled-tls-hostname-verification	A hostname verifier that unconditionally returns true

Actual application result: **19 files scanned**, **0 findings**, **0 scanner errors**.

```
Ran 3 rules on 19 files: 0 findings.
```

Separate controlled exercise: the real scanner reported 1 finding on an explicitly labelled temporary command-execution fixture. That fixture is not application code and is not an organically discovered incident.

Zero findings under these rules does not resolve the six existing HIGH Sonar alerts. The two analyses have different rule coverage.

Original application report: native-reports/sast/semgrep.json. Original exercise evidence: native-reports/sast/controlled-exercise/. Rule snapshot: configuration/.semgrep/.

4. Infrastructure policy scanning: Checkov

Tool: Checkov 3.3.29. Target: Terraform source configuration, including a separate scan with the optional coursework tools enabled. This is static infrastructure analysis, rather than an inspection of running Azure resources.

Configuration	Passed	Failed	Reported skipped	Parse errors
Default	27	0	0	0
Tools enabled	43	0	0	0

The two rows overlap and must not be added together as a count of distinct policies. The project also defines CKV_LAB_1 to reject internet-wide inbound SSH, including literal /0 CIDRs and port ranges that include port 22.

The policy configuration contains documented exclusions for the student lab, such as paid registry features and the VM agent needed for Azure Run Command. A reported skipped count of zero does not mean there are no configured policy exclusions. The full .checkov.yml and security notes are included.

```
Configured exclusions: CKV_AZURE_50, CKV_AZURE_119, CKV_AZURE_139, CKV_AZURE_163, CKV_AZURE_164,
 CKV_AZURE_165, CKV_AZURE_166, CKV_AZURE_167, CKV_AZURE_233, CKV_AZURE_237
```

Original machine-readable reports: native-reports/iac/checkov-default.json and checkov-course.json. Native JUnit XML, command outcomes and logs accompany them. Configuration and custom checks are under configuration/.

5. Dependency management: Trivy and SBOM

Tool: Trivy 0.76.0. The dependency job first resolves Maven dependency metadata into its cache without compiling, running tests or packaging the application. Trivy then analyzes the source POM using that metadata before the actual Maven build.

Measurement	Observed value
Source packages analyzed	108
CycloneDX SBOM components	109
HIGH/CRITICAL findings	0
Scanner exit code	0
Source POM SHA-256	ab31fea1a4a3c7cd4b3b299eeed74af0b58f40b19bc330574f02f231f2d90bca

The helper rejects empty inventories, missing expected runtime dependencies and unresolved versions/package URLs. It verifies that the SBOM retains every analyzed package. CI also asserts that application classes and the packaged JAR do not yet exist at this point.

Scope: Maven compile/runtime/import dependency analysis. Test and optional dependencies are excluded by the POM analyzer. The later full-image scan separately examines the packaged Java libraries and OS packages. Dependabot proposes scheduled updates; proposals still need review and validation.

Original files: native-reports/dependencies/dependencies.json, inventory-summary.json, sbom.cdx.json and the exact source pom.xml. The recorded dependency-resolution command is included.

6. Commit secret detection: Gitleaks

Tool: Gitleaks 8.30.1. The separate commit security job checks the available Git history with a full-history checkout and redacted report output. It complements the local staged-secret hook.

Actual result: **0 findings**. An empty findings array is a valid Gitleaks result after a real history scan. It has different semantics from an empty dependency inventory, which would not prove package coverage.

```
3:12PM INF 52 commits scanned.
3:12PM INF scanned ~535518 bytes (535.52 KB) in 386ms
3:12PM INF no leaks found
```

If a real credential is ever found, rotate it and investigate its exposure. Removing the current file alone does not remove Git history or invalidate the credential.

Original files: native-reports/secrets/gitleaks.json, gitleaks.log and gitleaks-result.json. The report uses redacted output.

7. Verified order before Maven compilation

Both workflow entry points depend on the same reusable pre-build security workflow. Hooks run first. Semgrep, Gitleaks, Checkov and source dependency checks follow. Report collection also completes before the Maven job can start.

Prerequisite job	Completed UTC
Pre-commit hooks and threat-model evidence	2026-10-29T15:12:41Z
Commit SAST - Semgrep	2026-10-29T15:13:10Z
Commit secrets - Gitleaks history	2026-10-29T15:12:49Z
Commit dependencies - Trivy source POM and SBOM	2026-10-29T15:13:09Z
Commit infrastructure - Terraform and Checkov	2026-10-29T15:13:31Z
Collect readable pre-build reports	2026-10-29T15:13:43Z
Maven compilation started	2026-10-29T15:13:52Z

Verified: every prerequisite completion timestamp precedes the Maven compilation start. The job dependency configuration provides the enforcement, while these timestamps demonstrate the order in the recorded execution.

The earlier dependency:resolve command is metadata resolution only. The later mvnw verify command performs compilation, testing and packaging. These operations are intentionally separate.

Source files: ordering-proof.json, native-reports/workflow-result.json and configuration/.github/workflows/prebuild-security.yml.

8. Actual failures and the response

Empty early dependency inventory: the 23 October target-directory scan returned no packages and an empty SBOM. A green exit did not establish dependency coverage. The new source-POM scan and explicit coverage checks correct this issue. The old report remains historical evidence.

Maven Central rate limit: the first 29 October hosted source scan received HTTP 429 while retrieving dependency metadata. It failed rather than claiming an incomplete scan passed. Maven compilation and downstream image jobs were skipped. The correction populates a dependency cache with dependency:resolve and scans the cached metadata. This was a repository-access failure, not a detected application vulnerability.

Historical Checkov failure: the optional tools configuration originally allowed public HTTP port 80. Checkov CKV_AZURE_160 blocked that revision. The correction closed port 80 and used TLS-ALPN certificate validation on port 443. The original JUnit reports are included under historical-failures/checkov-public-http/.

Remaining application work: six HIGH entity-binding Sonar findings, authentication/authorization, request validation, improved tests and tested off-VM backups remain open. The initial Sonar baseline had 41.5% overall coverage. A passed new-code gate did not establish overall application security.

Provenance: scans ran on a hosted Linux runner for the recorded revision. This local document is a readable view of the original tool outputs. The native reports, configuration snapshots and SHA-256 manifest accompany it. This report introduces no new finding suppressions. Existing Checkov policy exclusions remain documented.

Technical references: Trivy Java POM coverage at https://trivy.dev/docs/latest/guide/coverage/language/java/ and Trivy JSON conversion at https://www.trivy.dev/docs/v0.53/guide/configuration/reporting/.

9. Acceptance phase: Nmap (5 November 2026)

Nmap is the post-deployment network exposure gate. Pre-commit and commit checks still precede Maven compilation. After deployment, Nmap checks public endpoints from a hosted runner and private/localhost endpoints from the application VM. A failing gate blocks later monitoring verification; pipeline email reports failure. No automatic rollback is configured.

Viewpoint / profile	Target	Open TCP ports	Scanned	Result
public / app-public	158.158.49.102	None	1040	PASSED
public / tools-public	68.221.67.223	443, 8443	1040	PASSED
private / app-loopback	127.0.0.1	22, 3000, 8089, 9091	1040	PASSED
private / app-private	10.42.1.4	22, 9100	1040	PASSED
private / tools-private	10.42.2.4	22, 443, 8443, 9100	1040	PASSED

Scope: TCP ports 1-1024 plus 2375, 2376, 3000, 3306, 5432, 6443, 8080, 8081, 8089, 8443, 9000, 9090, 9091, 9100, 10250 and 30089. Other TCP ports and UDP were not tested. The TCP connect scan uses light service detection and no exploit scripts.

Public app: all 1,040 tested ports were filtered. Public tools: only HTTPS ports 443 and 8443 were open. Private and localhost checks positively verified SSH, the application/monitoring listeners and private Node Exporters. Filtered means no usable reply from that scanner viewpoint; -Pn assumes a host is up.

Nmap names such as ppp, xmltec-xmlmail and jetdirect are port-table guesses. Compose maps those ports to Grafana, Prometheus and Node Exporter. These labels do not prove a protocol identity or a vulnerability. The gate checks exposure against the declared policy, not application authorization or CVE coverage.

Original files: native-reports/acceptance/public/ and private/ contain .xml, .nmap, .gnmap, logs and tool versions. Acceptance JSON, exact workflow metadata, the policy snapshot and checksummed Azure report-transport record are included.

10. Real Nmap failure and corrected rescan

The first public app scan reached the 180-second host timeout. Nmap returned process exit success but no port table. The completeness gate rejected that incomplete scan. This was a scan-timing problem, not a discovered application vulnerability. All three private profiles and public tools already passed in that attempt.

```
FIRST ATTEMPT - ORIGINAL NMAP OUTPUT
Nmap scan report for 158.158.49.102
Host is up, received user-set.
Skipping host 158.158.49.102 due to host timeout
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Thu Nov  5 10:47:16 2026 -- 1 IP address (1 host up) scanned in 180.42 seconds
```

Correction: keep the same 1,040-port scope, allowed/required services, retry count, 100-probe/second port-scan ceiling and 180-second host deadline. Bound concurrency to 16-32 probes and set initial/maximum RTT timeouts to 500 ms / 1 second. Explicitly reject timedout XML hosts. No firewall rule was weakened and no defect was planted.

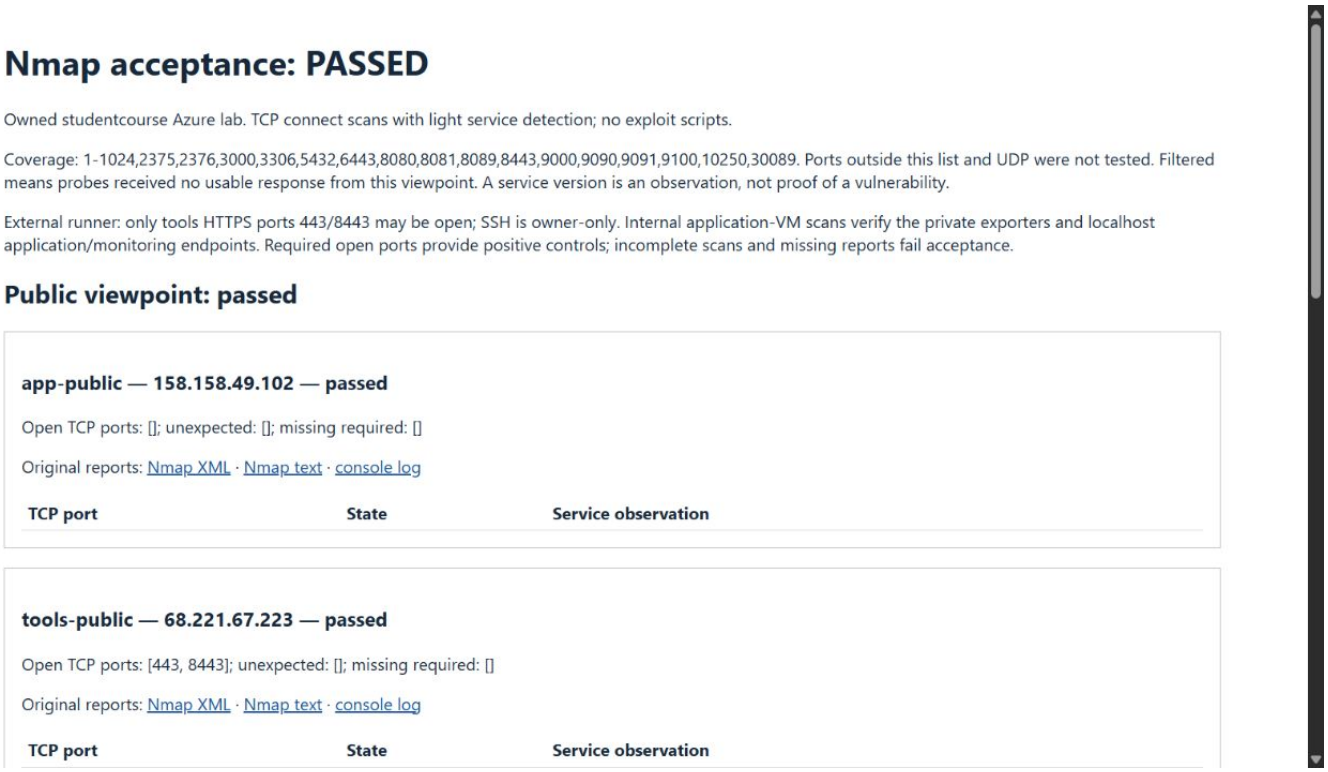
```
CORRECTED ATTEMPT - ORIGINAL NMAP OUTPUT
Nmap scan report for 158.158.49.102
Host is up, received user-set.
All 1040 scanned ports on 158.158.49.102 are in ignored states.
Not shown: 1040 filtered tcp ports (no-response)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Thu Nov  5 11:07:58 2026 -- 1 IP address (1 host up) scanned in 66.28 seconds
```

The corrected scan completed in 66.28 seconds. All five profiles passed. The final assessment rechecked the original XML target, port coverage and policy rather than trusting a green status JSON. Original failed files: historical-failures/nmap-host-timeout/.

11. Nmap report screenshots

Actual report views of the verified public and private scan results. Original tool files remain the primary evidence; screenshots illustrate them.



Nmap acceptance: PASSED

Owned studentcourse Azure lab. TCP connect scans with light service detection; no exploit scripts.

Coverage: 1-1024,2375,2376,3000,3306,5432,6443,8080,8081,8089,8443,9000,9090,9091,9100,10250,30089. Ports outside this list and UDP were not tested. Filtered means probes received no usable response from this viewpoint. A service version is an observation, not proof of a vulnerability.

External runner: only tools HTTPS ports 443/8443 may be open; SSH is owner-only. Internal application-VM scans verify the private exporters and localhost application/monitoring endpoints. Required open ports provide positive controls; incomplete scans and missing reports fail acceptance.

Public viewpoint: passed

app-public — 158.158.49.102 — passed

Open TCP ports: []; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

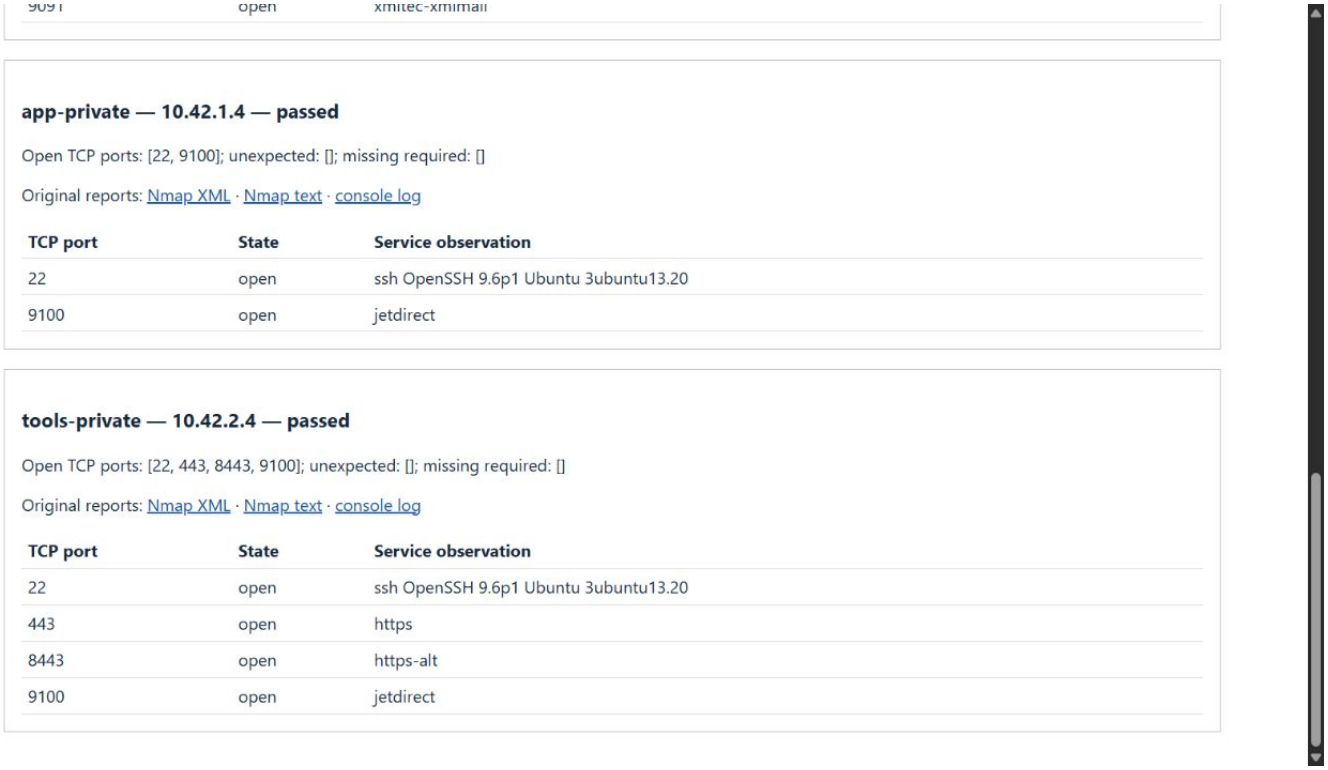
TCP port	State	Service observation

tools-public — 68.221.67.223 — passed

Open TCP ports: [443, 8443]; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

TCP port	State	Service observation
9091	open	xmltec-xmlmail



app-private — 10.42.1.4 — passed

Open TCP ports: [22, 9100]; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

TCP port	State	Service observation
22	open	ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.20
9100	open	jetdirect

tools-private — 10.42.2.4 — passed

Open TCP ports: [22, 443, 8443, 9100]; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

TCP port	State	Service observation
22	open	ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.20
443	open	https
8443	open	https-alt
9100	open	jetdirect